

2026

IT Risk and Compliance Benchmark Report



A PUBLICATION BY  hyperproof

TABLE OF CONTENTS

Foreword 3

Top Findings in Numbers 5

01 How GRC Leaders Are Scaling and Operating Their Compliance Programs..... 9

02 Framework Adoption Trends and Risk Management Best Practices 30

03 Budgets, Capacity, and ROI: How GRC Teams Are Funding the Work in 2026 52

04 Third-Party Risk Management at Scale 81

05 Decision Power in GRC: Ownership, Oversight, and Organizational Readiness 107

Survey Methodology 126

About Hyperproof..... 132

FOREWORD

2025 reinforced what many GRC leaders have been feeling for the past several years: the work is expanding, the expectations are accelerating, and the margin for error is shrinking. Risk and compliance teams are being asked to demonstrate readiness more frequently, respond faster when something goes wrong, and provide clearer proof of control effectiveness to stakeholders across the business.

At the same time, third-party ecosystems continue to grow, introducing new operational dependencies and new categories of risk that cannot be managed through point-in-time reviews alone. As AI becomes embedded across workflows and vendor offerings, GRC teams are increasingly expected to govern not only traditional security and compliance risks, but the rapidly evolving risks associated with AI-enabled technology.

The findings of this year's survey point to a market investing in maturity but still working through the operational realities of scaling. Many organizations report strong confidence in their ability to execute: most respondents said they had the budget and resources needed to achieve their goals in 2025, and a majority anticipate spending more money on GRC in 2026. At the same time, the underlying workload pressure is clear. Organizations expect to spend more time on IT risk management and compliance in the year ahead, and breach experience appears to be a meaningful accelerant: respondents who experienced a breach are significantly more likely to anticipate increased time investment in 2026 than those who did not. Taken together, this suggests that even when resourcing is available, the central challenge becomes how to scale readiness without scaling administrative overhead in parallel.

So, what does this mean for 2026?

The short answer? GRC operating models and tooling choices matter. Respondents who manage risk ad-hoc are far more likely to have experienced a breach than those using an integrated, automated approach. Many organizations report high maturity and widespread adoption of third-party risk management best practices, yet their execution inputs remain mixed, with continued reliance on spreadsheets and document-based questionnaires. **This gap reflects an important reality for 2026: maturity is no longer defined by intent or policy alone. It is defined by consistency, traceability, and the ability to maintain assurance over time across controls, evidence, and third parties.**

As you explore the benchmarks and insights throughout this report, we invite you to consider where your program sits on the maturity curve and what it will take to move forward this year. The collective experience of your peers points to a clear direction: teams are prioritizing centralization, standardization, and automation to reduce manual effort and sustain continuous readiness. Whether you are formalizing an emerging program or evolving a mature one, the opportunity in 2026 is to turn investment into measurable outcomes that result in less time spent chasing evidence, clearer reporting for leadership, and stronger resilience when risks materialize.

Top Findings in Numbers

50%

of respondents who manage risk ad-hoc or when a negative event happens experienced a breach in 2025

An integrated, automated approach to risk management is linked to a reduction in breaches: respondents using an integrated, automated tool were less likely to experience a breach at only 27%.

97%

of respondents are using AI to streamline their workflows

AI adoption is now mainstream in GRC. The biggest advantage comes when it's embedded into a SaaS platform that can apply AI directly to controls, evidence, and assessments, not as a disconnected tool.

58%

of companies that experience a breach anticipate spending more time on IT risk management and compliance in 2026

Breaches can lead to an expanded workload on already-taxed teams. After an incident, GRC professionals anticipate that their workloads will increase beyond immediate response.

86%

of respondents have a centralized team to manage GRC

Centralizing GRC activities is becoming a best practice. Only 14% of respondents manage GRC via individual teams or business units.

34%

of respondents are still using spreadsheets to identify and manage third-party risks

Large portion of respondents are still using manual processes to address third-party risk management, leading to scalability challenges as vendor ecosystems expand.

58%

of respondents anticipate that their organization will spend more money on GRC in 2026

The majority of respondents expect GRC budgets to increase for the second consecutive year, despite a challenging economic climate.

70%

of respondents have GRC budgets of over \$1M

Most of the surveyed organizations are making a substantial investment in GRC. Only 30% of respondents reported that their annual GRC budget is under \$1M.

56%

of respondents said they use a common controls framework to streamline their GRC processes

Using a common controls framework (CCF) has become a standard best practice, aligning with our findings in 2025.

92%

of respondents said they had the budget and resources they needed to achieve their goals in 2025

This confidence creates an opportunity to translate investment into measurable results by prioritizing automation and consolidation over adding more manual processes.

68%

of respondents say their team sizes will grow over the next two years

Even with planned headcount growth, teams will still need scalable workflows and automation to keep pace with increasing regulatory demands without linear increases in effort.



CHAPTER 1

How GRC Leaders Are Scaling and Operating Their Compliance Programs

Compliance teams are being asked to do more than ever: keep pace with expanding requirements, demonstrate control effectiveness faster, and deliver audit-ready evidence with fewer bottlenecks. Most organizations are organizing GRC work in ways that look mature on paper, like centralized teams, regular audits, and increasing use of controls monitoring.

However, the day-to-day reality still includes heavy manual overhead, fragmented systems, and cross-functional chasing that slows everything down. The biggest differentiator in this chapter isn't simply whether a program is centralized; it's whether the work is executed through **integrated, repeatable workflows** that keep controls and evidence current year-round.

This year's data shows a clear picture of where this friction still persists, especially in manual work, cross-team coordination, and evidence readiness. It also underscores a consistent theme across the benchmark: the structure of your compliance operations – where it's centralized, distributed across your organization, automated, or addressed ad-hoc – is closely tied to compliance outcomes. This points to a consistent operational reality: **organizations are structurally centralizing GRC and increasingly adopting monitoring software, but they still lose significant time to manual work and fragmented processes.**

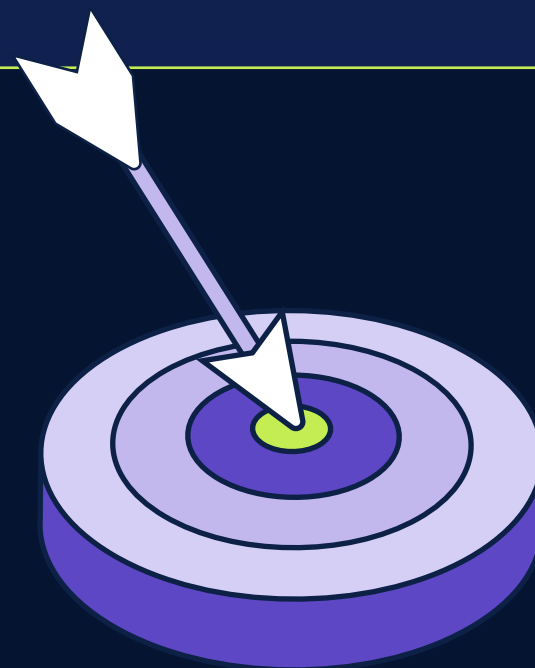
The strongest differentiator across our findings is not just whether a team is centralized. It's whether risk and compliance workflows are executed in an integrated, automated way that supports continuous evidence readiness and control assurance.

Organizations are structurally centralizing GRC and increasingly adopting monitoring software, but they still lose significant time to manual work and fragmented processes.

How compliance is structured and governed

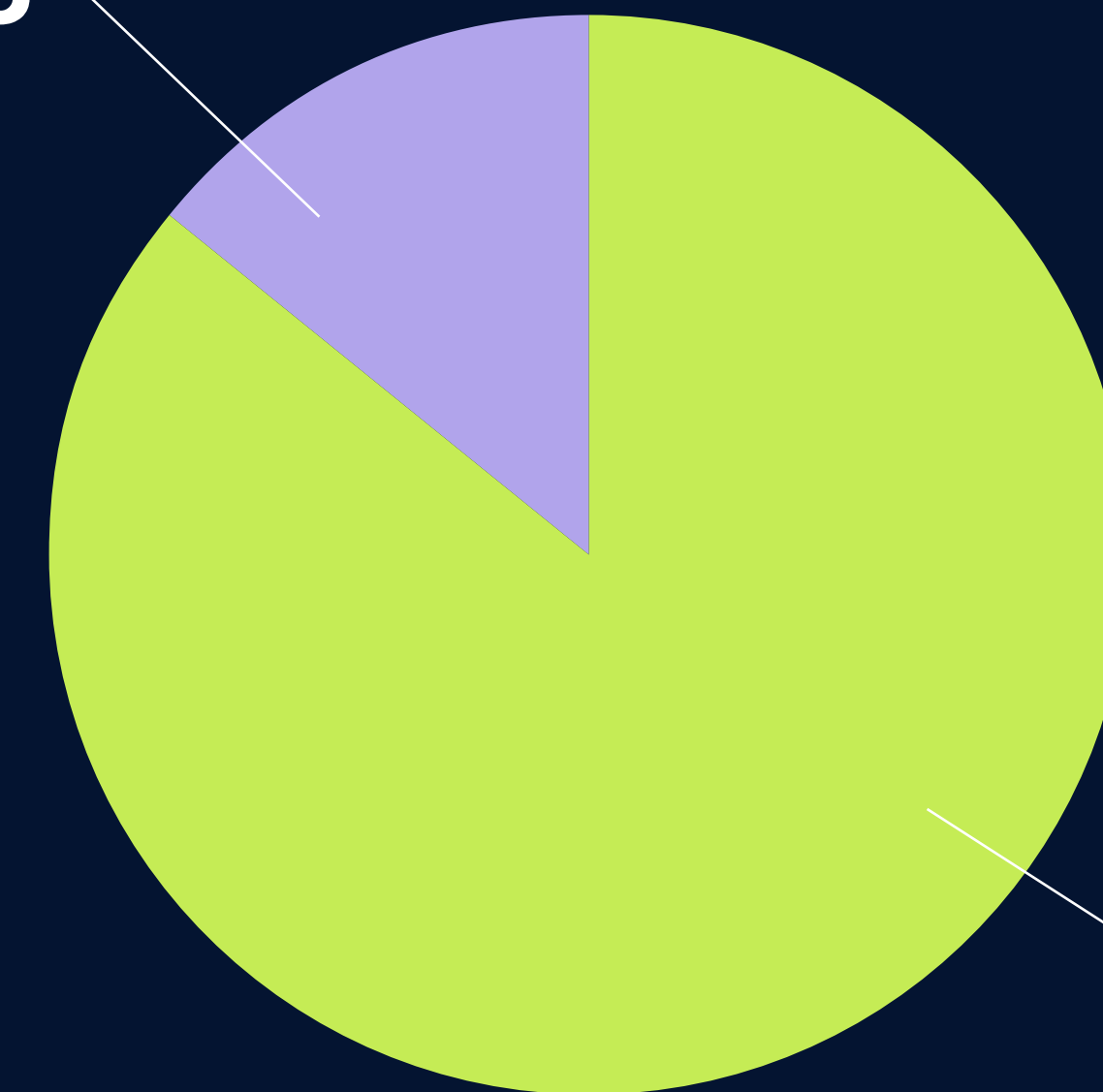
Most organizations report having centralized ownership for governance, risk, and compliance. 86% of respondents have a centralized team responsible for GRC efforts, while only 14% said that individual teams or business units handle GRC. Centralization has become the dominant operating model, but centralization alone doesn't guarantee that risk and compliance are truly integrated in practice.

Centralization has become the dominant operating model, but centralization alone doesn't guarantee that risk and compliance are truly integrated in practice.



Does your organization have a centralized governance, risk, and compliance program that works across business units and geographies?

14%



86%

● We have a centralized team responsible for our GRC efforts

● Individual teams or business units handle their own GRC efforts

Many organizations still treat compliance and risk as separate activities rather than a unified system. When asked how risk and compliance functions are structured, 57% reported that risk and compliance are integrated functions, while 36% said they are separate functions, with each having its own staff. 7% said it varies by function or location. Only about one in five respondents has an integrated view where risk and compliance are explicitly tied together. The more common reality is that compliance helps reduce risk, but the two functions still tend to activate in response to different triggers, leading to duplicated efforts, unclear ownership, and gaps in visibility.

Notably, program structure influences whether organizations experience consistency or variability: respondents with individual teams and/or business units were more likely to say risk/compliance structure varies by business function and/or location (11%) than those with a centralized team (6%). This aligns with a practical reality: distributed models may better reflect how work gets done locally, but they often introduce inconsistencies in how controls are implemented, evaluated, and evidenced.

At your organization, is the risk management function a distinct and separate function from the compliance function, or are risk responsibilities rolled into compliance personnel's jobs?

by GRC program structure



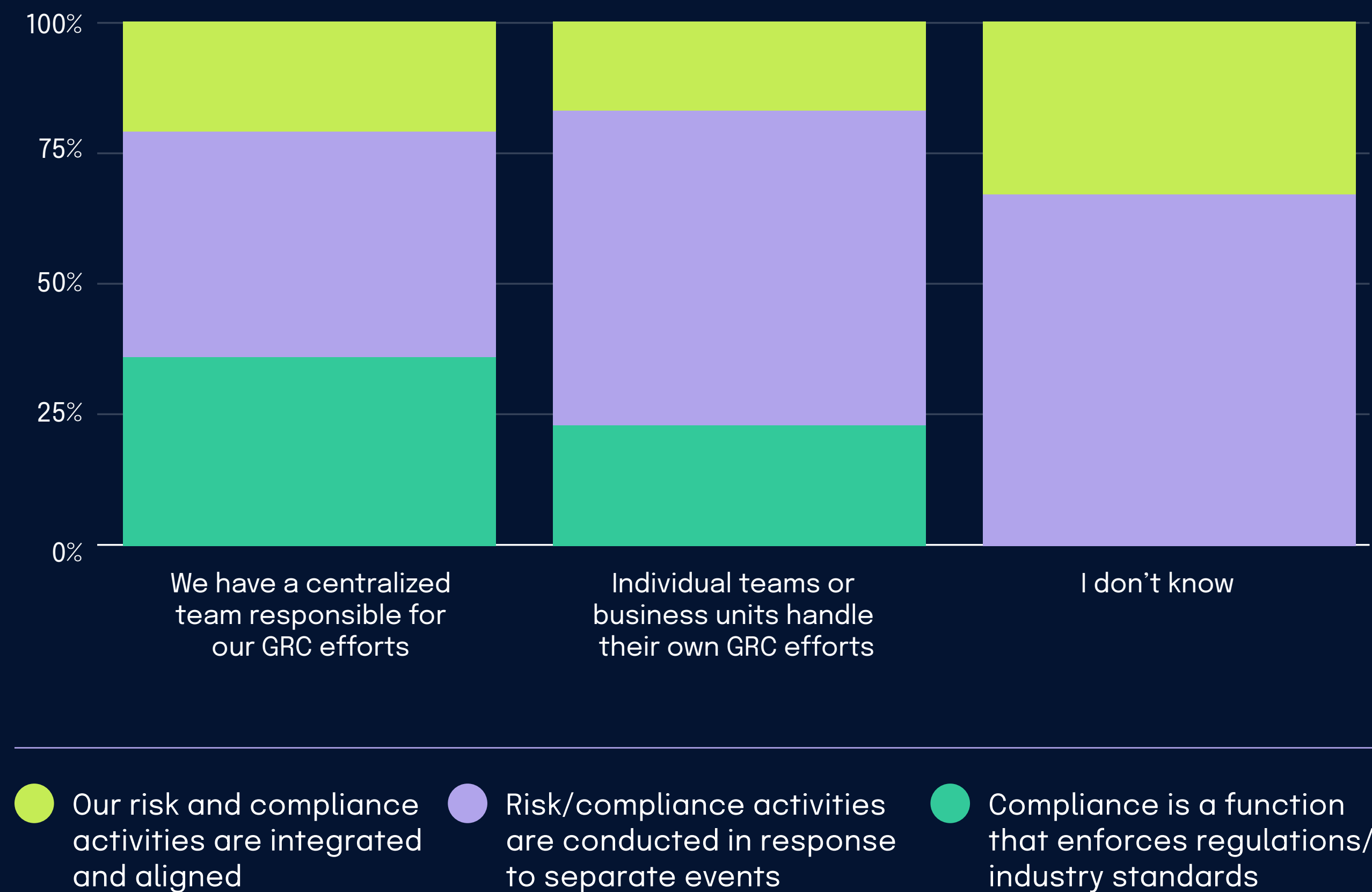
When asked about the purpose of compliance, only 21% of those who have a centralized team responsible for GRC reported having an integrated view of how to manage their risks. In comparison, 43% reported that risk and compliance activities are conducted in response to separate events. Another 36% said that their organization simply views compliance as the function that enforces regulatory standards.

The takeaway?

Distributed programs are more likely to interpret compliance as a reactive function, an outcome that can add friction when organizations need fast, proactive reporting on control posture and risk exposure.

Which statement best reflects how your organization views the purpose of the compliance function?

by GRC program structure



What's slowing teams down during day-to-day compliance work

Even where compliance programs appear structurally mature, the operational reality is that many teams are still wrestling with manual, repetitive work and fragmented processes. Respondents most often cited challenges that reflect a common root issue: **lack of centralized visibility and workflow continuity**.

Top-most time-consuming compliance tasks

When asked about their most time-consuming compliance tasks, the top reported issues were switching between multiple systems, identifying where critical risks are, and finding risk-related information. These are the hallmarks of a workflow problem, not a talent problem. When compliance teams are forced to operate across multiple sources of truth, every audit, control test, and report becomes a mini data-integration project.

The tasks that closely follow when effort turns into coordination: following up with staff in other departments, ensuring consistency in how controls are applied across an organization, and maintaining policies and tracing evidence of control operation. These tasks are often less about technical complexity and more about operational fragmentation, which are precisely the conditions that make compliance difficult to scale.

What recurring or time-consuming tasks do you struggle with when managing security and data privacy risks in your internal environment?



This pattern becomes even clearer when comparing responses by approach to managing IT risks. For example, respondents who manage IT risk ad-hoc reported higher overall friction than those using an integrated, automated tool. Those who manage risk ad-hoc particularly struggle with managing user permissions, conducting user access reviews, data entry tasks, and finding risk-related information when they need it. Similarly, the ability to maintain traceability from requirements to evidence appears.

What recurring or time-consuming tasks do you struggle with when managing security and data privacy risks in your internal environment?	Approach to managing IT risks				
	Ad-hoc	In siloed departments, processes, and tools	An integrated, manual tool	An integrated, automated tool	Our MSSP manages our IT risks
Switching between multiple systems	45%	42%	37%	38%	25%
Identifying where critical risks are	40%	44%	34%	41%	43%
Finding risk-related information when I need it	49%	50%	43%	43%	49%
Managing user permissions and conducting user access reviews	51%	49%	42%	48%	55%
Data entry tasks	49%	47%	49%	43%	47%
Collecting the necessary data to test controls	30%	29%	31%	32%	27%
Tracking remediation progress	28%	29%	29%	33%	25%
Getting a continuous view of risks	29%	28%	27%	30%	40%
Following up with staff in other departments for information about risks	24%	22%	21%	27%	29%
Ensuring consistency in the application of controls across various departments	25%	19%	27%	32%	37%
Assembling reports for executives	15%	23%	24%	34%	19%
Maintaining traceability from regulatory/contractual/legal requirements to policy to control to evidence of control operation	11%	21%	18%	26%	19%
None of the above	2%	2%	3%	4%	7%

The audit prep burden is growing

Preparing for and executing audits is also time-consuming. Audit execution tasks point to a consistent operational pressure: access reviews, evidence retrieval, and auditor back-and-forth dominate where teams spend time. These are not edge-case problems. They're foundational compliance operations that repeat every cycle and scale poorly as the business grows.

The largest time sinks align closely with evidence workflows and access governance. These tasks are foundational – not fringe – and they represent a major opportunity for organizations to reduce audit cycle time by streamlining how evidence is collected, validated, stored, and permissioned. If teams want to reduce audit cycle time and reduce audit fatigue, the path is not “work harder” or “hire more.” It's to automate evidence collection, standardize ownership and approvals, and reduce one-off follow-ups by keeping evidence continuously up to date.

When it comes to preparing for and executing audits, what tasks do you find to be tedious or take way longer than you'd like?



Administrative overhead remains a material constraint

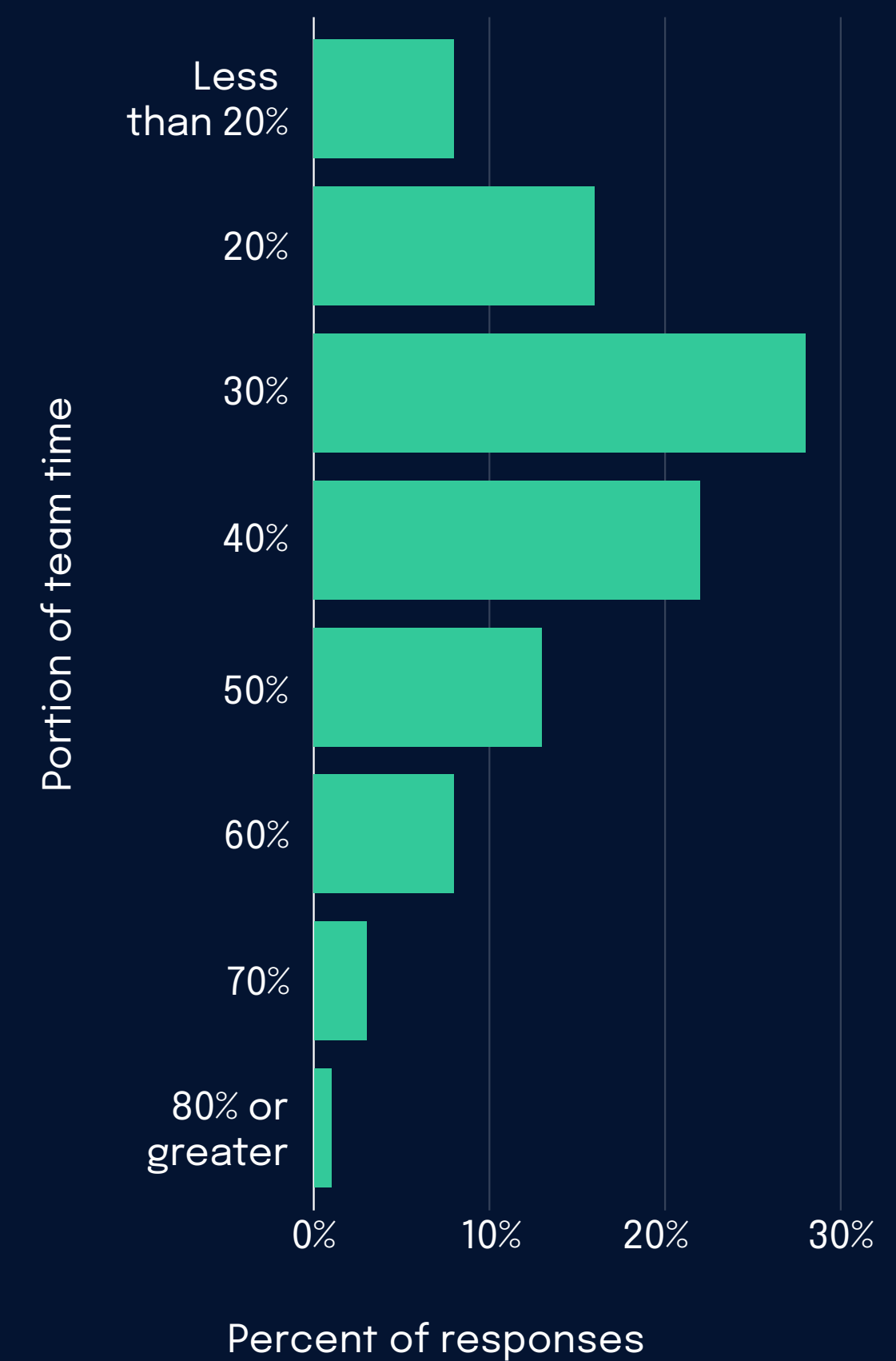
Manual work remains one of the most consistent signals in this year's data, and one of the clearest levers for improving compliance efficiency. A major share of respondents report that a meaningful chunk of risk/compliance time is spent on repetitive administrative work, with the largest concentration in the 30%–50% range.

Even more telling: Organizations that operate ad-hoc or in silos show a higher average admin-time burden than those using integrated, mostly automated approaches.

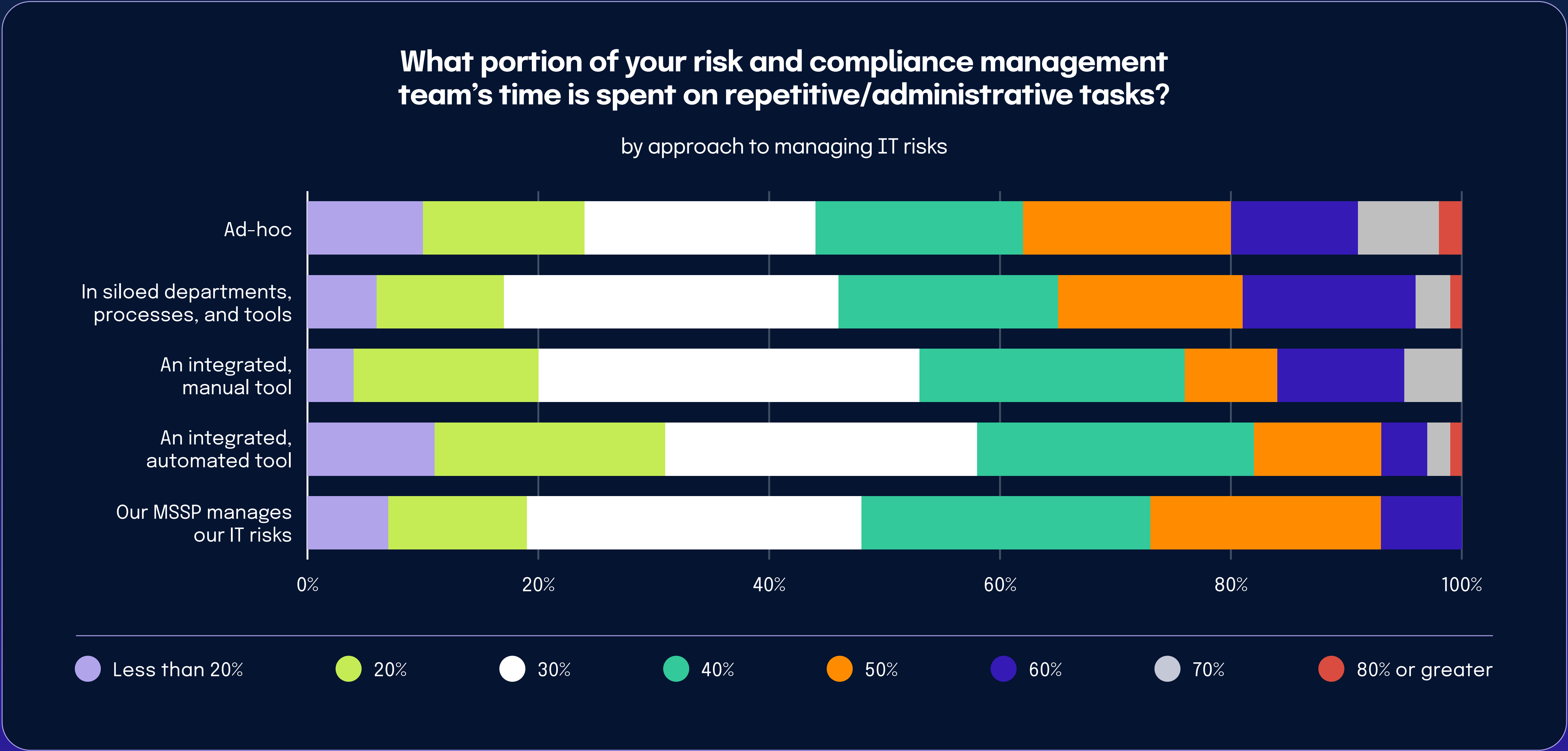
76% of respondents report spending 30% or more of their time on repetitive tasks, which hasn't changed much year over year (2025's results came in at 77%). Administrative overhead doesn't just slow down compliance tasks. It reduces the time available for higher-value work, like proactive risk analysis, control design improvements, and readiness planning. It also creates a compounding effect: the more time is spent on administration, the harder it becomes to shift toward continuous monitoring and continuous evidence readiness.

Compliance capacity is currently being spent on staying afloat rather than improving controls, strengthening risk decisions, or preparing for future requirements. This is where automation creates compounding returns, because time saved here flows into every other part of the program.

What portion of your risk and compliance management team's time is spent on repetitive/administrative tasks?



However, organizations using an integrated, automated tool have a lower average administrative time burden (~33%) than those managing IT risk ad-hoc (39%) or in siloed departments (39%). This relationship is directionally consistent: integrated workflows reduce the coordination and reconciliation work that drives administrative load.



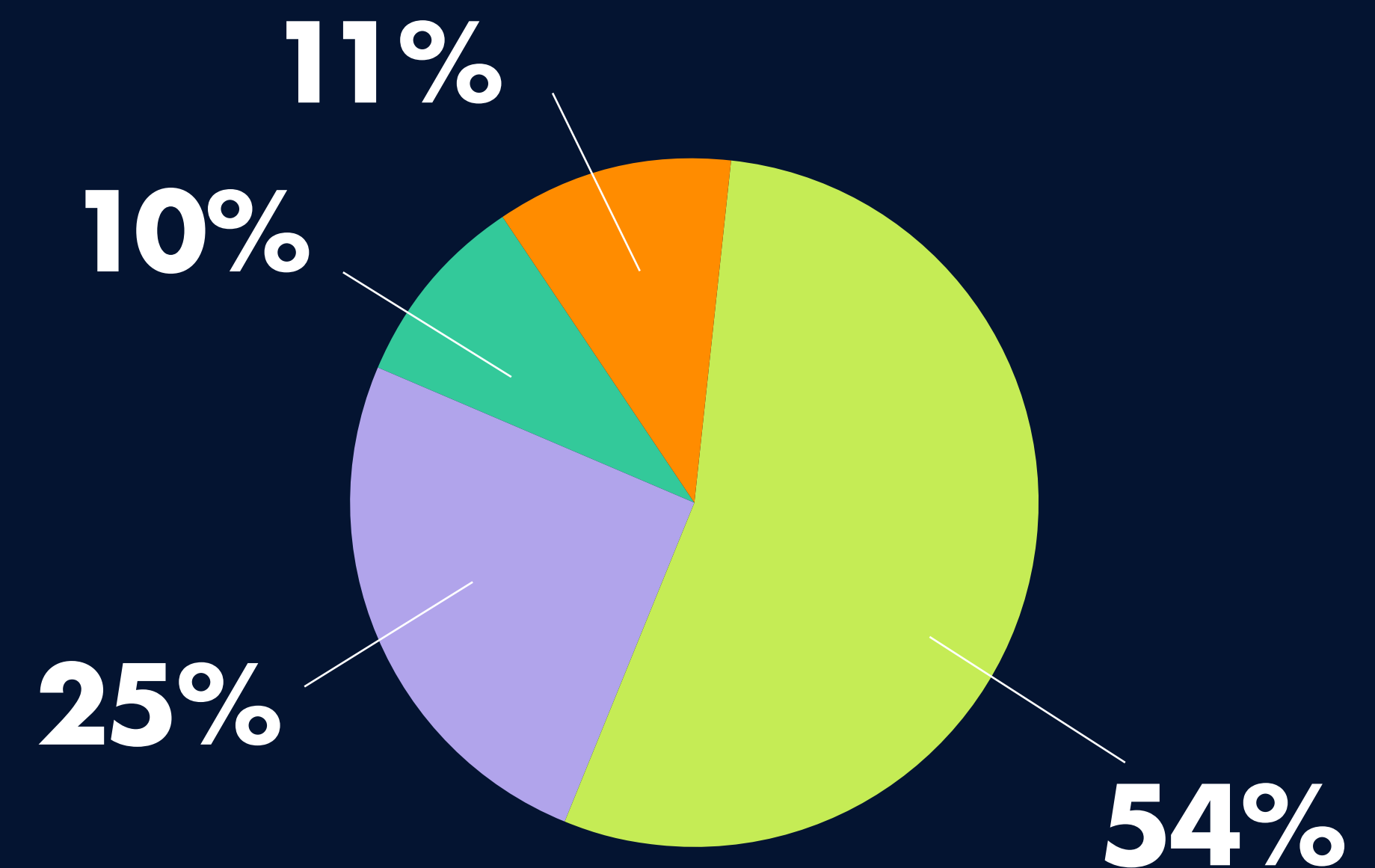
Continuous compliance is advancing (unevenly)

The data suggests that many organizations are taking steps toward more continuous compliance behaviors, but respondents still have a meaningful gap between intent and practice. When asked about their approach to evidence collection, respondents most commonly said they regularly collect evidence for internal and external audits.

The takeaway?

Ongoing evidence collection is substantial, but it is not yet the dominant practice.

How does your organization approach evidence collection to verify that controls are operating effectively?



Evidence collected

Internal and external audits; we conduct internal audits regularly

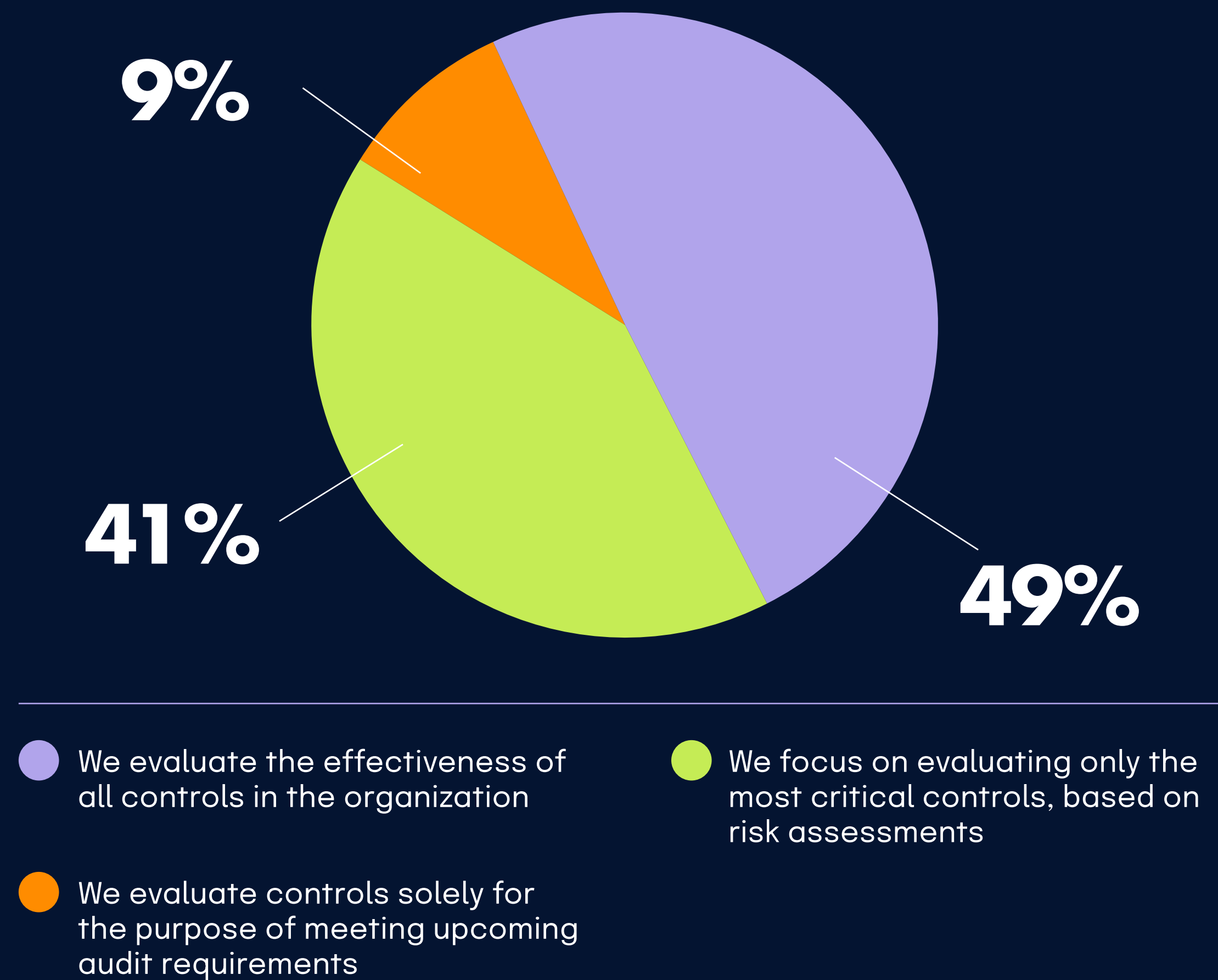
Ongoing basis, as part of a continuous compliance program

Ad-hoc basis

Only for external audits

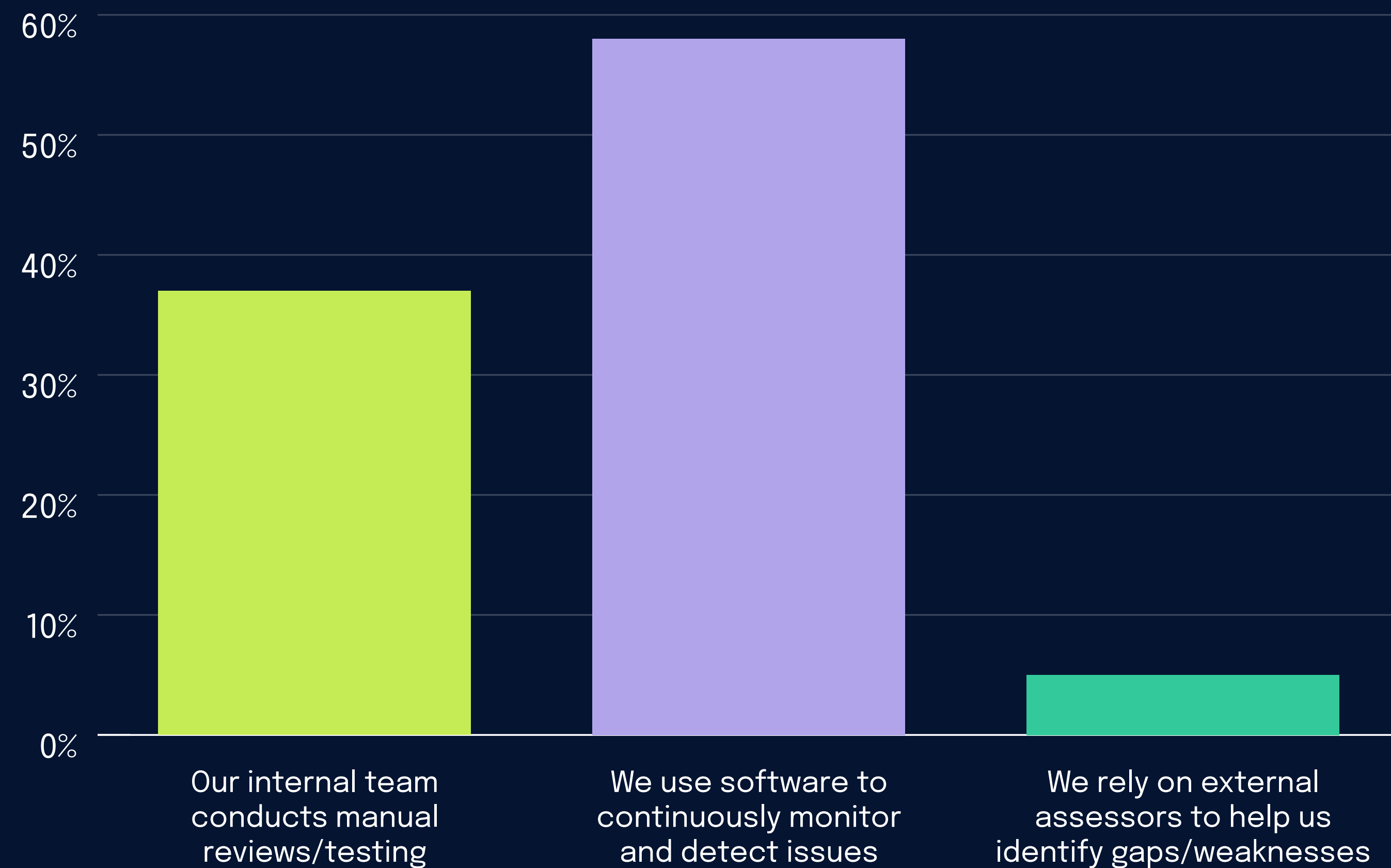
Control evaluation patterns show a similar split between broad assurance and risk-based prioritization. 49% of respondents evaluate the effectiveness of all controls, and 41% evaluate only the most critical controls. Routine control evaluation is becoming standard, but organizations vary widely on whether this evaluation is comprehensive or targeted. Evaluating all controls can indicate broad assurance maturity, but it can also imply workload. Risk-based control evaluation can be appropriate when prioritization is explicit and continuously updated. The key difference is whether organizations have the infrastructure to make either approach repeatable and defensible.

Which statement best describes your organization's approach to evaluating the effectiveness of security and compliance controls?



The move toward continuous compliance is apparent when looking at controls monitoring as well. We asked respondents about their approach to controls monitoring, and 58% reported that they use software to continuously monitor controls.

Which of the following best characterizes your organization's approach to monitoring the efficacy of security controls?



Outsourcing as a strategy for scalability

Outsourcing remains a meaningful part of how organizations scale compliance and security programs, particularly for specialized tasks and high-effort operational needs. Outsourcing is widely used, particularly for specialized and execution-heavy work such as security testing and risk assessments. Many organizations also rely on external support for policy generation and security/asset management. At the same time, fewer outsource the core operational backbone of compliance, such as compliance management or defining a unified control framework.

Select all the services that you outsource to consulting/security and compliance advisory firms:



Company size patterns are instructive. Smaller organizations are more likely to outsource risk assessments and security/asset management than the largest organizations. This likely reflects practical constraints: limited internal bandwidth, limited specialization, and a need to accelerate execution. Larger organizations may bring more capabilities in-house, but their complexity increases demands for standardization, coordination, and visibility.

Select all the services that you outsource to consulting/security and compliance advisory firms.	Company size			
Response	100 to <1,000	1,000 to <2,500	2,500 to < 5,000	5,000+
IT security and asset management	51%	49%	51%	37%
Security testing	49%	42%	41%	32%
Policy generation	35%	42%	38%	43%
Risk assessments	38%	45%	45%	47%
Business continuity plan testing	34%	41%	39%	33%
Readiness reviews/gap assessments	24%	23%	22%	27%
Compliance management	25%	35%	26%	21%
Defining a unified control framework	30%	28%	28%	26%
Vendor risk assessment	56%	61%	48%	34%
Control design	30%	27%	27%	21%
Vendor/supply-chain management	20%	21%	17%	17%
Project management	16%	10%	9%	17%
Other	4%	2%	3%	5%

Using AI to streamline workflows

AI adoption in GRC has moved decisively beyond experimentation and into day-to-day execution. Only 3% of respondents say they are not using AI to streamline any workflows, demonstrating how quickly AI is becoming a baseline productivity layer for many teams rather than a niche capability used by early adopters.

What stands out is where AI is being applied. The highest-use workflows are documentation-heavy activities that historically consume substantial time and slow down delivery, like reviewing documentation and merging multiple documents. These are the exact areas where GRC teams often face bottlenecks, because they require synthesizing information across sources, mapping it to standards, and producing consistent outputs. The data suggests teams are first turning to AI where it can reduce manual reading, comparison, and rewrite work, helping them move faster without sacrificing rigor.

AI is also being used as a research and analysis accelerator, not just a writing assistant. More than half of respondents (52%) use AI for research, indicating that teams are increasingly relying on AI to gather context, summarize requirements, and support decision-making quickly. At the same time, a significant share are using AI for writing policies (41%), which points to a practical shift: policy work is still important, but teams appear to be prioritizing AI for the tasks that sit between policy and execution, such as interpreting documentation, normalizing inputs, and aligning controls.

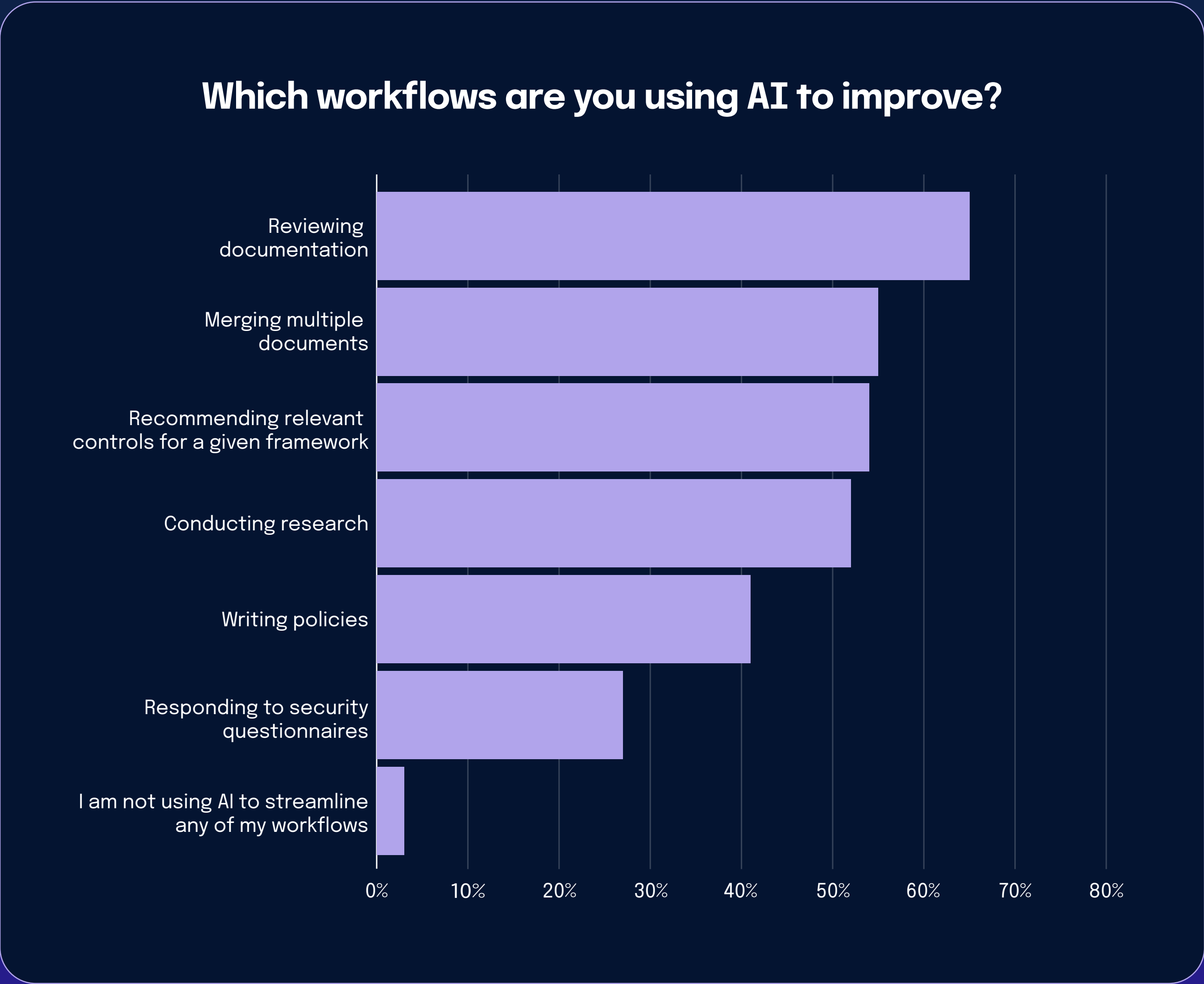
52%

of respondents use AI
for research

41%

of respondents use AI
for writing policies

One of the most revealing findings is what remains comparatively low: responding to security questionnaires (27%). Given how frequently questionnaires are cited as a pain point in many organizations, this suggests that while teams see value in using AI for core internal workflows, fewer have fully operationalized AI for external-facing assurance processes. That gap may reflect the need for stronger guardrails, higher confidence in outputs, or better integration with systems of record so that responses can be grounded in validated evidence rather than generated from scratch.



OUTCOMES:

The connection between breaches and approaches to risk management

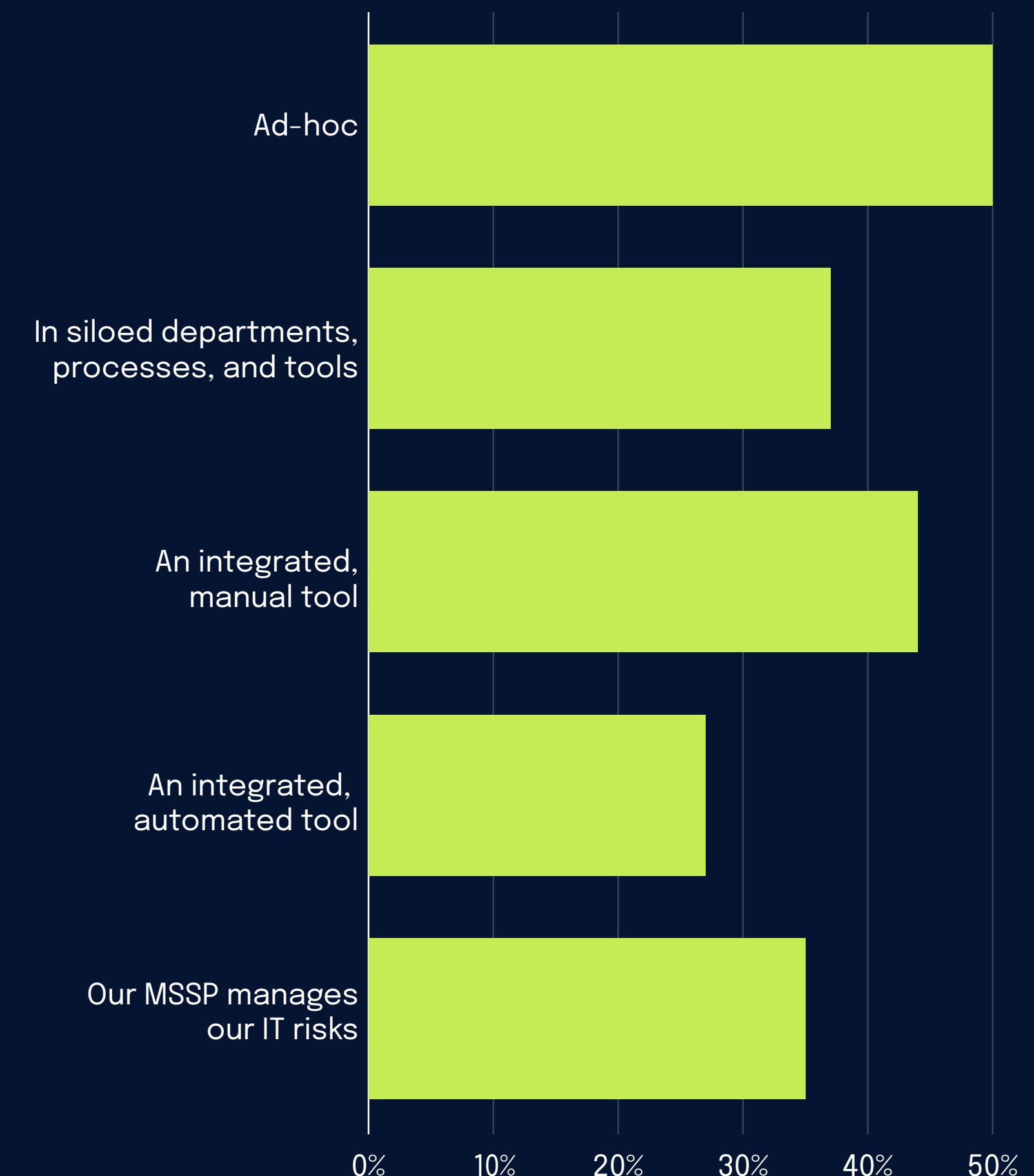
Using integrated tools to manage IT risks may reduce the likelihood of a data breach

The compliance operating model is not just an efficiency question. It's closely tied to risk outcomes. **Respondents who manage IT risk ad-hoc report markedly higher breach rates than respondents using an integrated and mostly automated approach.** 50% of those managing risk ad-hoc experienced a breach in 2025, vs. only 27% using an integrated, automated tool. This mirrors our survey results for the last three years, emphasizing that organizations with integrated, automated approaches are better positioned to reduce risks and shorten the time from signal to action. This is the practical promise of SaaS GRC: not only faster audits, but better control assurance, more current evidence, and stronger visibility into posture.

In the last 24 months, has your organization experienced a security breach?

by IT risk management approach

A: Yes

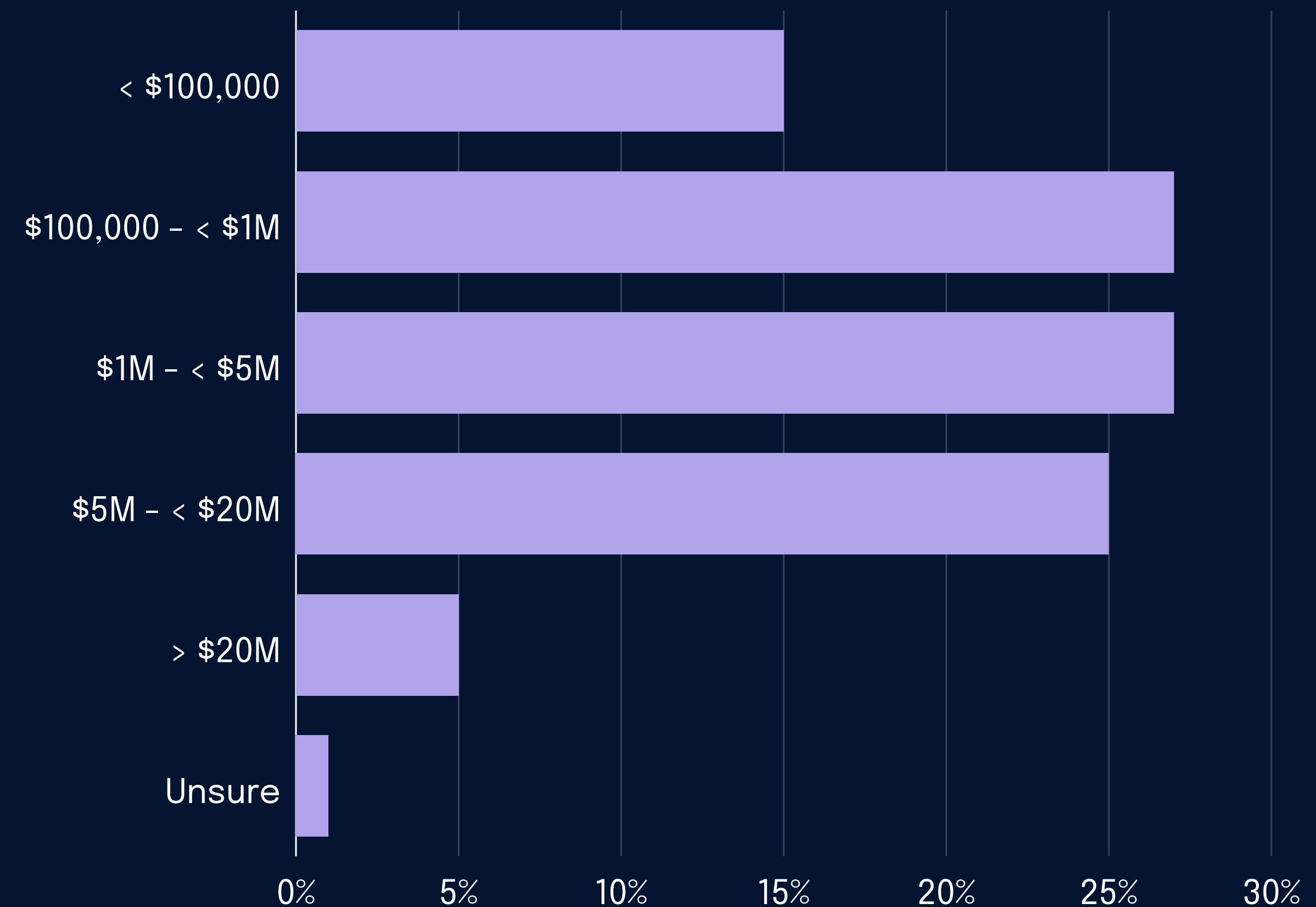


Breach cost distribution adds weight to the operational argument. A meaningful share of respondents report breach costs in the multi-million-dollar range, with one in four respondents reporting costs of \$5M or more. While many factors influence the cost of breaches, the presence of materially high-cost outcomes reinforces why operational efficiency and continuous readiness are not merely internal improvements. They are risk reduction strategies.

1 in 4

report incurring \$5M+ in losses as a result of a data breach

How much did your organization incur as a result of this data breach?



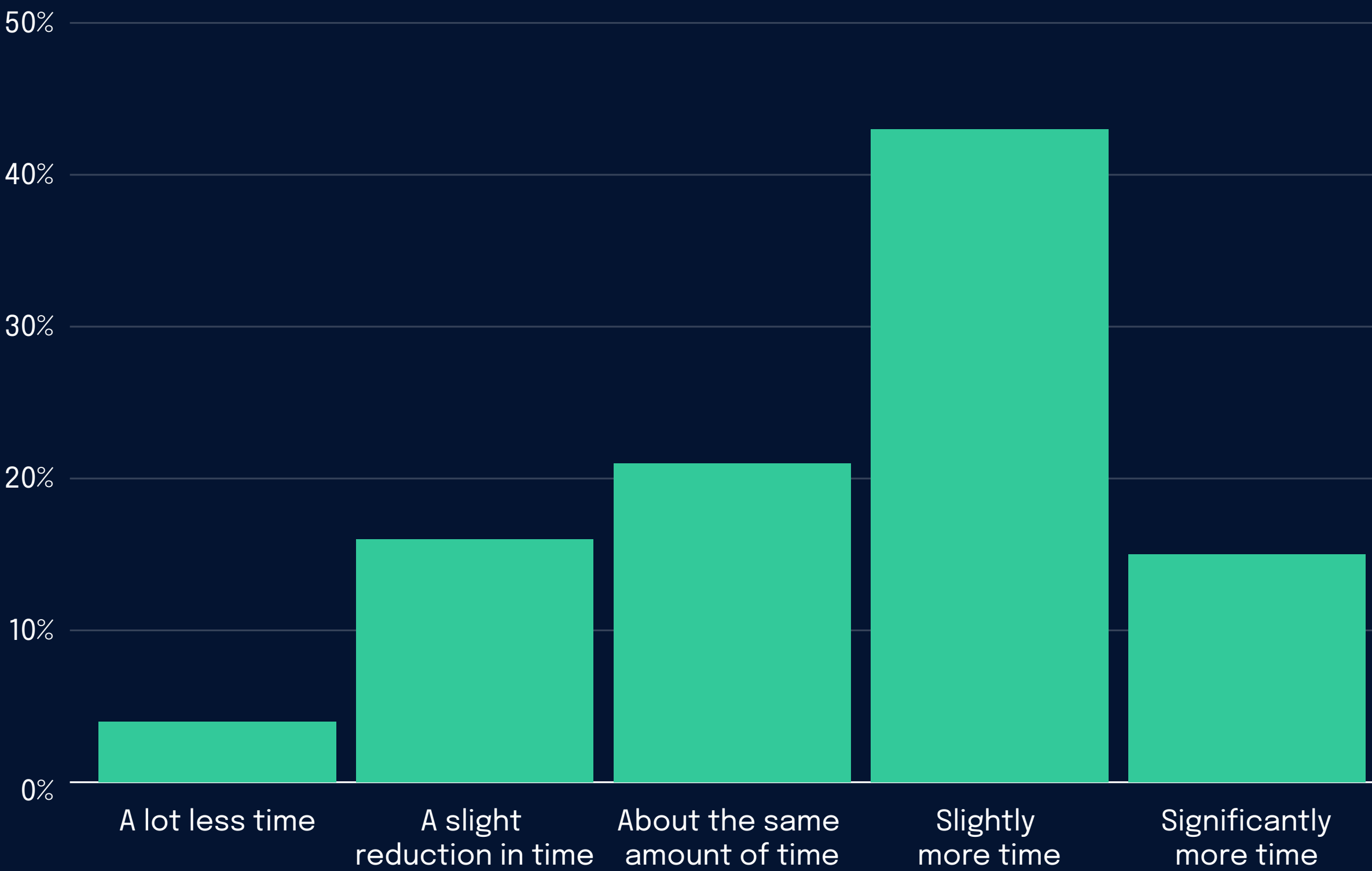
Those who experienced a breach will spend more time on IT risk management

Among respondents who experienced a security breach in the last 24 months, 58% anticipate spending more time on IT risk management and compliance in 2026 (43% slightly more time and 15% significantly more time). Organizations that have experienced a breach are much less likely to expect time to stay flat (21% vs 37%), meaning that after an incident, teams anticipate additional work that goes beyond immediate response, such as strengthening controls, expanding monitoring, addressing audit and assurance expectations, and institutionalizing process changes to prevent recurrence.

Do you anticipate that your organization will spend more, less, or about the same amount of time on IT risk management and compliance in 2026 vs. 2025?

by experienced a security breach in the last 24 months

A: Yes



CHAPTER 2

Framework Adoption Trends and Risk Management Best Practices

Risk management programs are evolving in two directions at once. Organizations are adopting a broader set of frameworks, conducting assessments on a more regular cadence, and formalizing governance practices that support repeatability. At the same time, the data shows a persistent execution gap, and program maturity is uneven. Many organizations have the components of a mature program, but outcomes vary materially depending on operating model, tooling, and whether risk and compliance are managed as a connected system. The difference is less about whether organizations recognize what “good” looks like, and more about whether they can operationalize it consistently through standardized processes and integrated systems.

This chapter focuses on what that maturity looks like in practice: which standards organizations are using, how they handle regional variance, how frequently they reassess risk, and which operating models are most strongly associated with consistent execution. Together, these results point to a clear conclusion: as scope expands, the programs that perform best are those that can keep risk and compliance execution repeatable, measurable, and continuously up-to-date.

The compliance framework footprint is broad (and AI governance is now mainstream)

Respondents report broad framework adoption, with over half of respondents (53%) using ISO 27001 and 48% using NIST CSF. ISO 27001 remains a leading framework, and SOC frameworks remain widely used for assurance-driven programs. Privacy regulation alignment is also substantial, with meaningful representation across GDPR and U.S. state privacy requirements.

53%

use ISO 27001 to
manage compliance

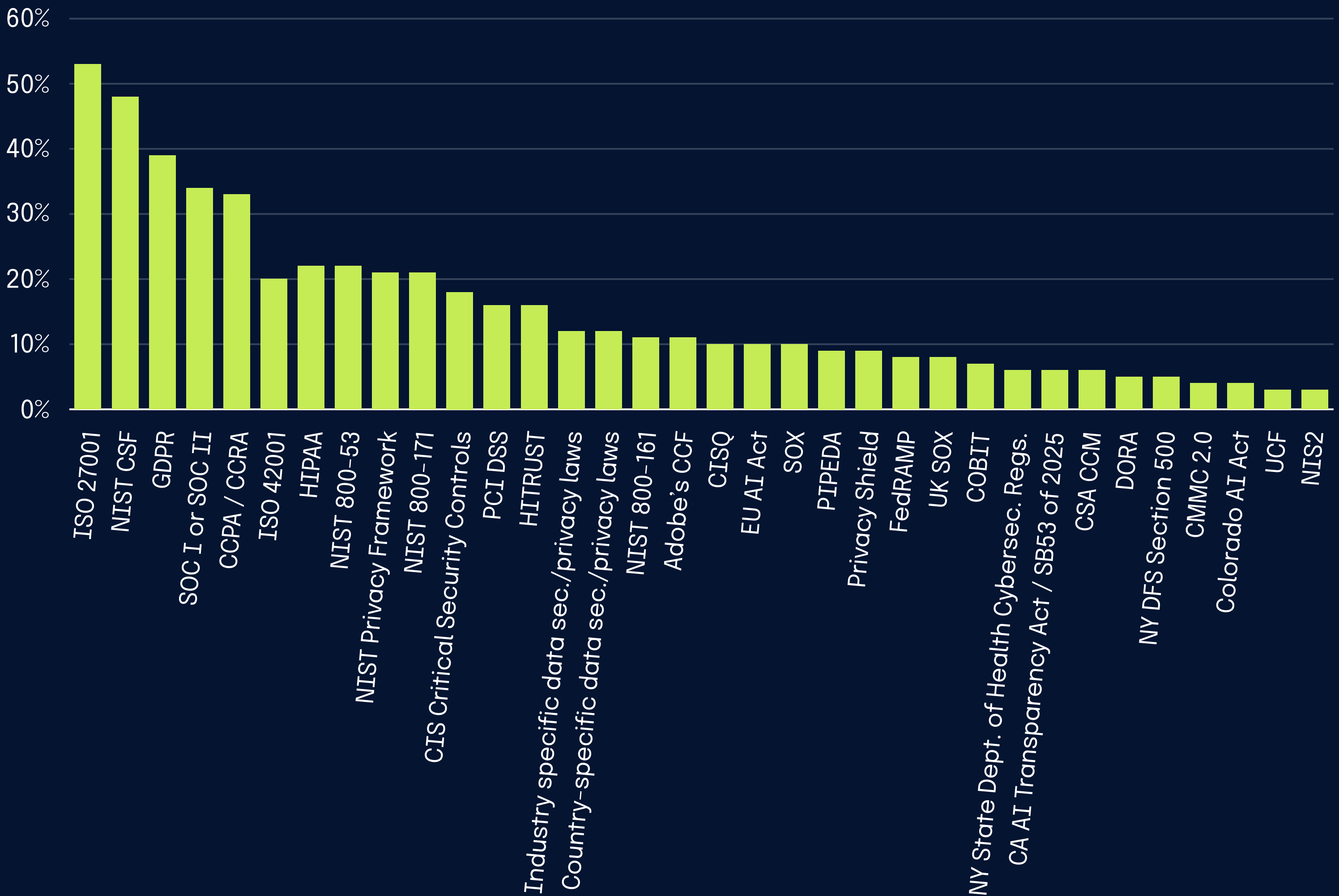
48%

use NIST CSF to
manage compliance

The most notable signal this year is the significant shift in AI governance from early adoption to mainstream planning. ISO 42001 and the NIST AI Risk Management Framework appear at levels that suggest many organizations are actively operationalizing AI risk, not merely discussing it.

This has two practical implications: first, risk programs are now covering a broader scope than traditional security and privacy; second, organizations will increasingly benefit from being able to map overlapping requirements across frameworks rather than managing them separately.

Which cybersecurity and/or data privacy compliance frameworks does your organization adhere to or plan to adhere to in the next 12 months?

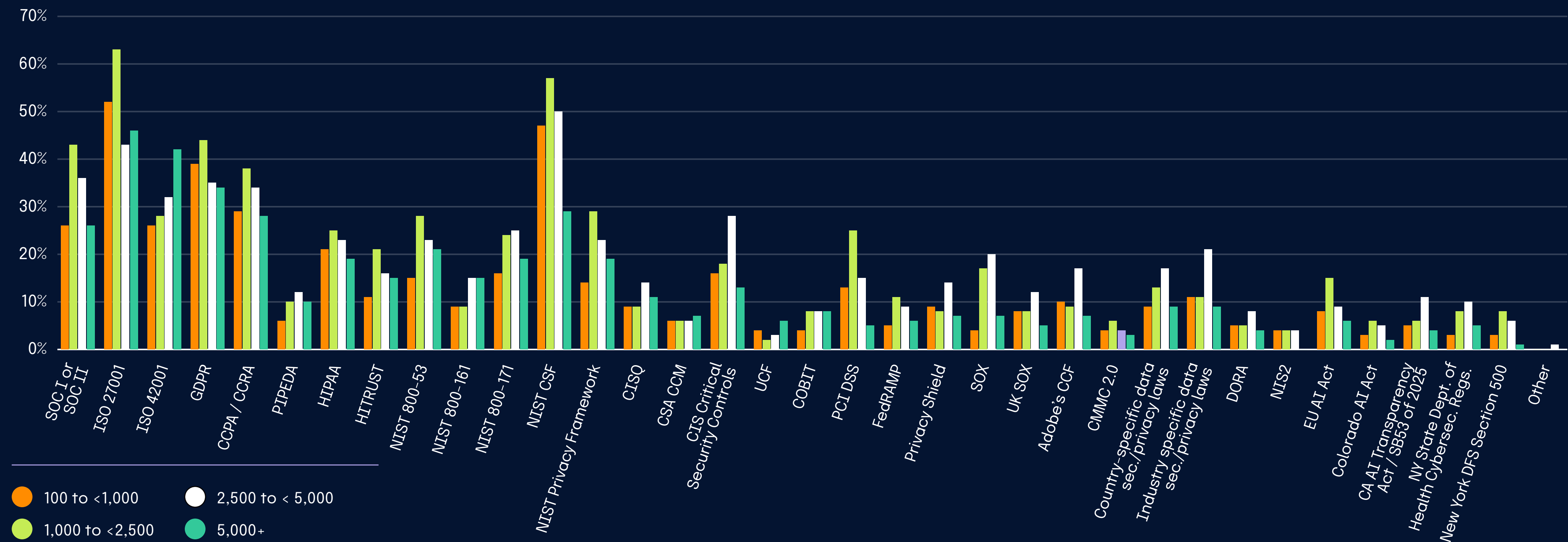


Segment patterns reinforce the operational story

Larger organizations tend to exhibit higher adoption of AI governance standards, which is consistent with their increased AI exposure, larger vendor ecosystems, and more complex internal deployment environments.

Which cybersecurity and/or data privacy compliance frameworks does your organization adhere to or plan to adhere to in the next 12 months?

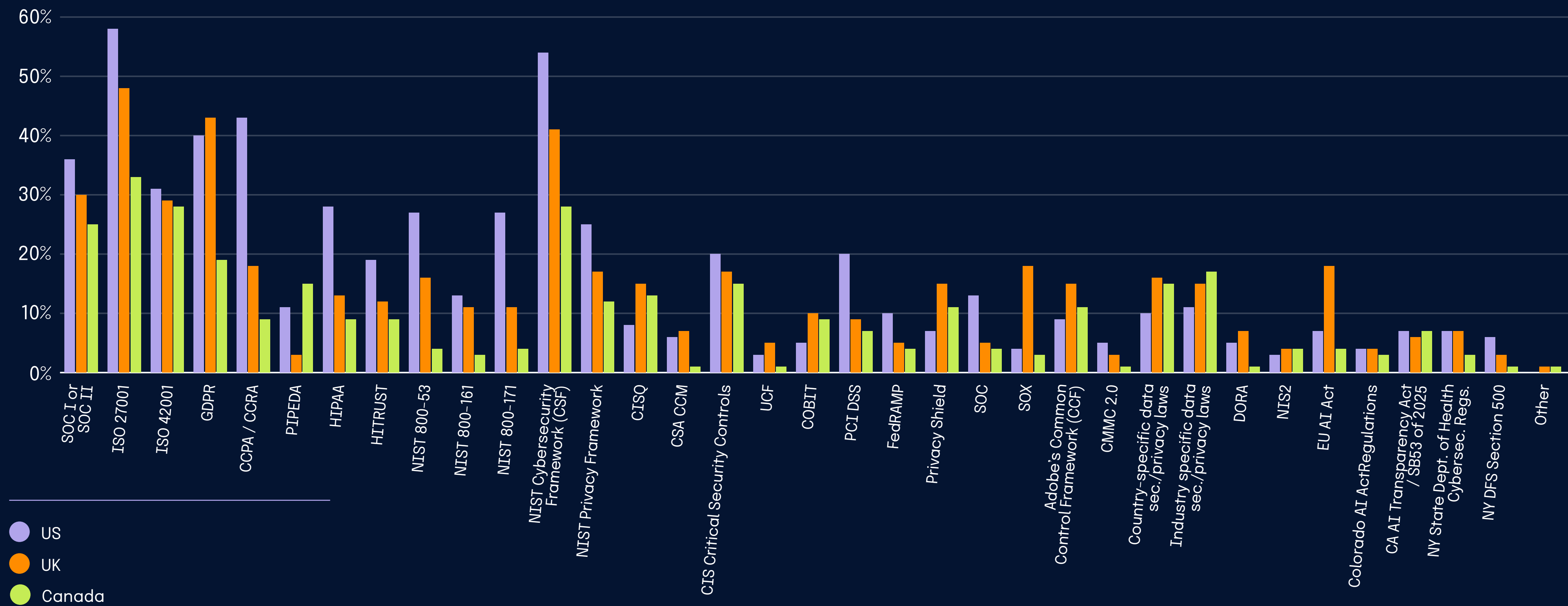
by company size



Regional differences also appear in expected ways: privacy framework alignment reflects where regulatory pressure is strongest, while AI governance standards are rising across all geographies.

Which cybersecurity and/or data privacy compliance frameworks does your organization adhere to or plan to adhere to in the next 12 months?

by company headquarters

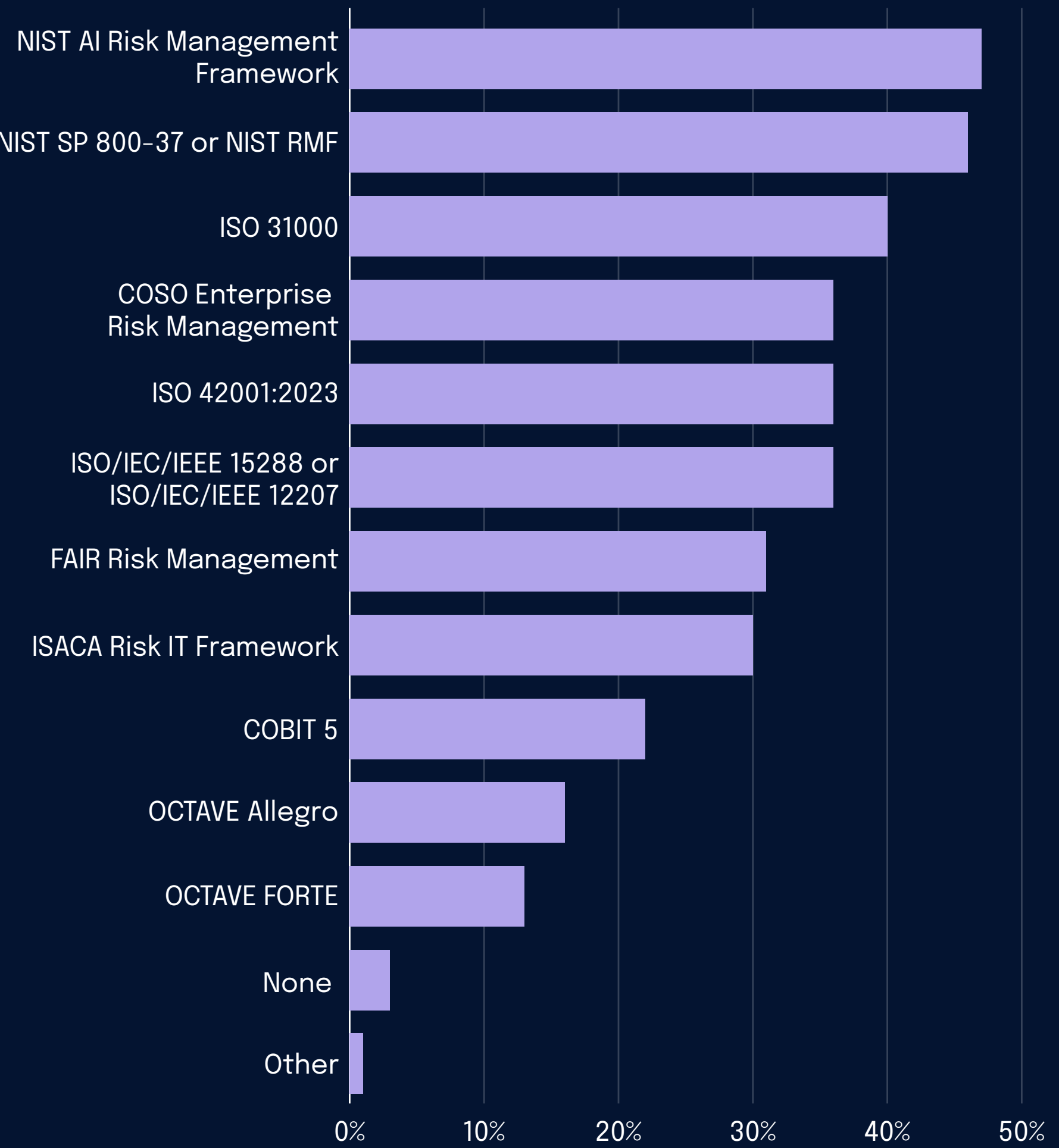


Traditional risk management framework usage persists, but AI risk management frameworks are on the rise

Risk framework utilization closely mirrors compliance framework adoption. NIST and ISO standards remain central, which is expected given their role in structuring risk identification, assessment, and control alignment. What is newly prominent is the breadth of AI risk frameworks being actively used. This suggests that organizations are not treating AI risk as a side initiative, but as an emerging pillar within their risk management toolkit.

The framework ecosystem is becoming more complex, not less. As AI governance becomes a core component, organizations will benefit from systems that can map requirements, reuse evidence, and keep controls current without multiplying effort.

Does your organization use any of the following IT risk management frameworks to identify and manage IT risks?



Leveraging a common controls framework is a best practice now

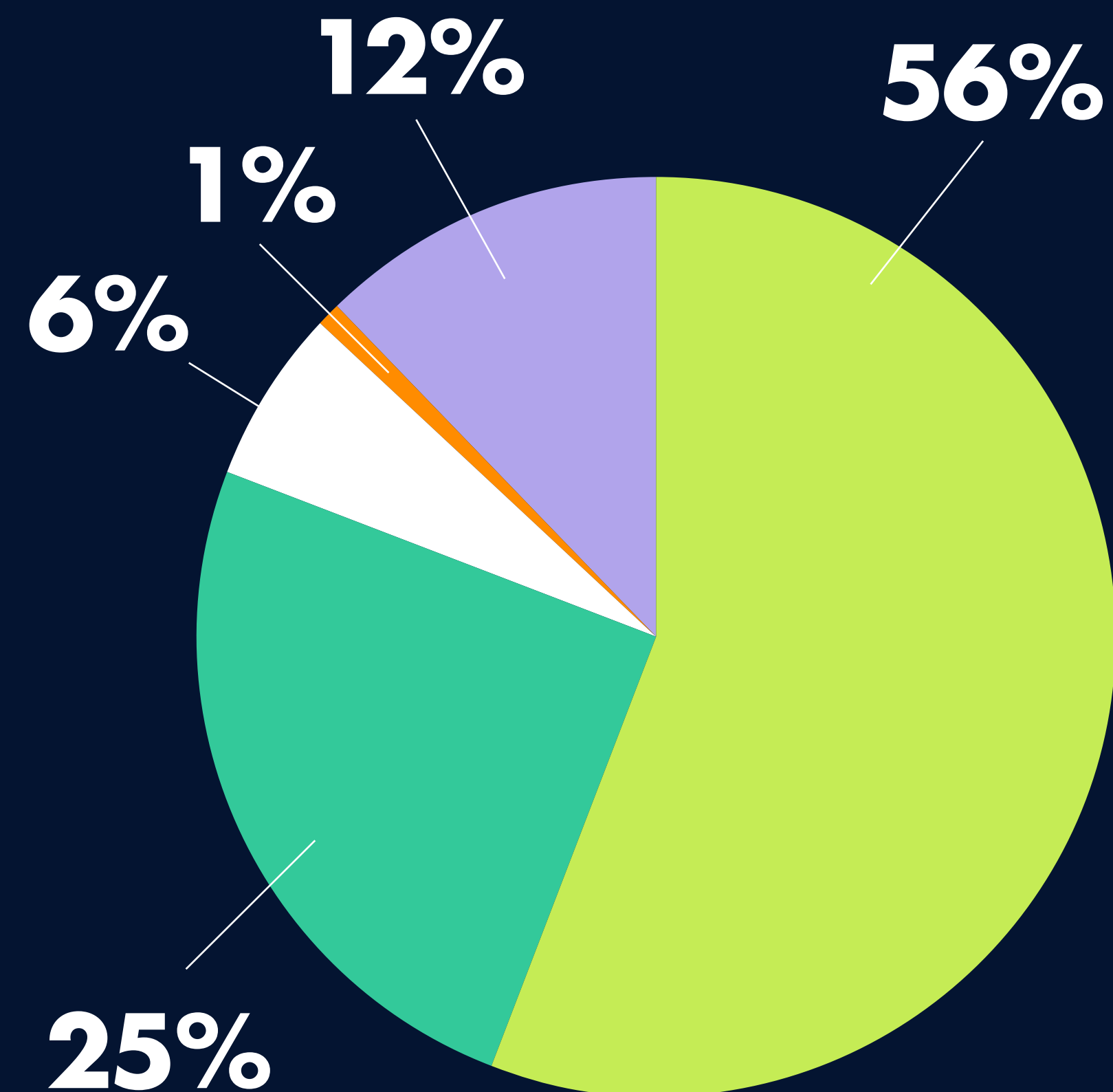
When organizations face regional variation in privacy and security requirements, their strategy tends to fall into one of three approaches. The most common approach (56%) is rationalization through a common controls framework, indicating a preference for standardization and reuse. A second-highest group (25%) aligns with the most rigorous applicable law, essentially setting a single bar and applying it across the organization.

Regional regulatory variance continues to be a forcing function for maturity. Organizations need a repeatable method for handling differences across jurisdictions without turning compliance into a series of one-off interpretations and exceptions.

The most scalable approaches are the ones that reduce complexity at the point of execution: standardizing controls, harmonizing evidence, and ensuring reporting is consistent regardless of geography.

This is also where many teams experience the “hidden cost” of compliance: not just meeting requirements, but maintaining clarity and consistency as requirements shift. A common controls approach makes this tractable because it turns regulatory complexity into an internal standard that teams can implement and monitor consistently.

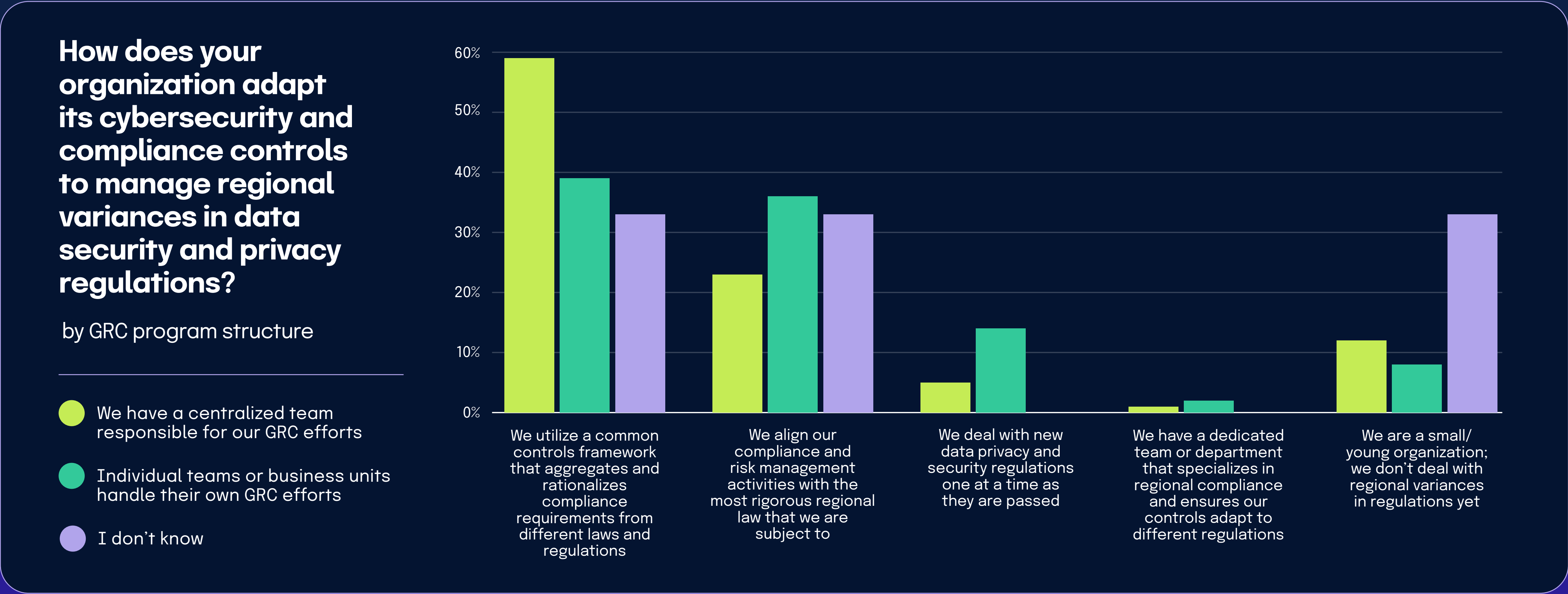
How does your organization adapt its cybersecurity and compliance controls to manage regional variances in data security and privacy regulations?



- We use a common controls framework that aggregates and rationalizes compliance requirements from different laws and regulations
- We align our compliance and risk management activities with the most rigorous regional law that we are subject to
- We deal with new data privacy and security regulations one at a time as they are passed
- We are a small/young organization; we don't deal with regional variances in regulations yet
- We have a dedicated team or department that specializes in regional compliance and ensures our controls adapt to different regulations

Program structure is a meaningful divider

Centralized programs are substantially more likely to adopt a common controls framework approach, while distributed programs are more likely to default to “most rigorous law.” This distinction is less about intent and more about operational feasibility: rationalizing requirements into a single control set requires cross-functional coordination, consistent ownership, and disciplined change management. Those conditions are easier to establish when accountability is centralized and tooling supports mapping and reuse.

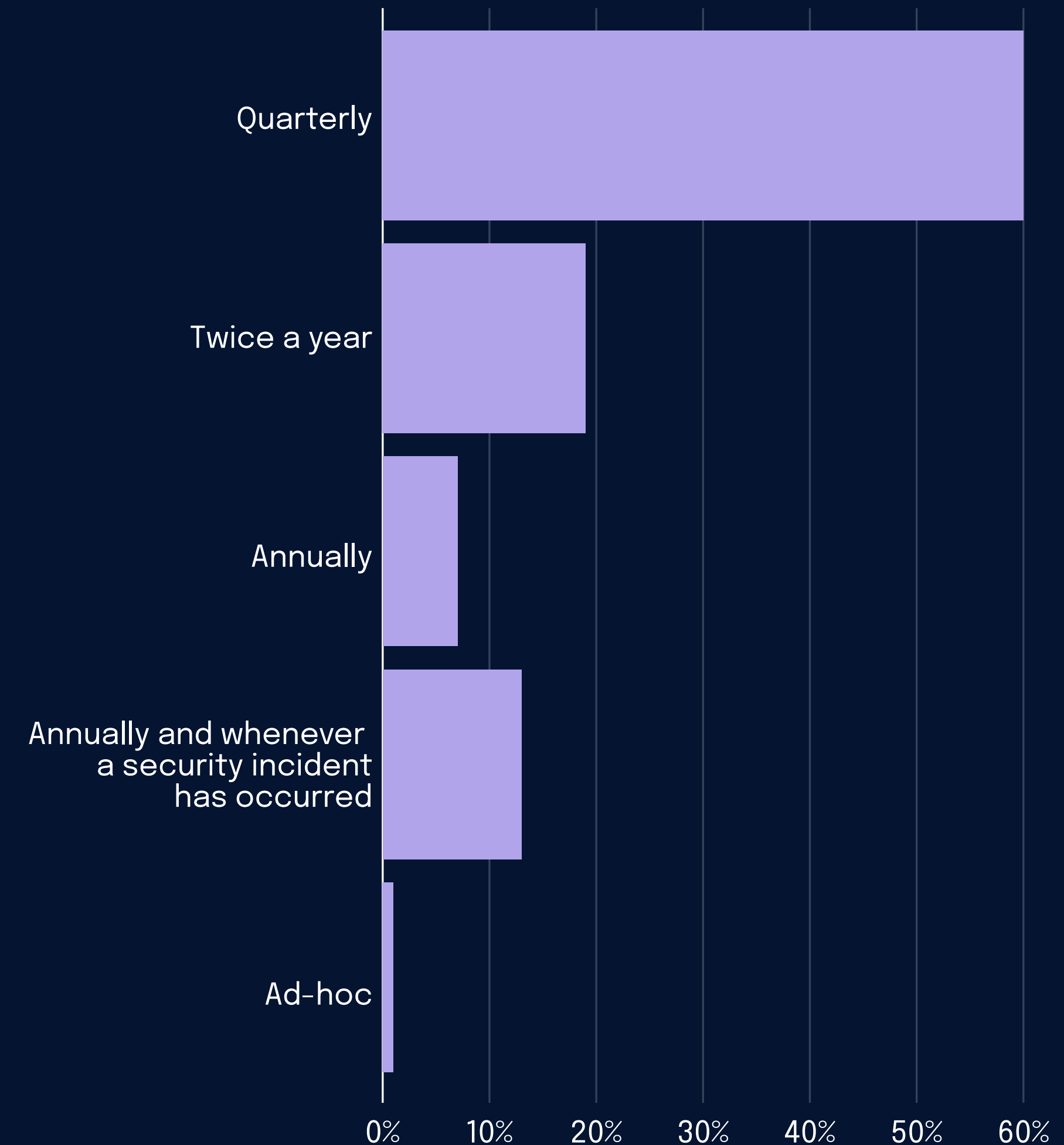


Quarterly risk assessments have become the norm, indicating increased maturity

A regular risk assessment cadence is one of the clearest markers of program operationalization. Quarterly assessments dominate the distribution, suggesting that regular risk assessments are becoming a standard rhythm rather than an aspirational goal. That said, cadence should be interpreted carefully: a quarterly assessment can still be superficial if it is disconnected from remediation tracking, control validation, and leadership reporting.

Quarterly cadence becoming the norm is a positive maturity signal, but cadence alone does not guarantee effectiveness. The differentiator is whether assessments are connected to remediation tracking, control evaluation, and leadership reporting, or whether they remain periodic snapshots that are difficult to operationalize and integrate.

How often does your organization conduct security risk assessments?

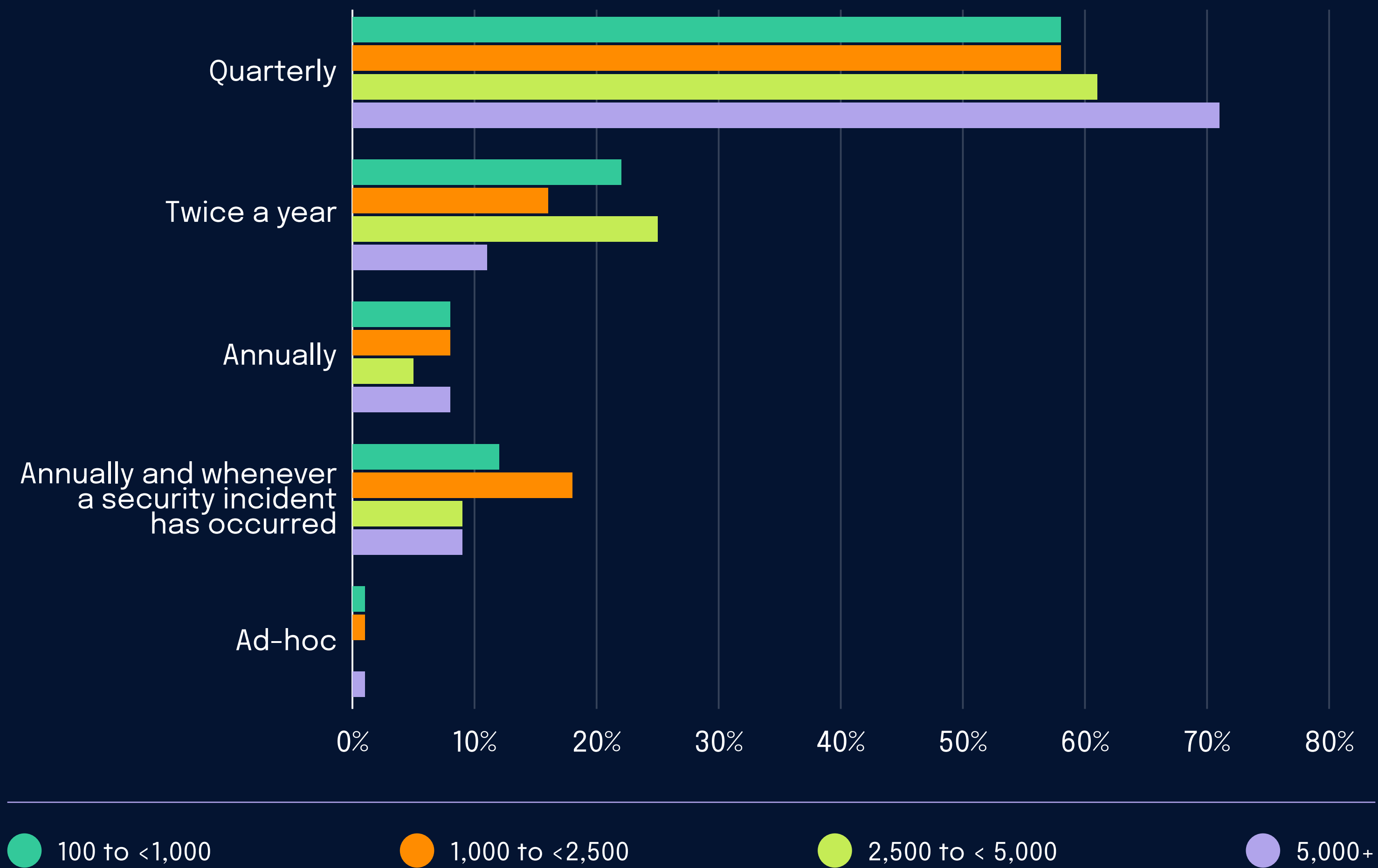


Company scale shifts the pattern

The largest organizations are even more likely to operate on a quarterly cadence, which is consistent with higher complexity, more frequent system changes, and a larger number of risk-relevant events that require review.

How often does your organization conduct security risk assessments?

by number of employees

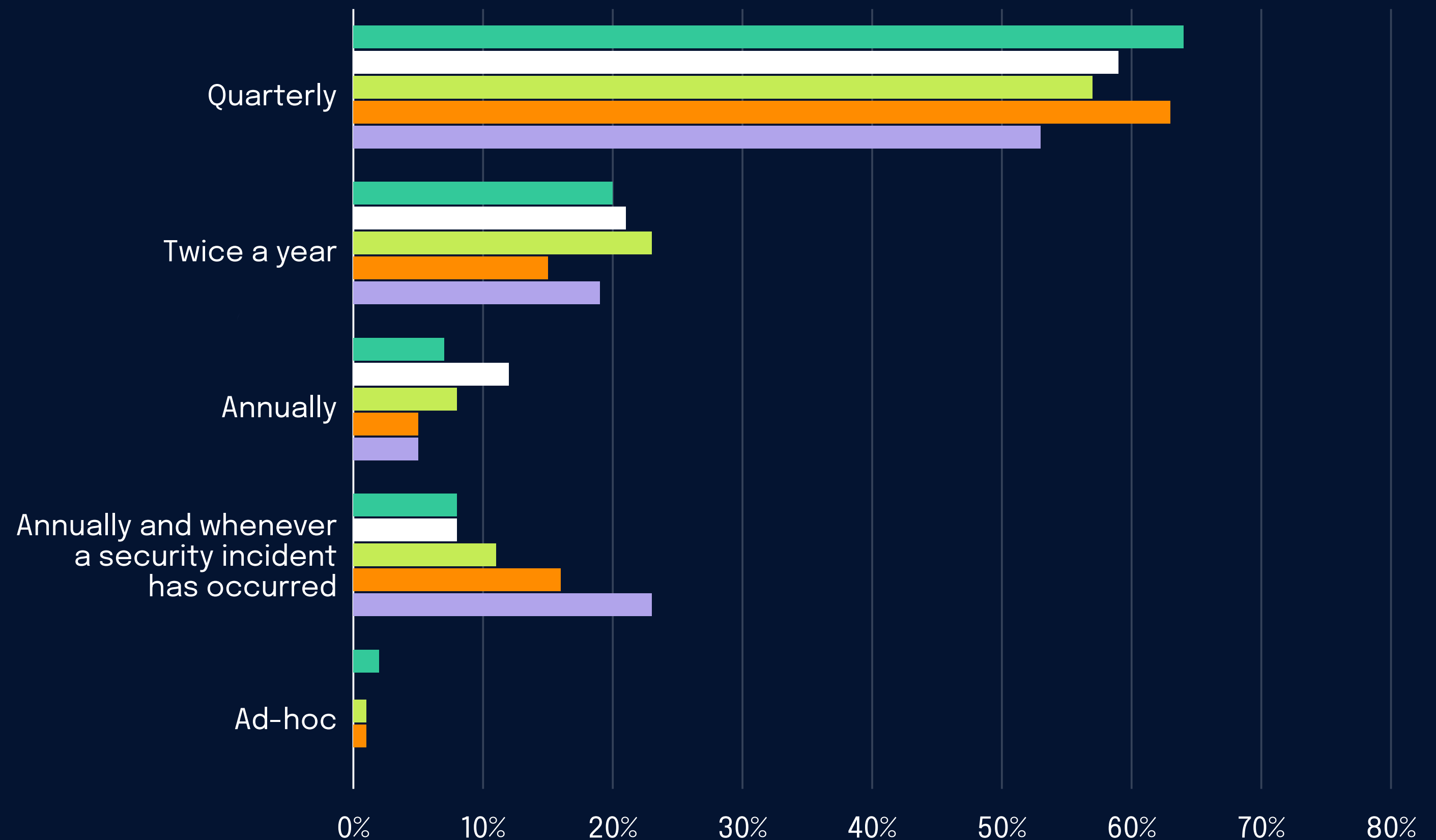


More mature GRC programs conduct assessments more frequently

Operating model also matters: organizations with more integrated approaches tend to show stronger alignment with recurring reassessment, reinforcing the idea that cadence is easier to maintain when assessment workflows and reporting are standardized.

How often does your organization conduct security risk assessments?

by approach to managing IT risks



● Ad-hoc ● In siloed departments, processes, and tools ● An integrated, manual tool ● An integrated, automated tool ● Our MSSP manages our IT risks

Most programs have the building blocks for a formal risk assessment program, but automation and governance add complexity

Across formalization actions, respondents report high adoption of the foundational elements of a risk program: using standards, establishing governance routines, and creating supporting architecture. Many also report using KRIs linked to KPIs and leveraging continuous monitoring tools, suggesting that measurement and automation are moving closer to the center of the risk function.

Organizations managing IT risk in an integrated, mostly automated approach are consistently more likely to report governance and measurement capabilities such as cross-functional committees, KRIs linked to KPIs, and supporting architecture for integrated risk management. These are not cosmetic differences. Committees and KRIs are mechanisms for turning risk into repeatable decision-making, and technology architecture determines whether that decision-making can be operationalized across teams.

Many organizations have adopted “risk program ingredients,” but execution maturity depends on whether those ingredients are connected through workflow and data. Integrated and automated approaches appear better positioned to translate governance into day-to-day consistency.

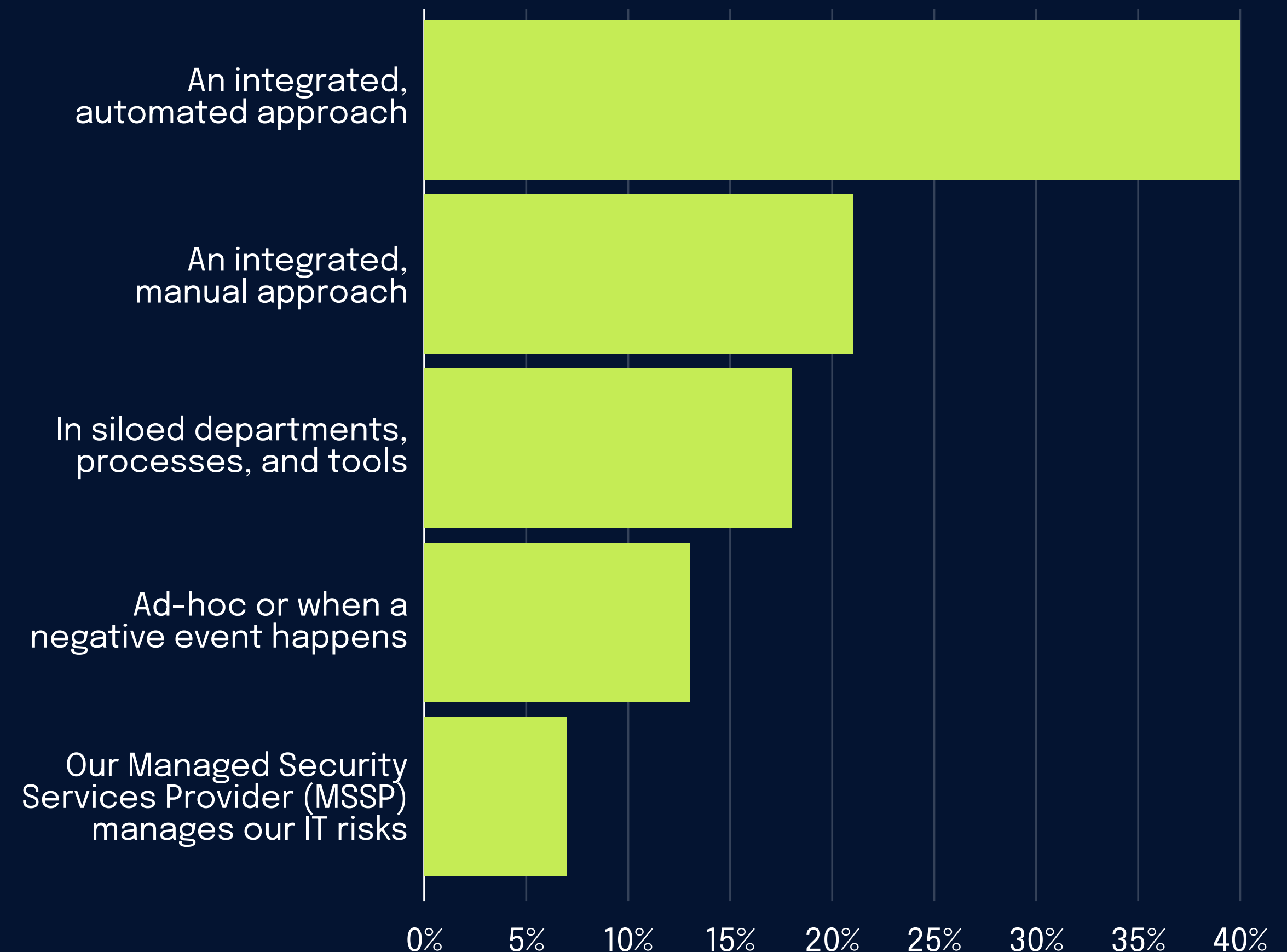
Which of the following best represents the actions you've taken to formalize your commitment to risk management?

Action taken	Approach to managing IT risks				
	Ad-hoc	In siloed departments, processes, and tools	An integrated, manual tool	An integrated, manual tool	Our MSSP manages our IT risks
We leverage a risk management standard/framework	95%	97%	91%	96%	99%
We have designated roles, responsibilities, and owners for risks	80%	83%	82%	82%	77%
We have a risk/compliance committee that regularly meets/executes our risk management plan	67%	71%	74%	88%	84%
We have a technology architecture that supports integrated risk management	74%	82%	77%	88%	89%
We conduct regular risk assessments	83%	79%	84%	89%	88%
We conduct risk assessments whenever major changes occur	71%	79%	79%	87%	83%
We have a regularly updated risk register	77%	74%	74%	82%	81%
We have a dedicated risk committee that meets regularly to discuss and update the risk register	68%	72%	70%	85%	84%
We conduct internal audits/assessments on internal controls on a regular basis	71%	79%	70%	86%	88%
We have aligned our risk management with our compliance efforts by mapping controls to risks	72%	81%	77%	85%	83%
We have implemented processes that methodically track governance objectives, risk/ownership/accountability, and compliance with policies and risk mitigation controls	74%	71%	71%	86%	77%
We use KRIs that are linked to KPIs to monitor high or critical risks	67%	73%	72%	86%	87%
We have engaged third-party consultants to perform regular security assessments or pen tests	72%	72%	64%	75%	77%
We use automated tools for continuous monitoring of risks and controls effectiveness	80%	79%	72%	90%	89%

Risk management integration is common, but enterprises still deal with silos

When respondents describe how IT risks are managed, the most common single response is an integrated approach with mostly automated processes. That is an encouraging headline. However, the persistence of siloed approaches remains meaningful, and the distribution shifts in predictable ways as organizations grow.

Which of the following statements is the closest reflection of how your organization manages IT risks?

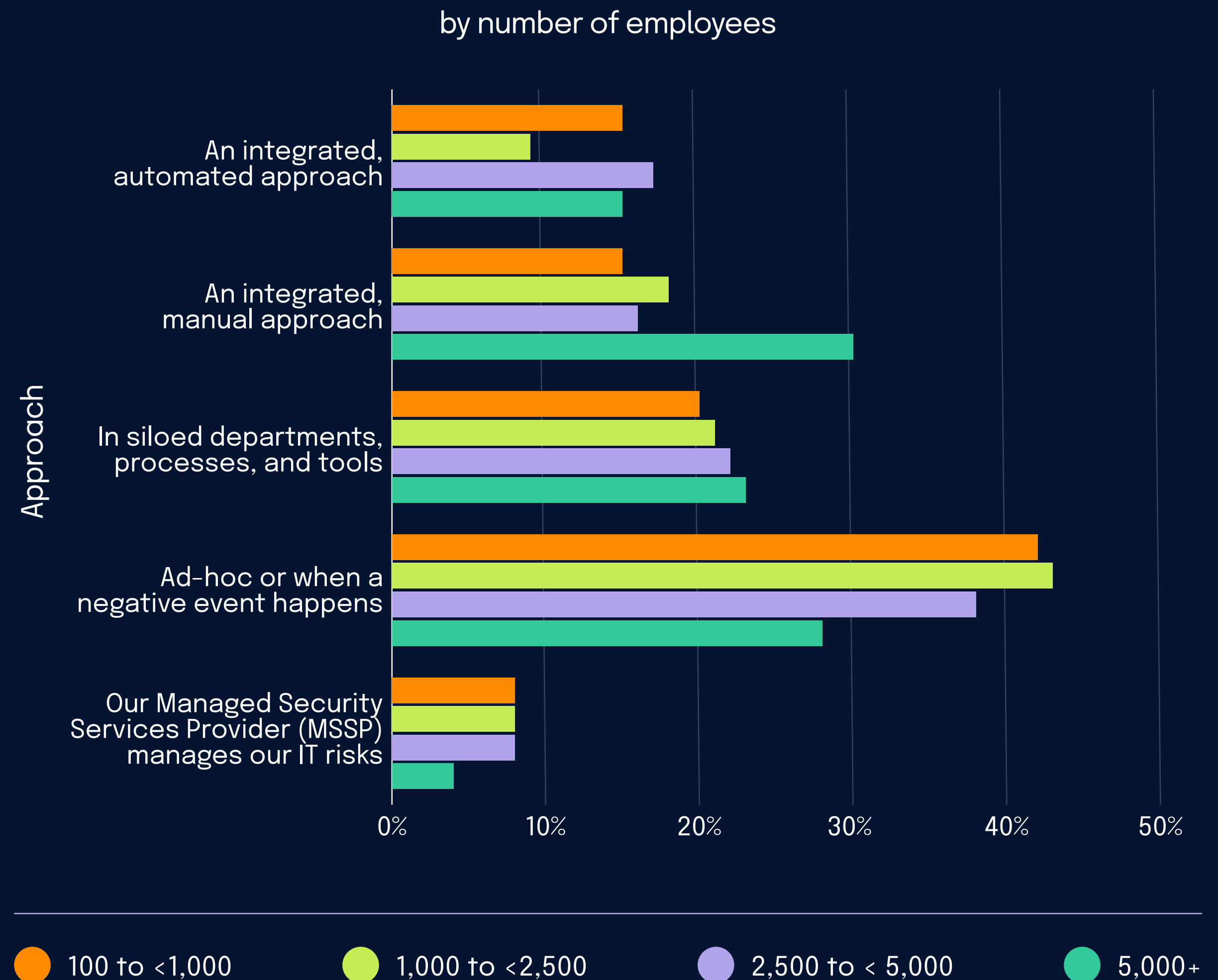


Enterprise scale is not simply “more of the same”

Enterprise scale is a different coordination problem. The largest organizations are less likely to describe their environment as integrated and mostly automated, and more likely to report siloed departments, tools, and processes. This pattern aligns with structural complexity: large enterprises often inherit multiple tools, disparate processes, regional variation, and different risk owners across business units. Without strong standardization and shared workflows, silos can become the default even with capable teams.

The findings suggest that integration is achievable, but it requires deliberate consolidation and standardization, not only policy decisions. A SaaS GRC platform supports this by providing a single operating layer across business units while still enabling local ownership where needed.

Which of the following statements is the closest reflection of how your organization manages IT risks?



Most say risk management meets their objectives, but automation, exceptions, and gaps create more manual work

Respondents generally rate their risk management execution positively across core activities such as identifying and assessing risks and documenting risk decisions. However, the areas that typically distinguish mature programs show larger variability: validating controls against standard controls, automating controls testing, and capturing and reporting deficiencies.

In your opinion, how well is your company doing in performing each of the following risk management actions?



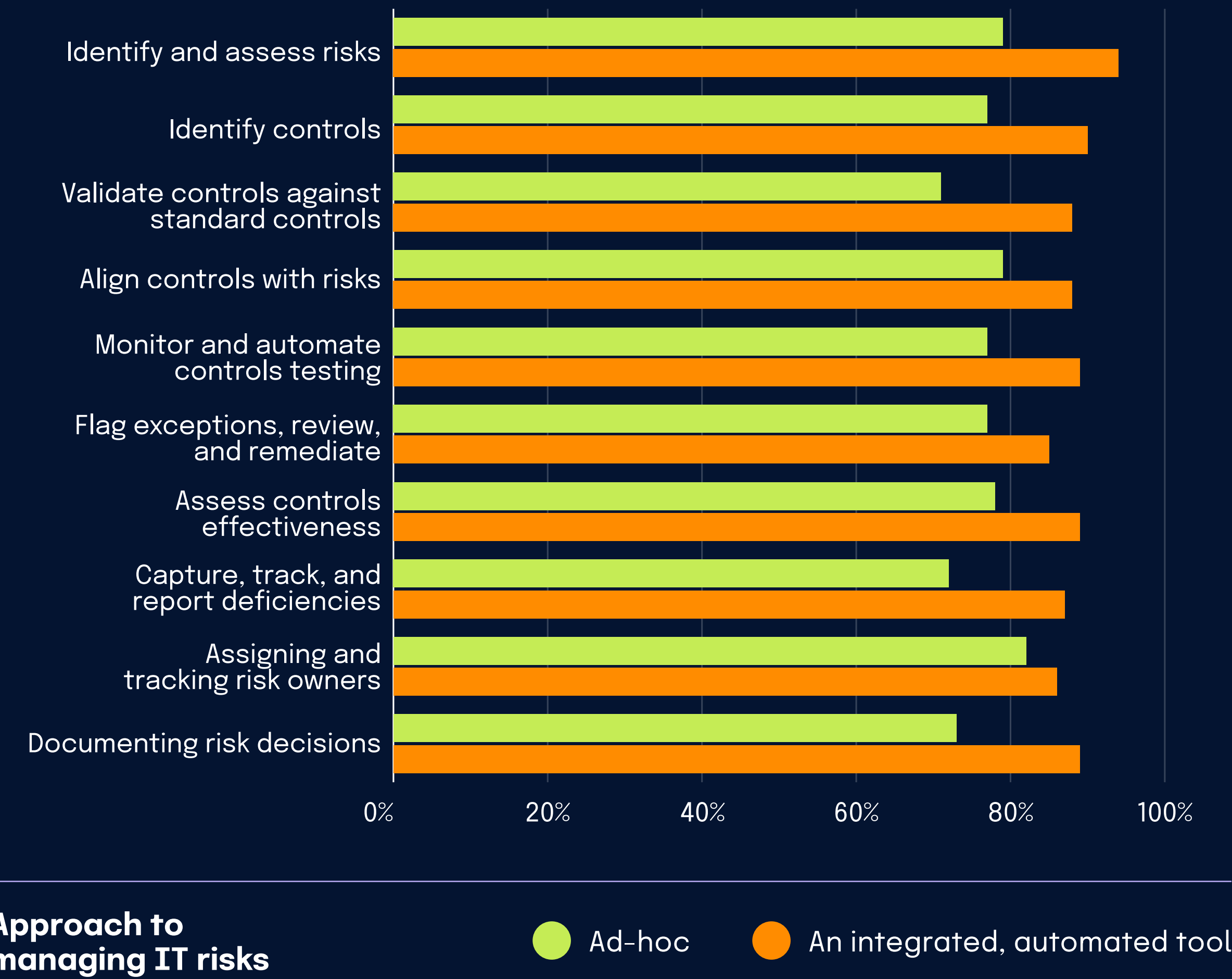
Integrated, automated approaches report stronger performance

Across these actions, **organizations with integrated and automated risk management approaches consistently report stronger performance than ad-hoc approaches**. This is a critical interpretive point: it suggests that the operating model and tooling are closely tied to execution confidence in the most challenging aspects of risk management, not just in the basics.

Many organizations believe they meet objectives, but the actions most sensitive to automation and workflow integration show the clearest operating-model advantage. This reinforces a practical narrative: the benefit of a SaaS GRC platform is not limited to documentation. It is strongest where teams need repeatability, monitoring, and defensible reporting at scale.

In your opinion, how well is your company doing in performing each of the following risk management actions?

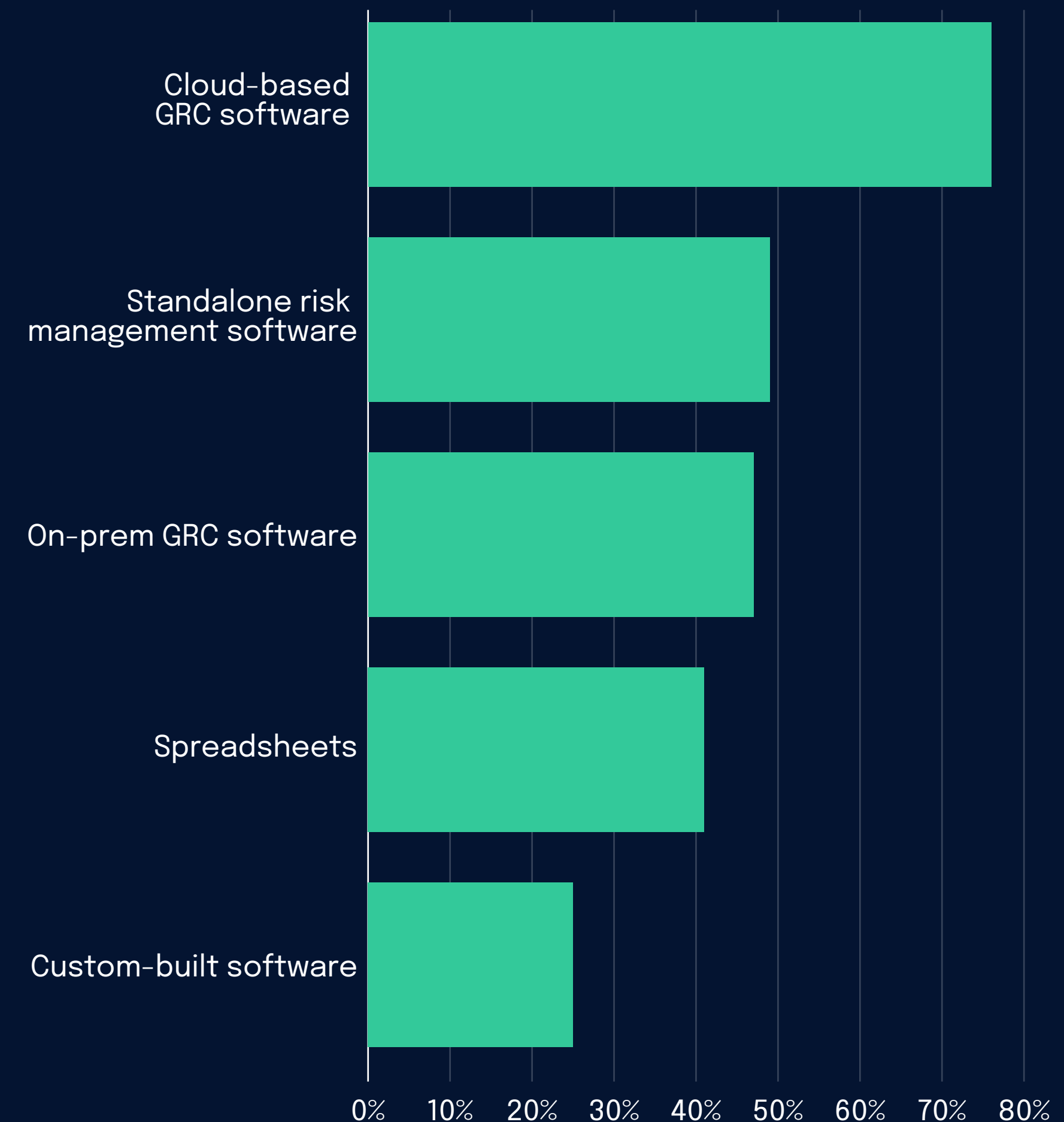
A: Meets objectives



Cloud risk management platforms lead risk management efforts, but spreadsheets still shape day-to-day reality

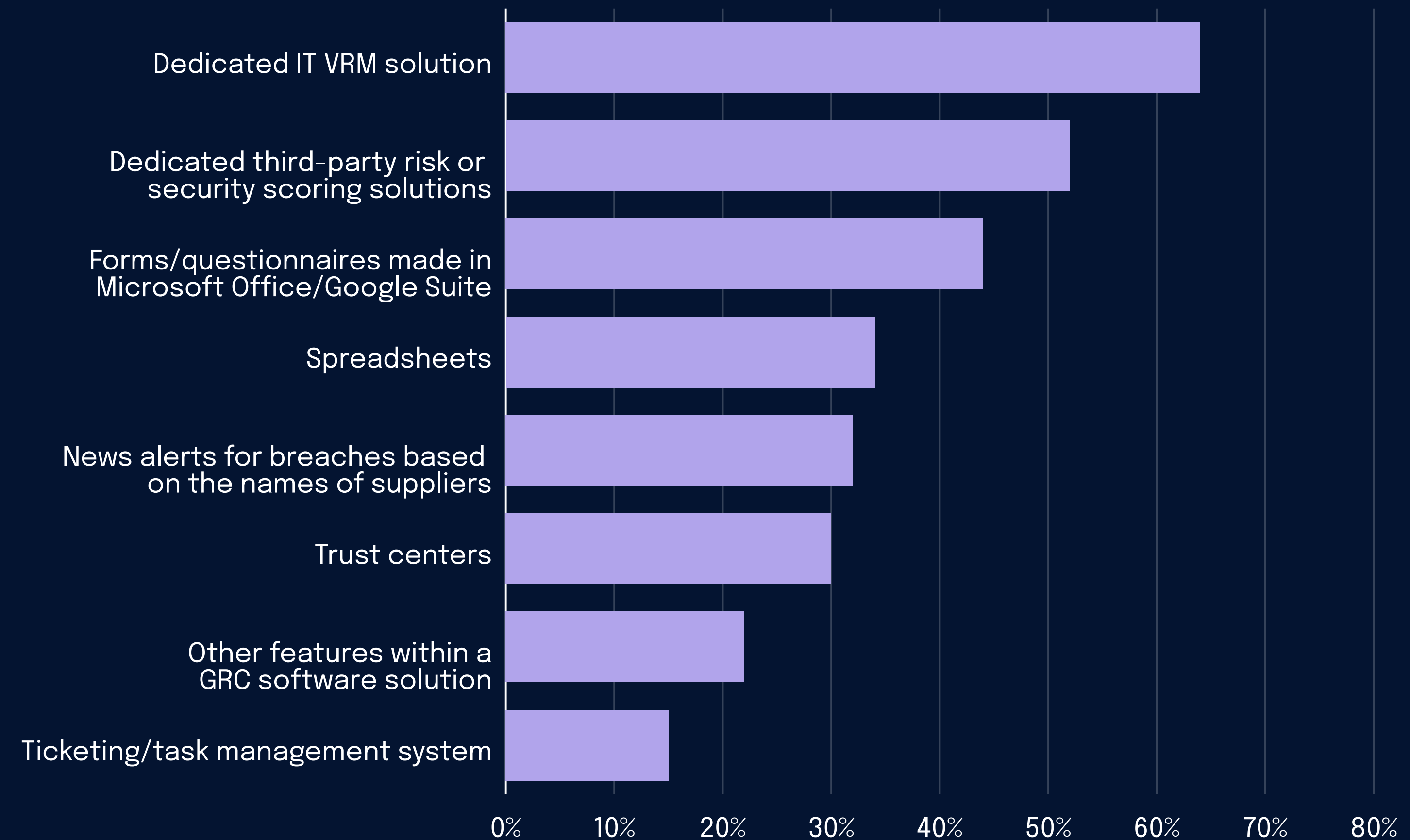
Tooling choices reveal an important dual reality. Most respondents report using the risk management module in a cloud-based GRC platform for first-party risk tracking, which suggests platform adoption is strong. At the same time, spreadsheets remain widely used alongside those platforms.

In your opinion, how well is your company doing in performing each of the following risk management actions?



This combination is common in practice: teams adopt a platform for structure and reporting, but spreadsheets persist for local workflows, side analyses, and ad-hoc tracking. The risk is not the existence of spreadsheets; it is what they often represent operationally. Spreadsheets are difficult to govern at scale, they fragment evidence and decisions, and they make it harder to maintain consistent ownership and traceability across the organization.

What tools are you using to identify and manage IT risks arising from your third parties? Select all that apply:

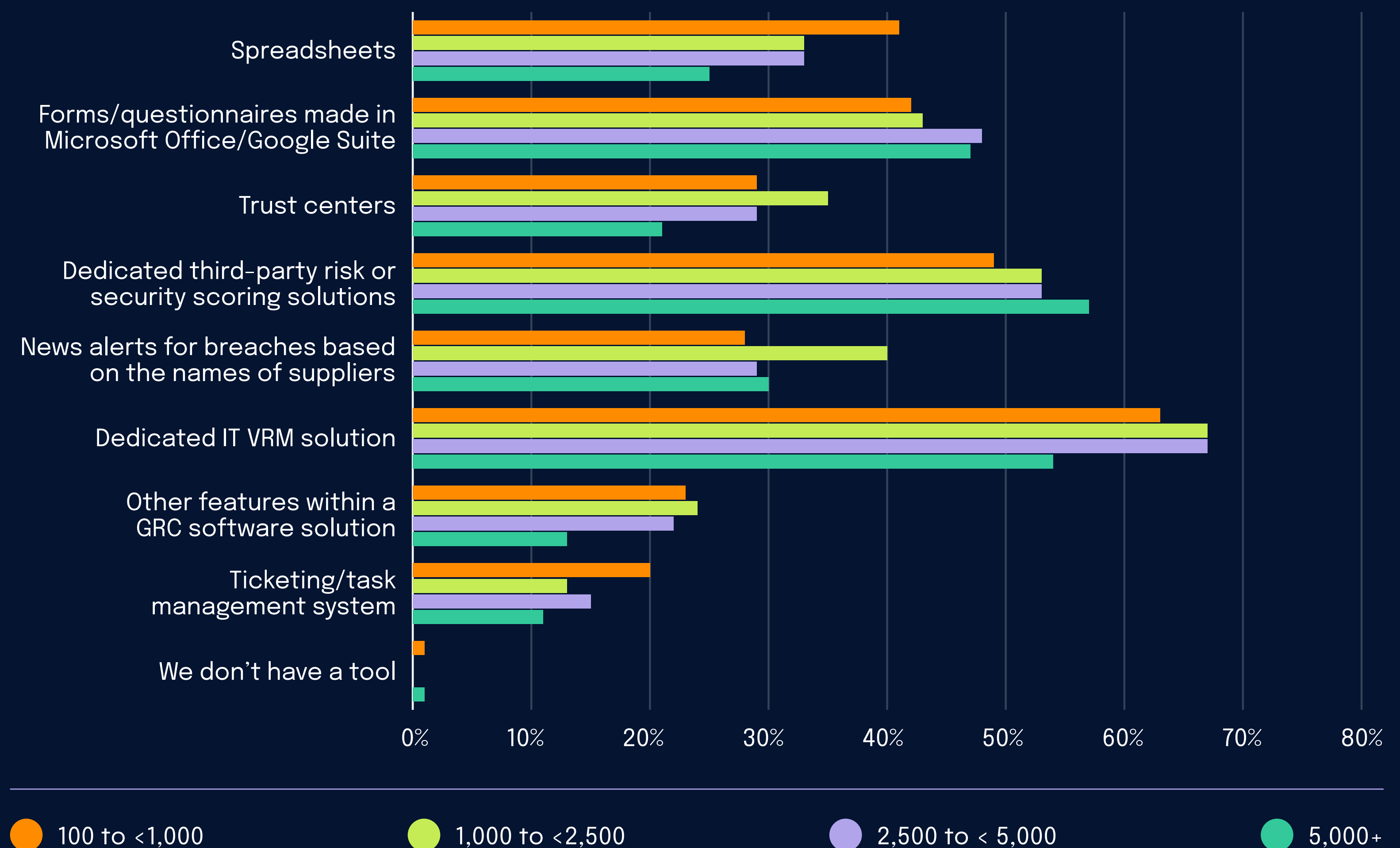


Larger organizations are more mature with their tooling

The data also showed that larger organizations are more likely to use a cloud-based risk module, while spreadsheet reliance can increase in certain mid-market bands, reflecting the transition phase where programs are scaling but not fully consolidated.

What tools are you using to identify and manage IT risks arising from your third parties?

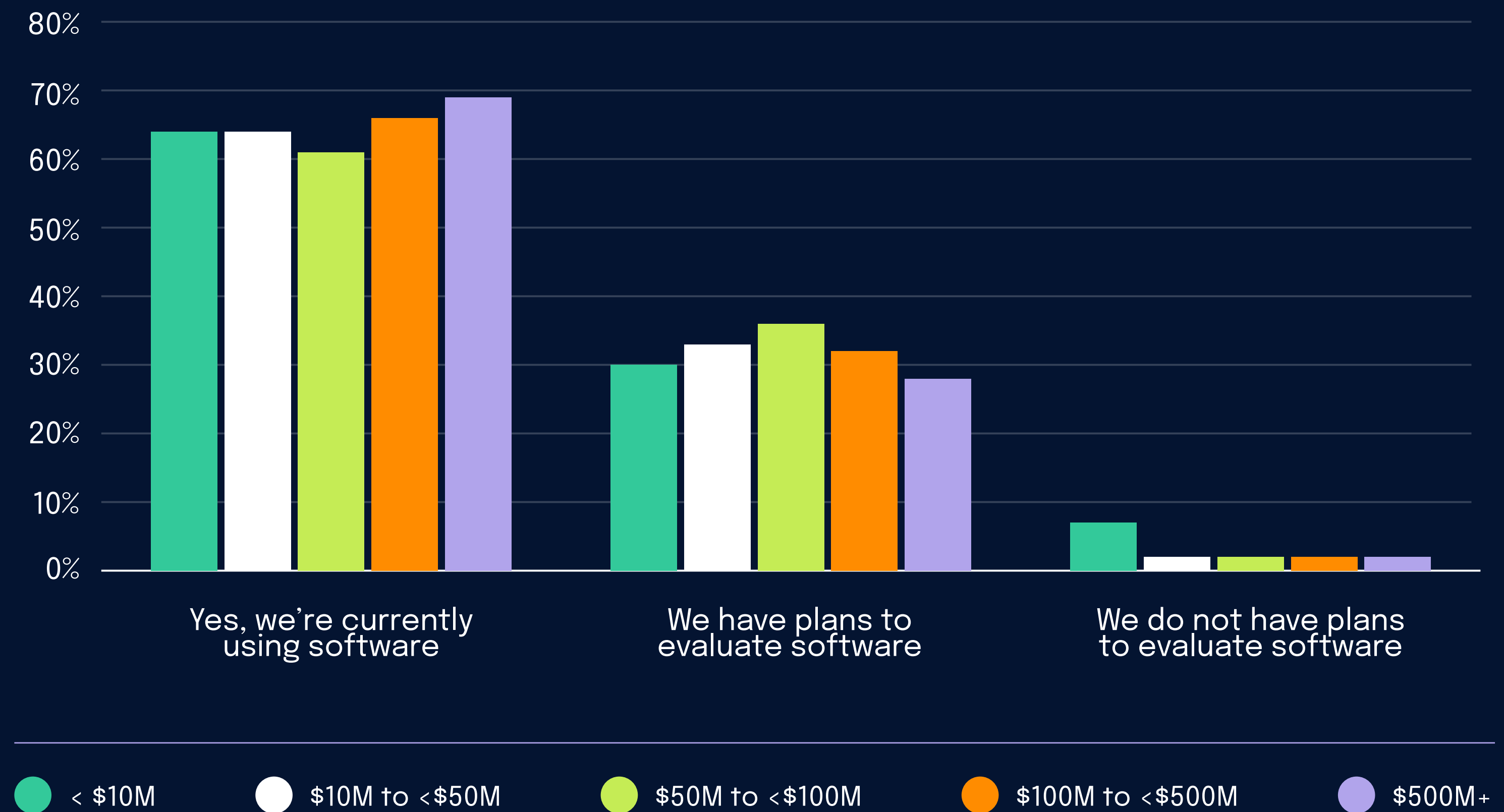
by company size



Platform and tool adoption are moving in the right direction, but hybrid tool environments remain a major driver of friction. Consolidation is not simply a cost story; it is a visibility and defensibility story, especially when risk decisions and remediation need to be evidenced consistently. Notably, larger organizations surveyed are more likely to have a formal tool in place compared to smaller organizations that take a more manual approach and do not have plans to evaluate control monitoring software.

Are you using/have you evaluated software that can help you automatically monitor and test your organization's security controls, assets and their compliance status?

by company revenue



CHAPTER 3

Budgets, Capacity, and ROI: How GRC Teams Are Funding the Work in 2026

Budgets and resourcing decisions reveal how organizations translate GRC priorities into operational reality. This year's benchmark shows that GRC is not being treated as a discretionary function. Many organizations are sustaining or increasing investment, and reported 2026 budget levels indicate that GRC programs are expected to deliver measurable value across multiple fronts: regulatory readiness, customer assurance, risk reduction, and resilience.

However, this is also where an important pattern emerges across the last several years. Survey respondents consistently report that budgets are increasing year over year, while many GRC leaders hear a different story in the market: tightened spending, delayed purchases, and scrutiny on renewals.

The most likely explanation is not that one view is “wrong,” but that they are measuring different realities. This survey captures the outlook and expectations of GRC leaders at a point in time, often reflecting planned budgets, priority-setting, or early-year allocations. Market sentiment, by contrast, often reflects later-stage adjustments such as mid-year freezes, reforecasting, shifting spend to fewer vendors, or reallocations that reduce discretionary projects while preserving mission-critical security and compliance work.

In other words, organizations may still feel pressure to invest in GRC, even as they face constraints on how that investment shows up in headcount, tooling, and external services.

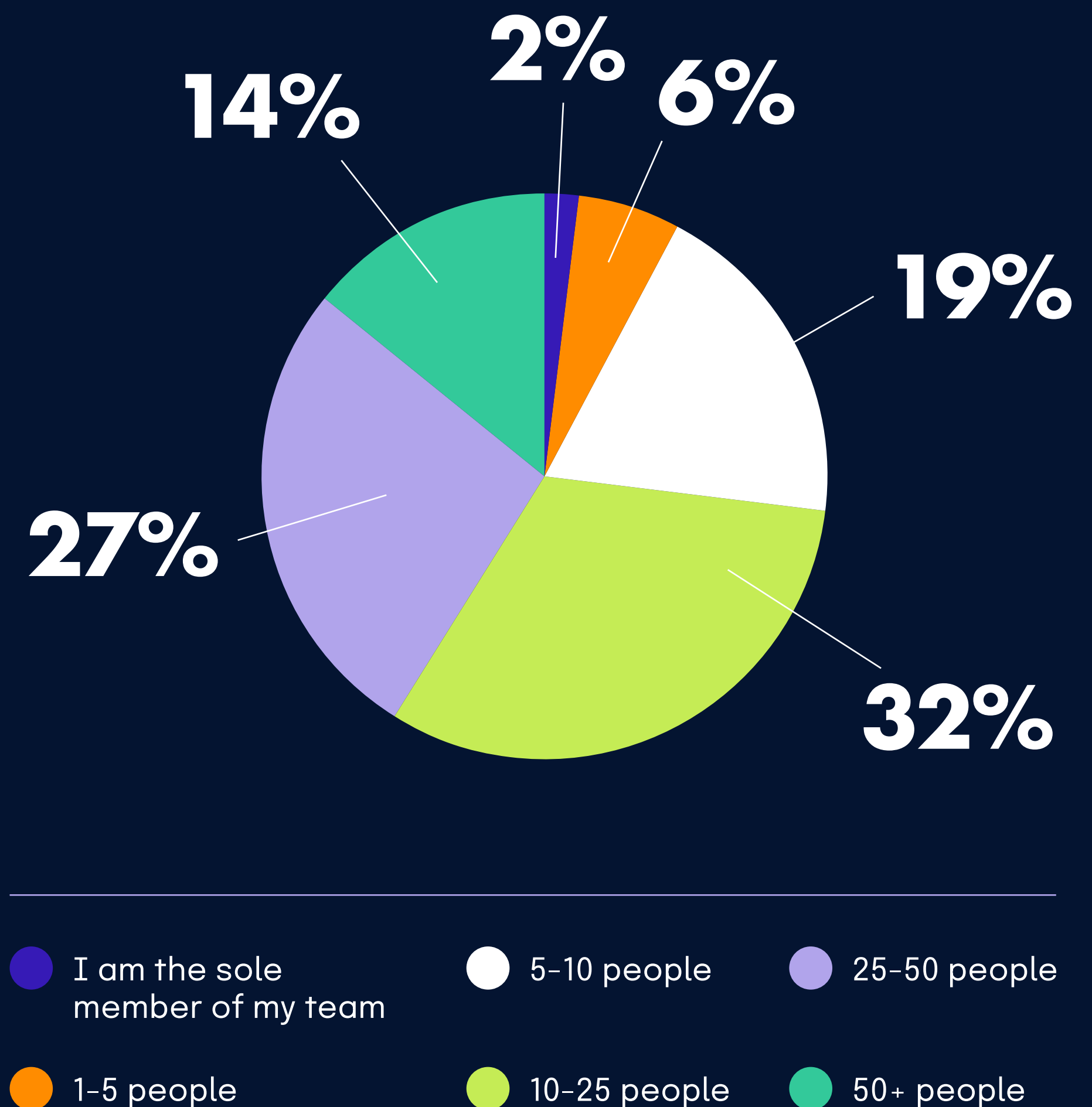
This chapter examines the budget story through three lenses. First, it establishes baseline context through revenue and team size, because program complexity increases as organizations scale. Second, it looks at budget direction, the drivers behind budget changes, and what organizations are planning for 2026. Third, it evaluates how funding is being allocated across headcount, software, and external services, and what that allocation implies for ROI. Across these findings, one conclusion stands out: in an environment where planned investment and actual spend can diverge, the strongest return comes from building an operating model that holds up under change, supported by standardized processes and technology that reduces manual overhead and strengthens traceability.

Capacity sets the ceiling for what GRC can deliver

Many respondents report operating with mid-sized teams rather than isolated individuals or very large departments. The distribution is concentrated in the middle bands, suggesting that a large portion of organizations are running programs that are established, but still constrained by how much work they can absorb without standardization and automation.

A practical implication is that capacity does not scale linearly with scope. As frameworks expand, third parties proliferate, and internal stakeholders multiply, the work often grows faster than headcount. That is why programs that can reduce administrative effort, centralize evidence, and standardize workflows tend to unlock outsized ROI, even when budgets are healthy.

What is the size of your compliance management and/or risk management team?

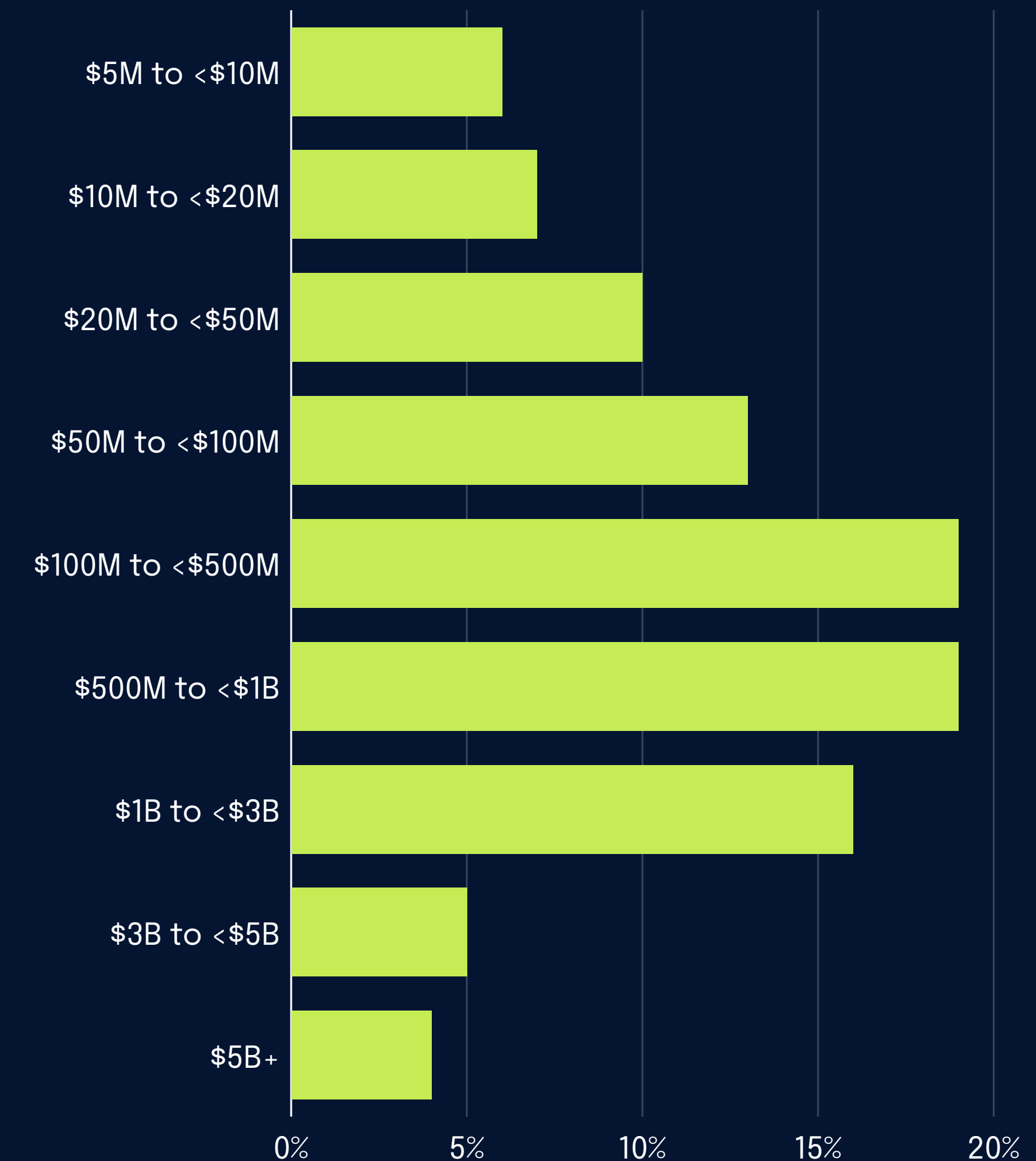


How revenue impacts GRC scalability

The revenue profile of respondents helps explain why capacity pressures remain persistent, even as budgets rise. 63% of organizations surveyed are operating at \$100M+ in annual revenue, and almost half generated \$500M or more in revenue (44%). At these revenue levels, GRC programs are typically supporting higher-stakes assurance requirements, broader regulatory exposure, more internal stakeholders, and more frequent executive and customer scrutiny. The result is that risk and compliance work is not only “more,” it is structurally more complex.

Scaling GRC is rarely solved by incremental hiring alone. As organizations move from midmarket into enterprise revenue bands, the GRC workload tends to shift from periodic preparation to continuous readiness: more frameworks to map, more evidence to maintain, more cross-functional coordination, and more reporting expectations. In that environment, capacity becomes an operating model question. Teams that can standardize controls, centralize evidence, and automate repeatable workflows are better positioned to keep pace with complexity without needing headcount growth to match workload growth.

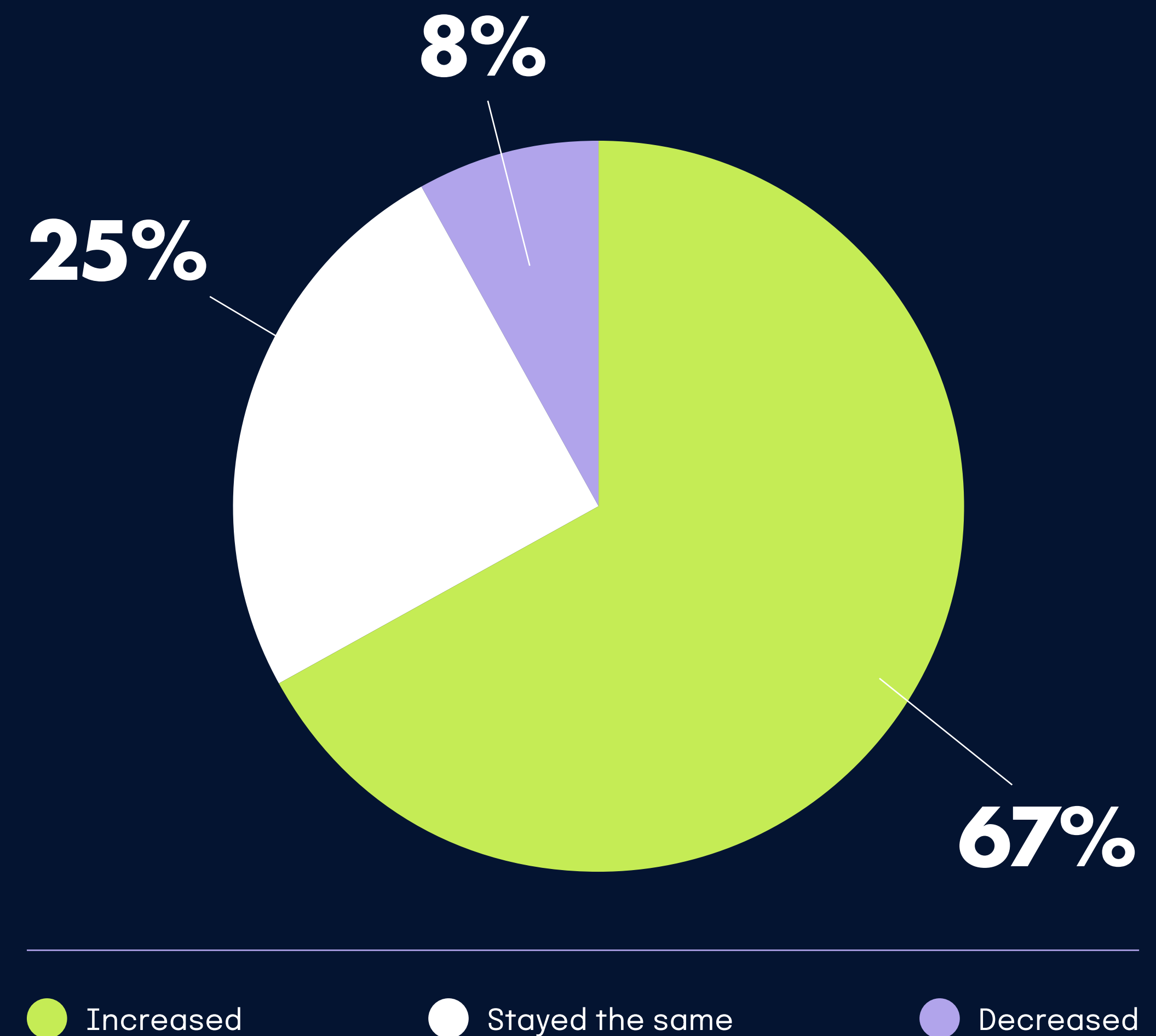
How much revenue did your business generate in 2025?



Budget direction in 2025 had momentum, but not evenly

67% of respondents said their GRC budget increased in 2025, a clear indicator that GRC remains a funded priority, even amid broader cost scrutiny in many organizations. Prior reports also showed GRC budgets increasing year-over-year. At the same time, this finding should be read with the same “optimism gap” lens reflected throughout the last several years of the benchmark. Year-over-year, respondents report increases to their budgets based on what is planned or expected, while real-world spend is often shaped later by reforecasting, freezes, vendor consolidation, or scope reductions that can make budgets feel tighter in practice even when the category remains prioritized. In other words, investment intent can remain strong even as procurement and finance pressure teams to do more with fewer tools, fewer external services, or slower headcount growth.

In 2025, did your GRC budget increase, decrease, or stay the same vs. 2024?

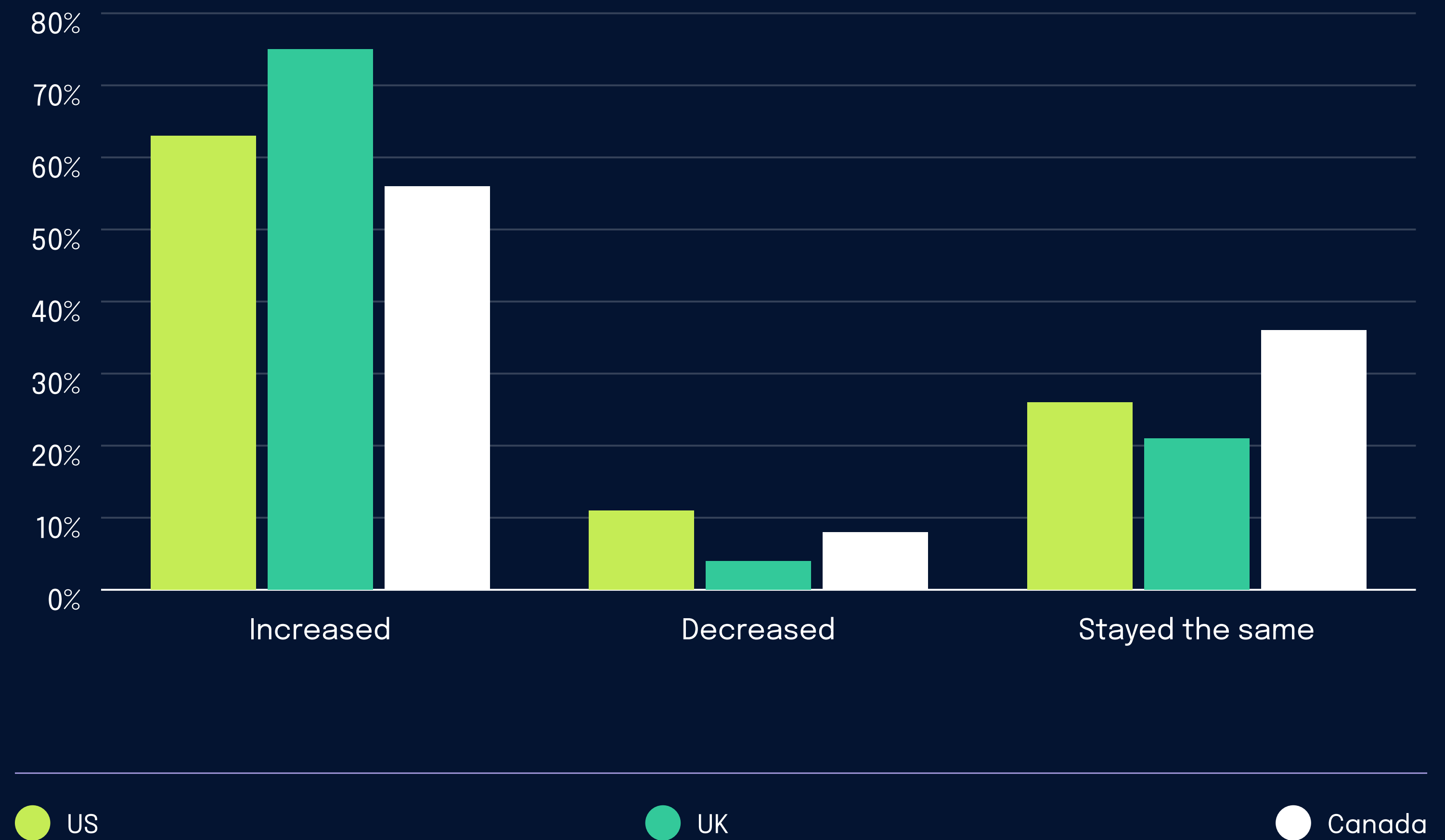


Location shows the UK is more “up and to the right” on budget direction

Budget direction varies meaningfully by headquarters. Respondents in the UK were more likely to report that their GRC budget increased in 2025 (75%) than those in the US (63%) or Canada (56%). This suggests a more consistently expansionary posture among UK-based organizations in this sample, potentially reflecting stronger near-term demand signals around assurance, regulatory readiness, and ongoing compliance execution.

In 2025, did your GRC budget increase, decrease, or stay the same vs. 2024?

by company headquarters

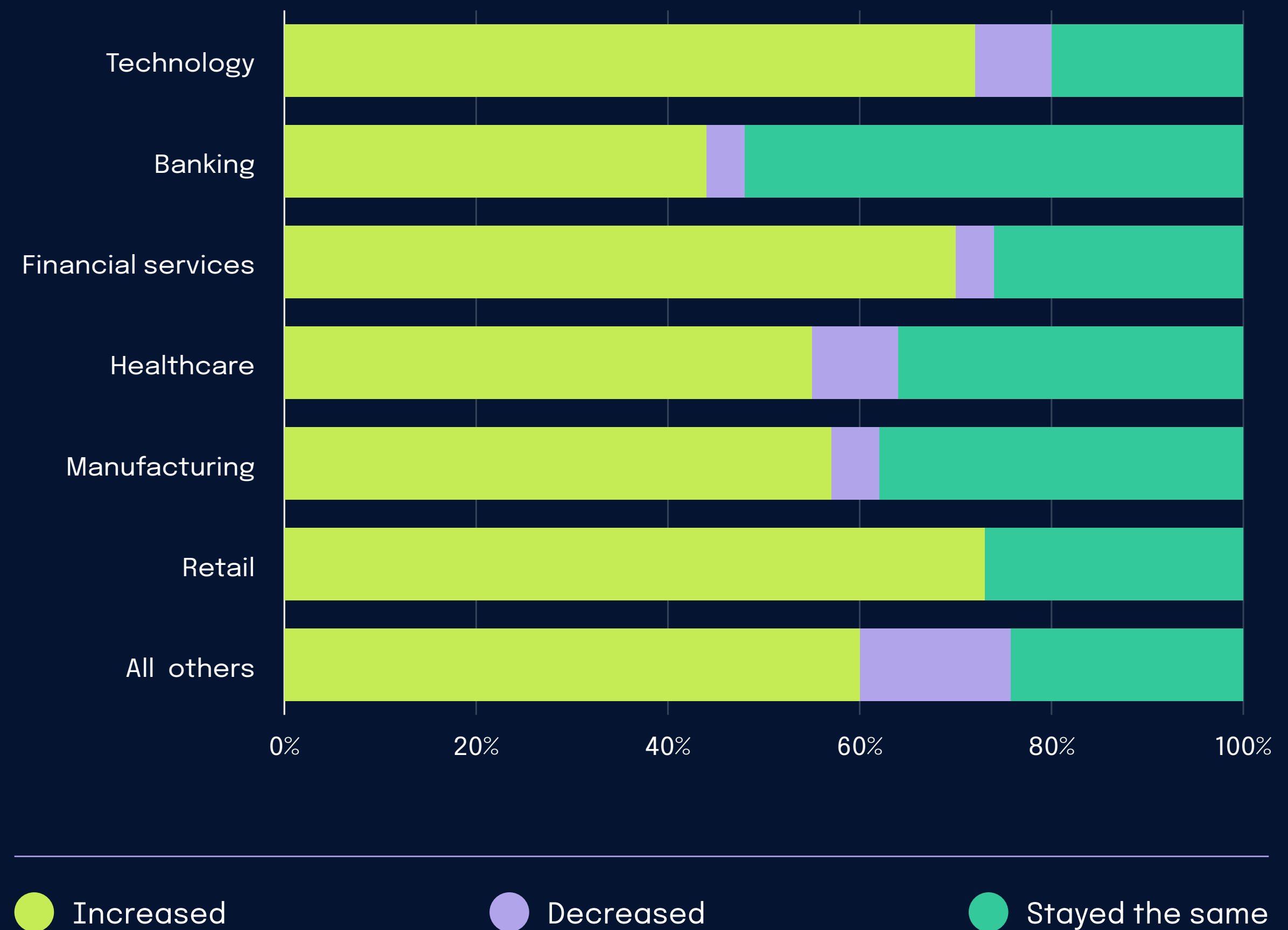


Budgets in the Manufacturing sector are more likely to hold steady, while the Technology sector is more likely to grow

Budget momentum is not uniform across industries. Technology respondents reported increases more frequently (72%) than Manufacturing (57%), indicating that Technology organizations may be continuing to fund GRC as an enabler of scale, customer trust, and rapid change management. Manufacturing, Banking, and Healthcare, by contrast, appear comparatively more budget-conservative, which may reinforce the importance of prioritization and operational efficiency when programs are expected to mature without the same rate of funding expansion.

In 2025, did your GRC budget increase, decrease, or stay the same vs. 2024?

by industry

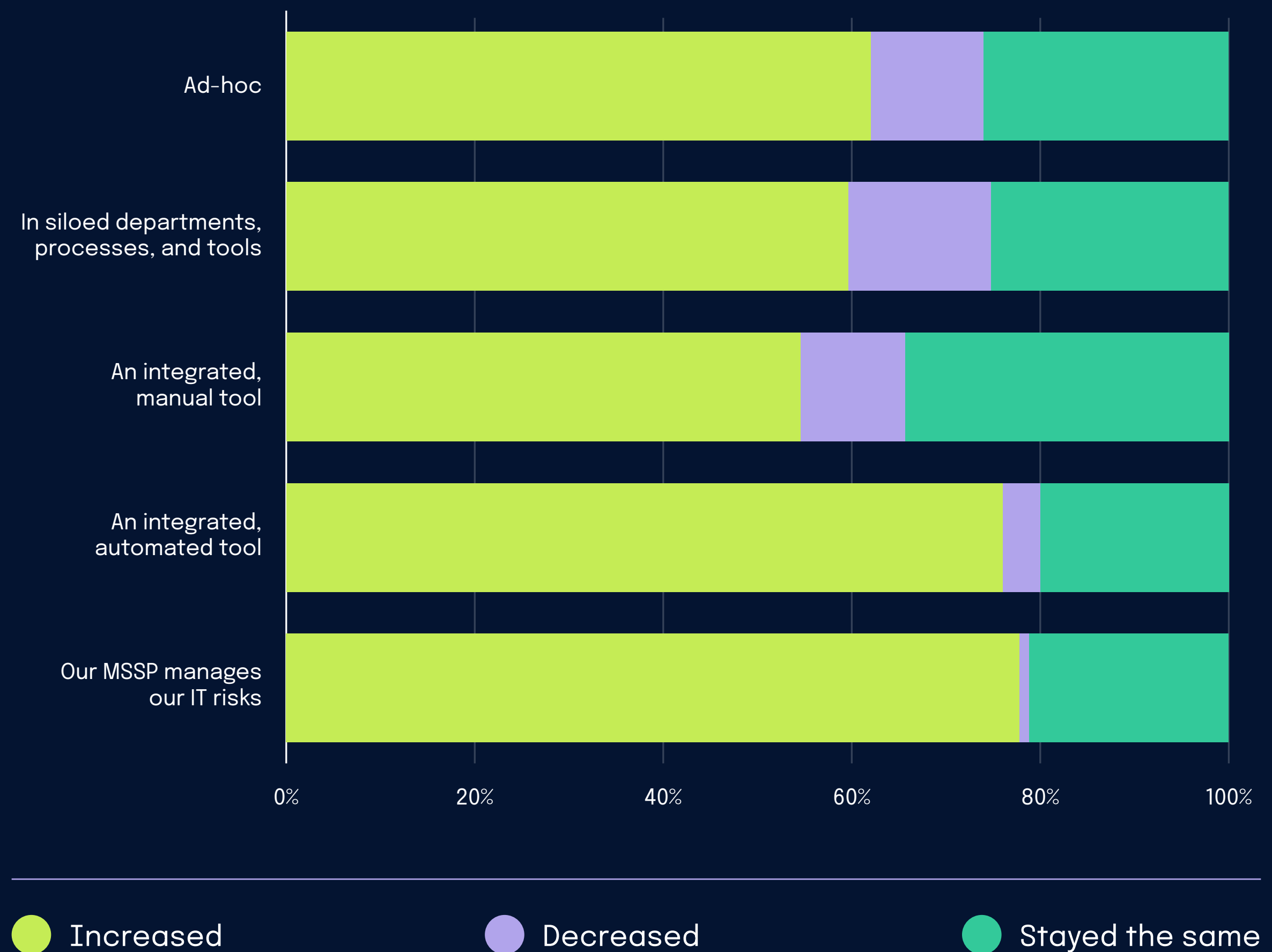


Approaches to IT risk management correlate with budget momentum

Budget direction aligns with how risk and compliance work is operationalized. Respondents using an integrated tool where processes are mostly automated were more likely to report budget increases (76%) than those using an integrated tool where processes are mostly manual (54%). Organizations investing in automation may also be investing more broadly in modernizing their GRC operating model, while more manual environments may face greater constraints or slower funding velocity.

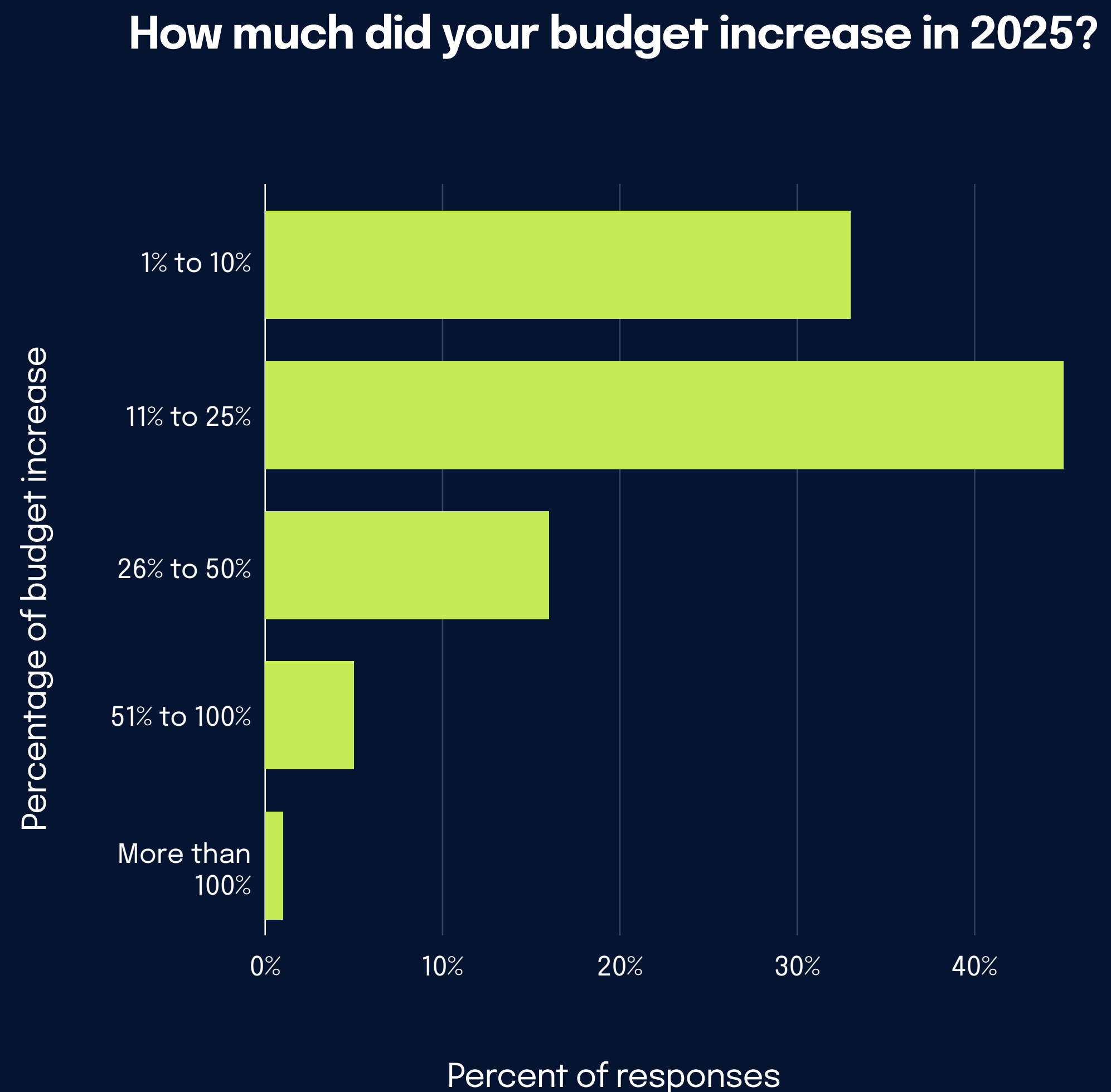
In 2025, did your GRC budget increase, decrease, or stay the same vs. 2024?

by approach to managing IT risks



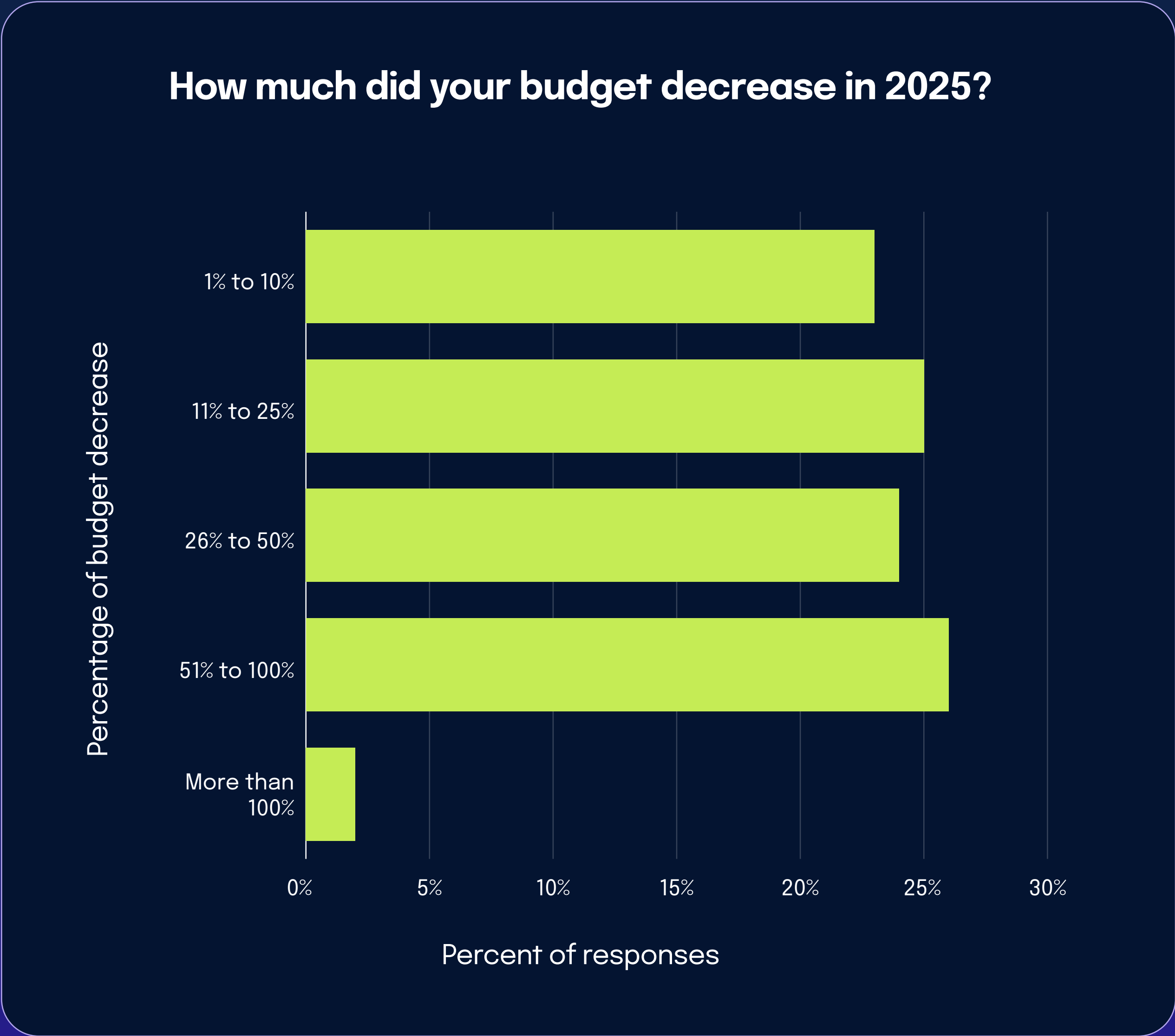
How much budgets increased in 2025

Among organizations that increased budgets, the most common increases were moderate rather than extreme: 45% reported an 11%–25% increase and 33% reported a 1%–10% increase. This pattern suggests many organizations are making deliberate, controlled investments in GRC rather than reacting with dramatic spend spikes. GRC investments are often tied to specific drivers (new requirements, increased scrutiny, expanding cloud environments) and are funded as part of planned operational scaling. The smaller share reporting very large increases (for example, 5% at 51%–100% and 1% at more than 100%) indicates that outsized budget expansions exist, but they are the exception, not the norm.



How much budgets decreased in 2025

The decrease distribution is spread across ranges rather than clustering in a single band, indicating that when cuts happen, they can vary from modest tightening to significant reductions. With a relatively small base of respondents reporting decreases (8% overall), the most responsible interpretation is directional: a minority of organizations did reduce GRC budgets, and those reductions were not uniformly small. In practice, this often translates into operational tradeoffs, such as delaying new initiatives, limiting external support, or consolidating tooling to protect core coverage. The chart helps underscore an important point for readers: even when overall momentum is positive, some teams are operating in constrained environments, which makes efficiency, prioritization, and defensible reporting even more critical.



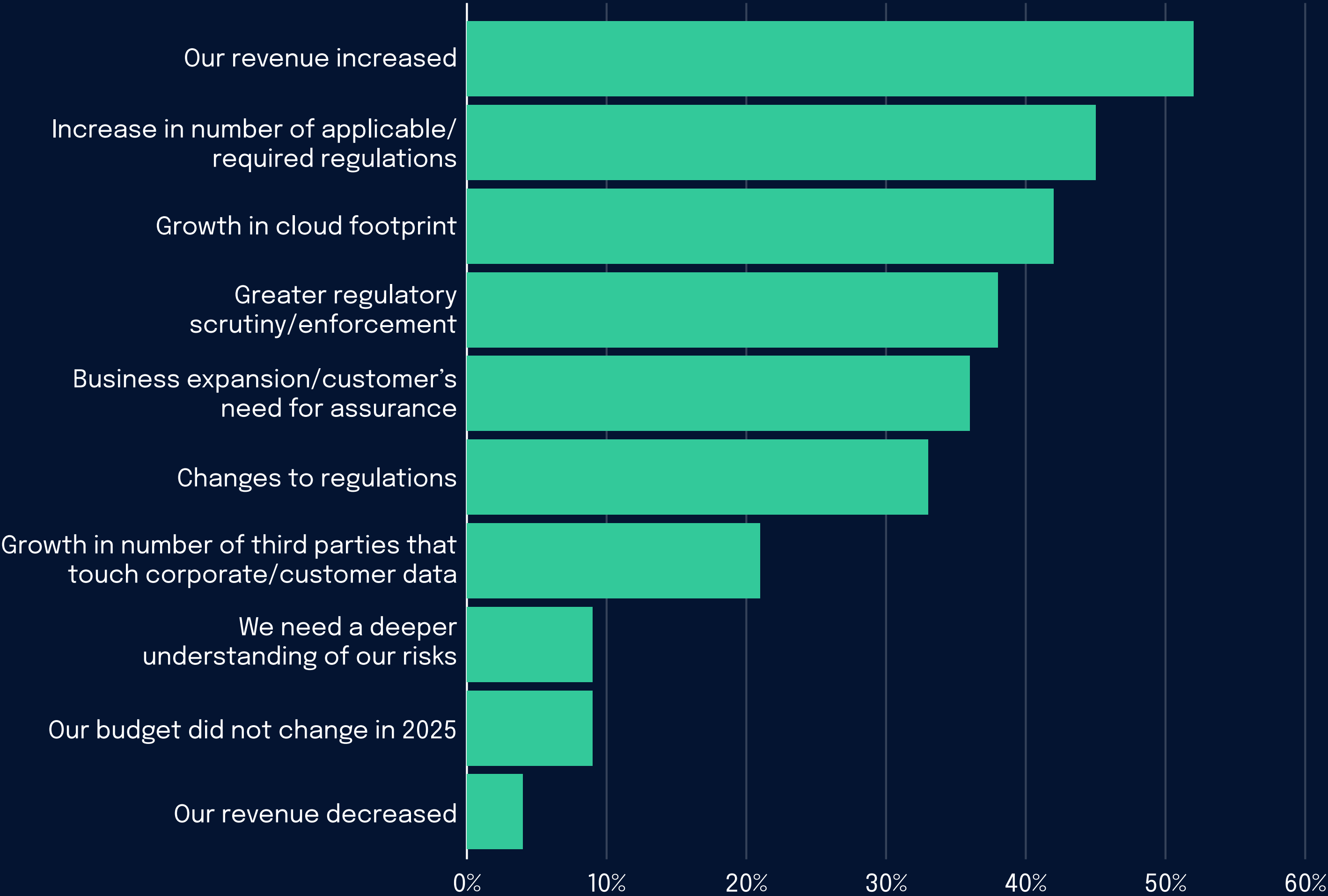
What's driving GRC investment

When respondents explain why budgets changed, the drivers cluster around four key forces that are shaping GRC strategy across the market.

- 1. Organizations saw revenue increases** that resulted in additional resources for GRC teams.
- 2. Regulatory expansion and enforcement pressure** continue to be a dominant catalyst for budget changes.
- 3. Cloud footprint growth** is driving increased risk and compliance workload, particularly as organizations balance speed of delivery with defensible controls.
- 4. Customer assurance expectations** remain a meaningful driver of investment, reinforcing that trust and proof are now ongoing business requirements, not periodic audit exercises.

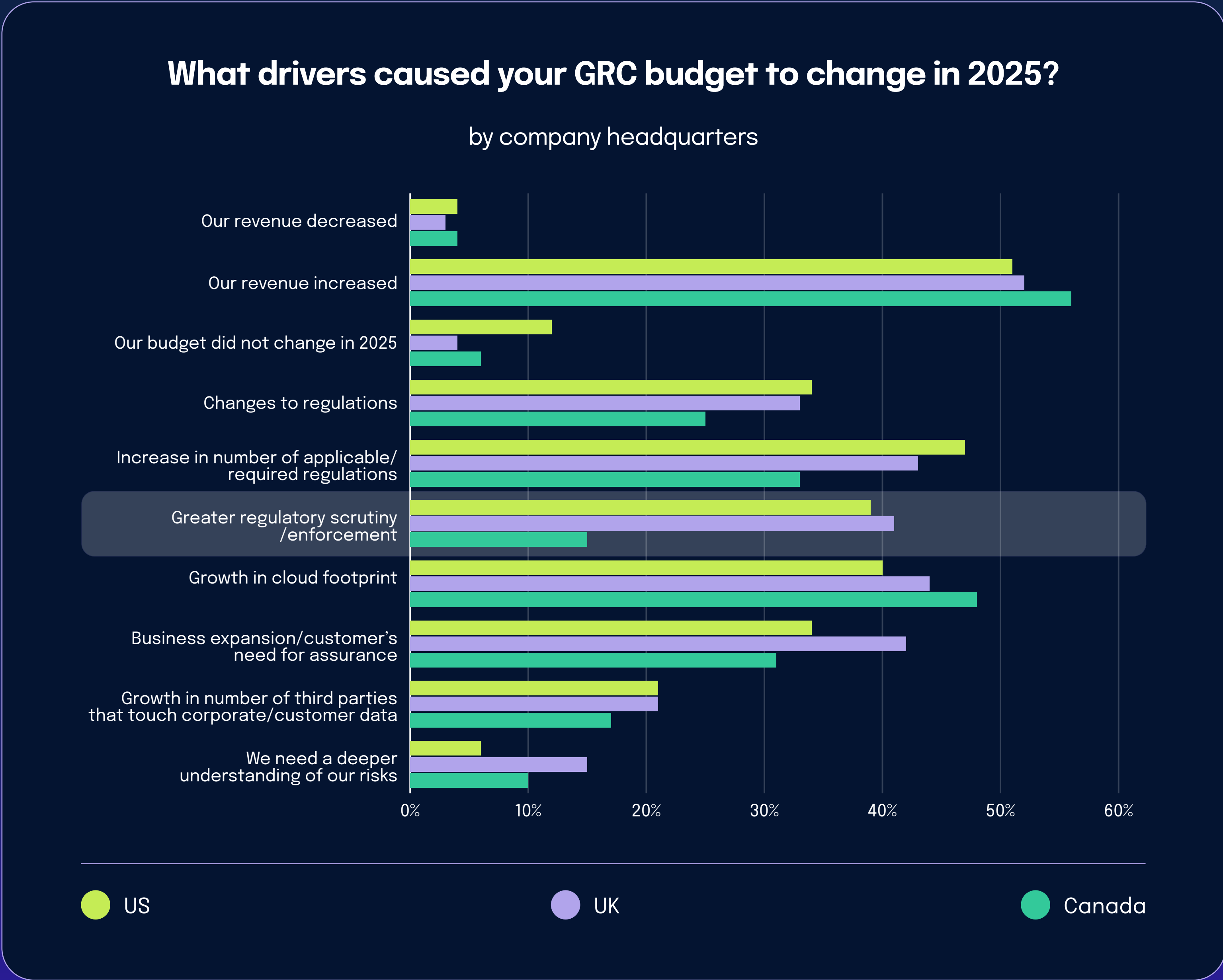
This set of drivers suggests that the demand side of GRC is not stabilizing. It is becoming broader, more continuous, and more externally visible, which in turn increases the ROI of workflow standardization and automation.

What drivers caused your GRC budget to change in 2025?



Regulatory pressure signals are much lower in Canada than the US/UK

Respondents headquartered in Canada were significantly less likely to cite greater regulatory scrutiny and enforcement as a driver of 2025 budget change (15%) compared to the US (39%) and UK (41%). This does not imply lower compliance requirements overall, but it may indicate that Canadian respondents are experiencing less enforcement pressure as the primary trigger for budget change, or that other drivers (such as operational scale or internal transformation) are more prominent in shaping spend decisions.

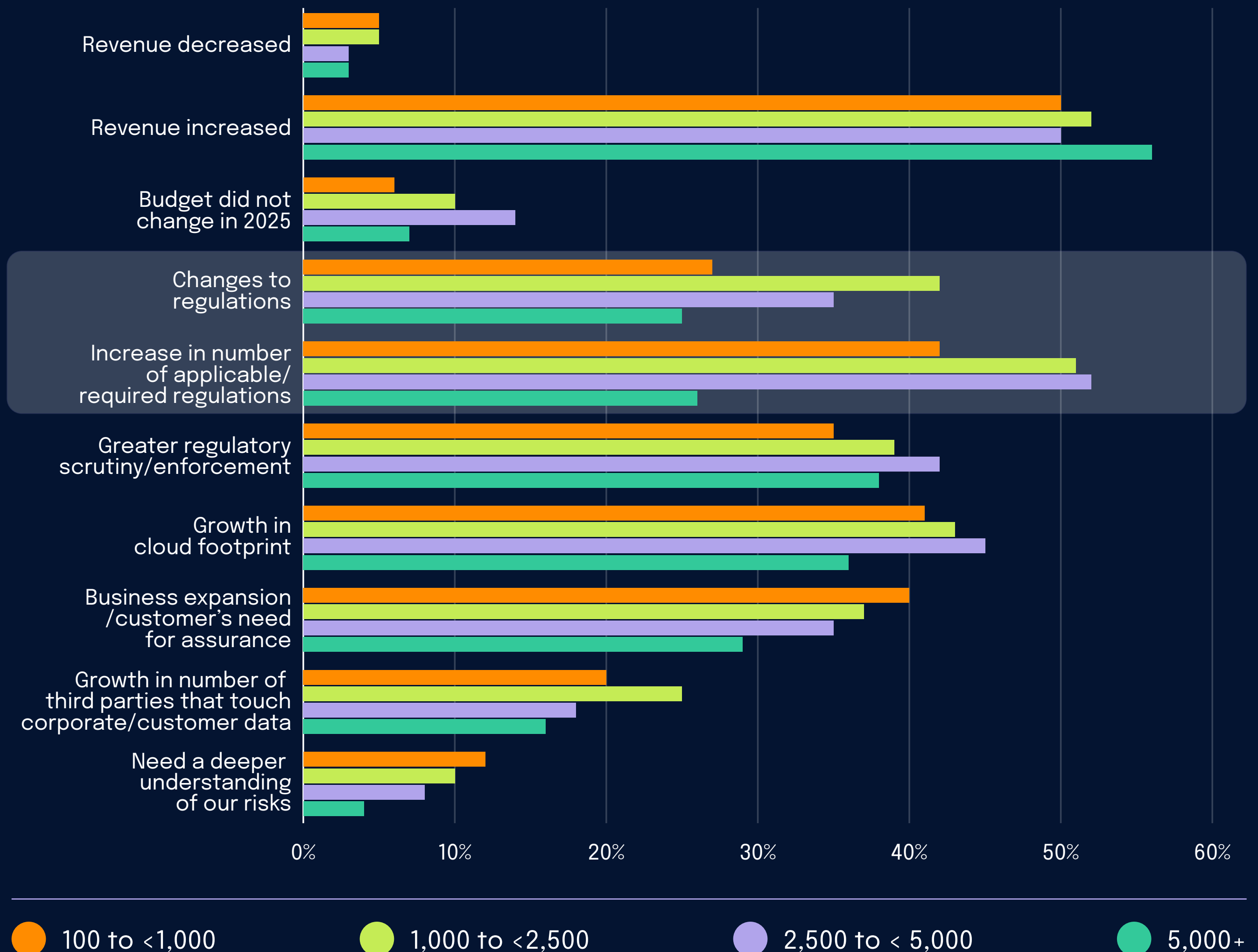


Larger organizations cite regulatory pressure and increased revenue as drivers for budget changes

Larger organizations with company sizes of 5,000+ experienced greater revenue increases that influenced their GRC budgets in 2025. This is likely due to the size and complexity of their businesses and their dedicated investment in GRC. Organizations of 2,500 to 5,000 employees were more likely to cite an increase to the number of required or applicable regulations they needed to adhere to as a reason for their GRC budgets changing. This suggests that as programs scale, regulatory change becomes less of an occasional planning factor and more of an ongoing operating condition that requires sustained investment in mapping, monitoring, and evidence readiness.

What drivers caused your GRC budget to change in 2025?

by company size



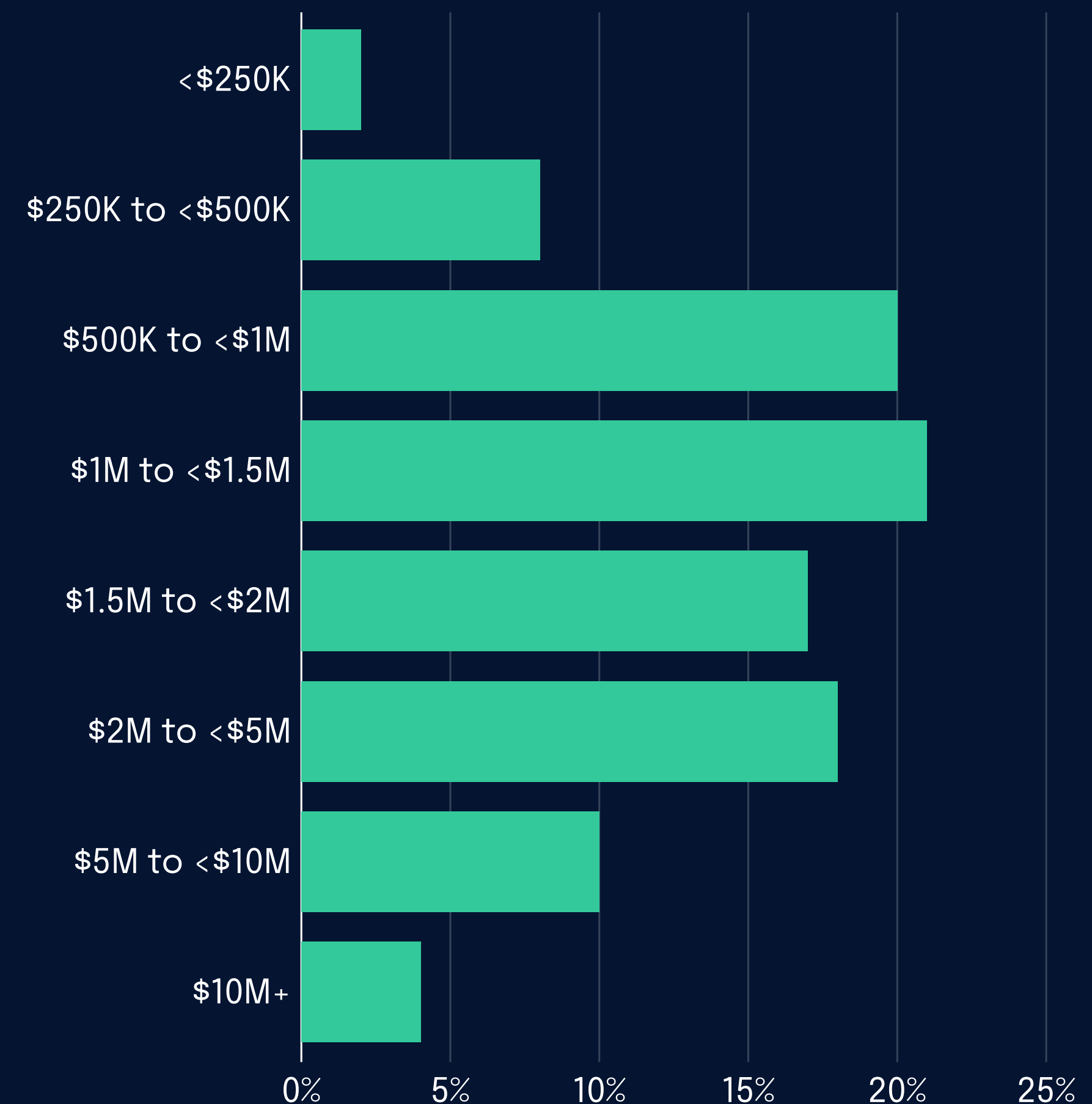
2026 budgets are substantial, and many programs are operating at enterprise investment levels

Reported 2026 GRC budgets skew high. 70% of respondents report a 2026 GRC budget of \$1M or more, signaling that many organizations view GRC as a strategic operating function with real investment behind it, not a side-of-desk responsibility.

This budget distribution also clarifies a critical point: **the opportunity in modern GRC is not simply “spend more.” It is “spend strategically.”**

As budgets cross meaningful thresholds, the biggest differentiator becomes how effectively teams deploy that funding across people, platforms, and services to achieve consistent execution.

What is your GRC budget (including staffing, software, and external services such as auditing) for 2026?

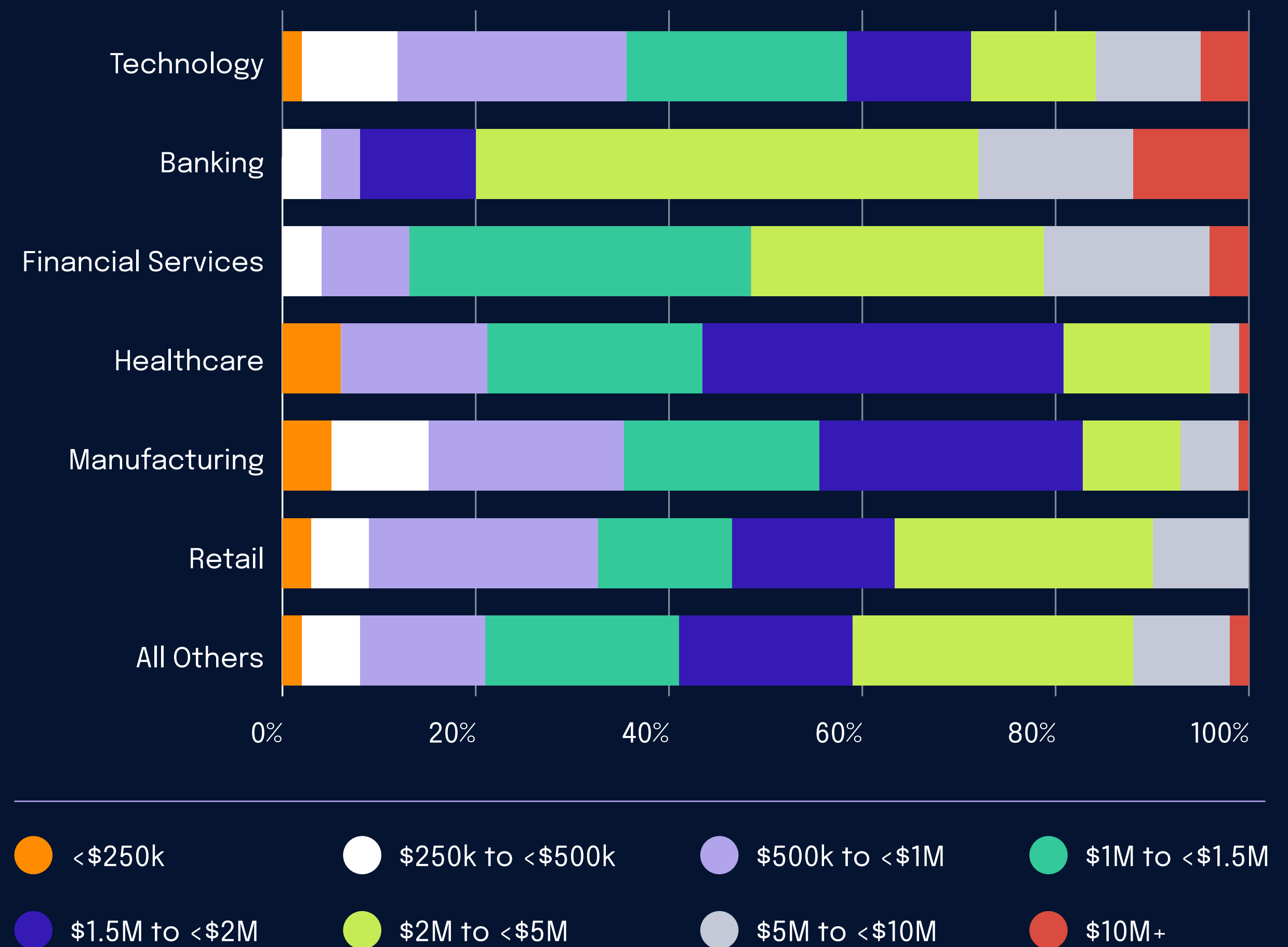


Industry segmentation shows a budget variations at the \$1.5M–<\$2M level

The distribution of 2026 budget bands differs by industry in ways that suggest distinct funding “tiers.” Healthcare and Manufacturing respondents are more likely than Technology respondents to land in the \$1.5M to less than \$2M range. Additionally, 52% of respondents in the Banking industry reported having a range of \$2–5M. This may reflect a common investment level for organizations balancing meaningful compliance obligations with tighter budget standardization, reinforcing that many programs are funding core execution but still need efficiency gains to scale without continuously expanding spend.

What is your GRC budget (including staffing, software, and external services such as auditing) for 2026?

by industry

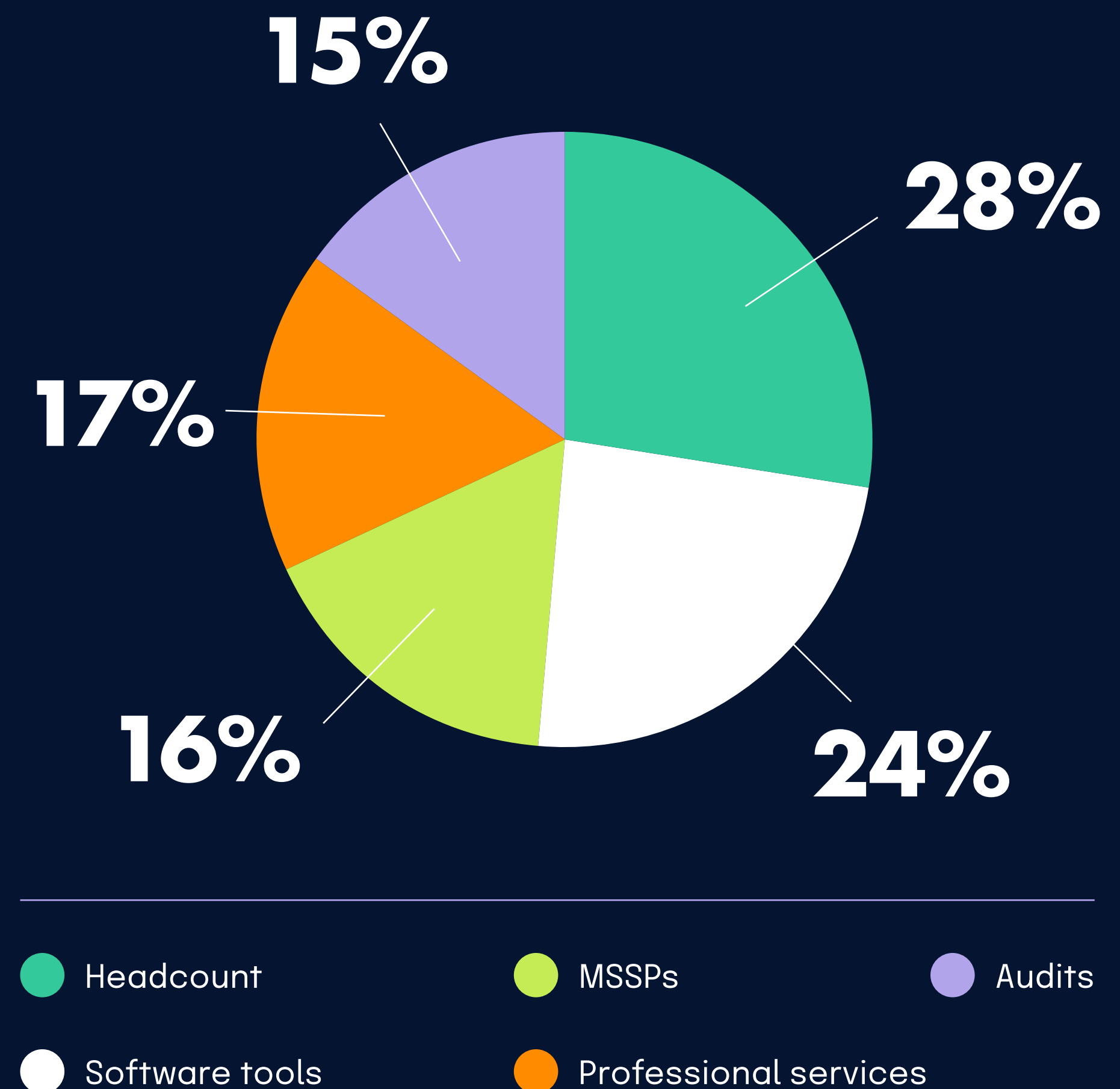


Allocation reveals priorities: headcount and software tools lead, with services filling key gaps

When respondents break down how their budget is allocated, the averages point to a balanced investment model. The largest share is allocated to headcount at 28%, and software tools follow closely behind at 24%. The remaining allocation is distributed across MSSPs, professional services, and audits.

Many programs are building internal capacity while relying on outside support for specialized needs. It also reinforces that **software investment is not just a tooling line item, it is a lever for reducing recurring administrative effort, strengthening traceability, and enabling consistent reporting across a growing set of requirements.**

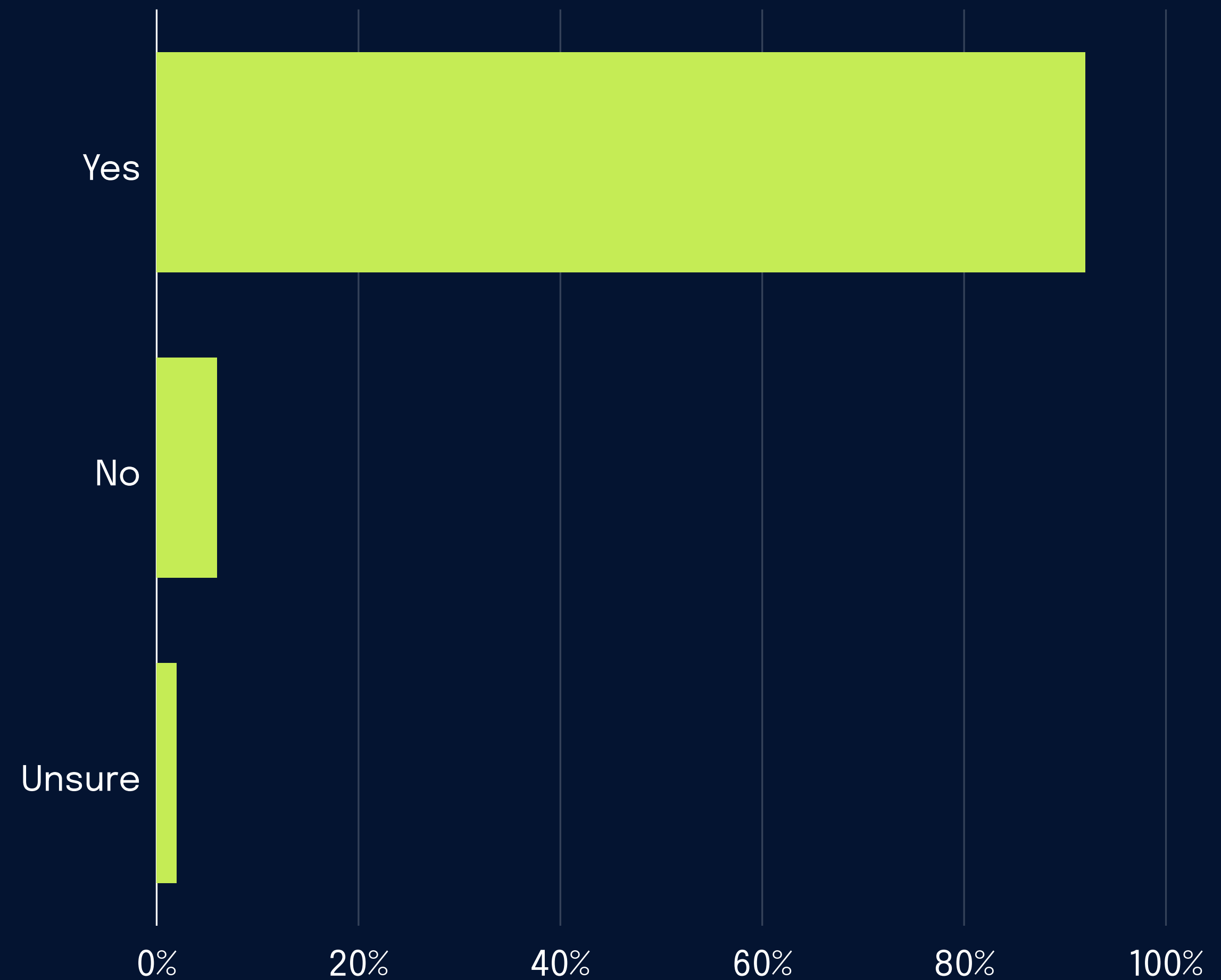
What percentage of your budget allocation goes to the following areas?



Most teams say they had what they needed in 2025, but workload expectations are still rising

A striking result this year is the level of confidence respondents express about resourcing. 92% report they had the budget and resources needed to execute their GRC goals and initiatives in 2025, a strong indicator that many organizations are not only investing, but also viewing those investments as sufficient.

In 2025, did you have the budget and resources to execute your GRC goals/initiatives?

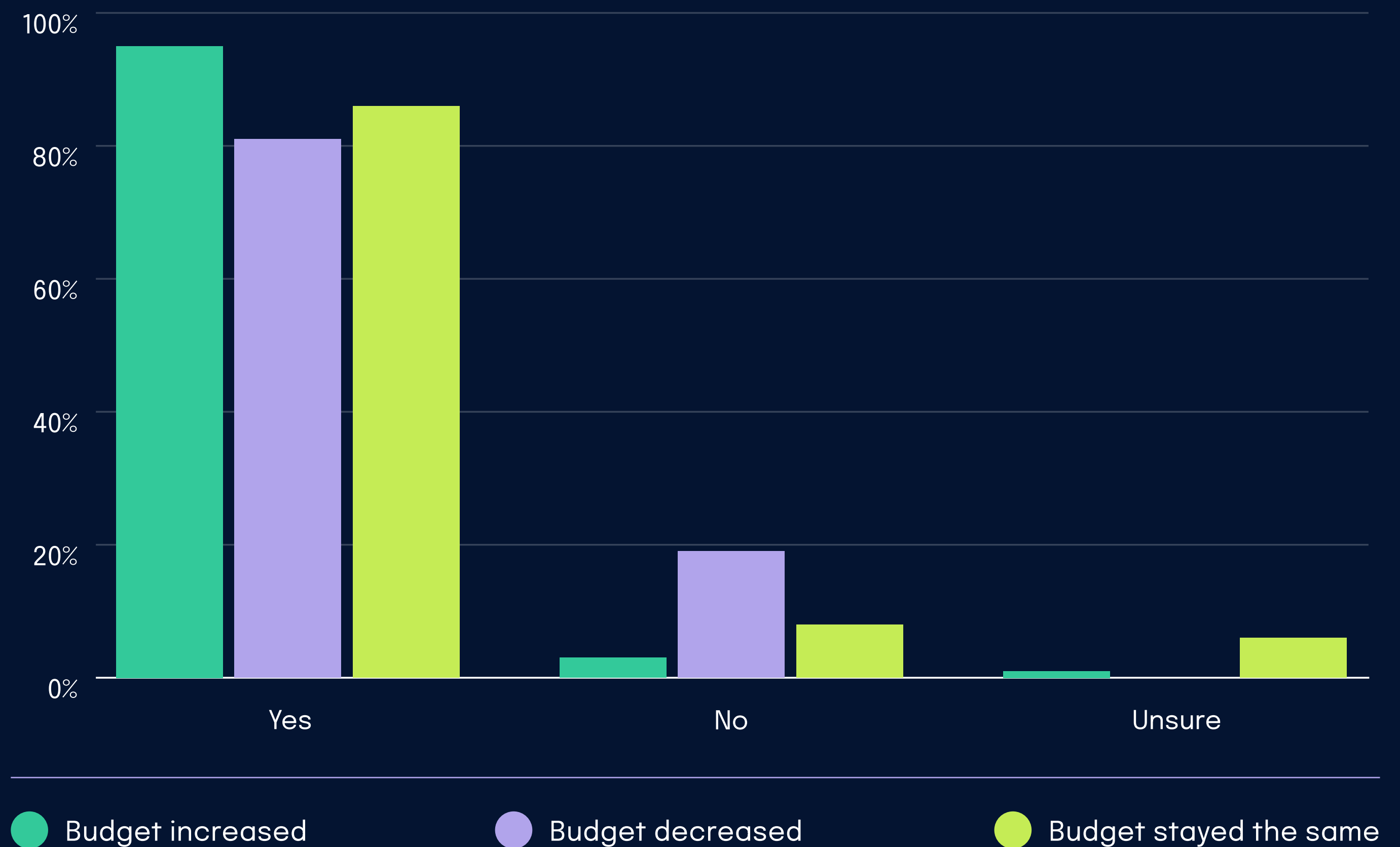


Budget confidence is meaningfully lower when budgets were cut

Perceived sufficiency of budget and resources is strongly affected by whether budgets were reduced. Respondents whose budgets increased were far more likely to say they had what they needed to execute their goals (95%) than those whose budgets decreased (81%). This gap highlights a practical reality: even small budget contractions can translate into disproportionate execution pressure, particularly when compliance scope and stakeholder expectations continue to grow.

In 2025, did you have the budget and resources to execute your GRC goals/initiatives?

by 2025 GRC budget changes

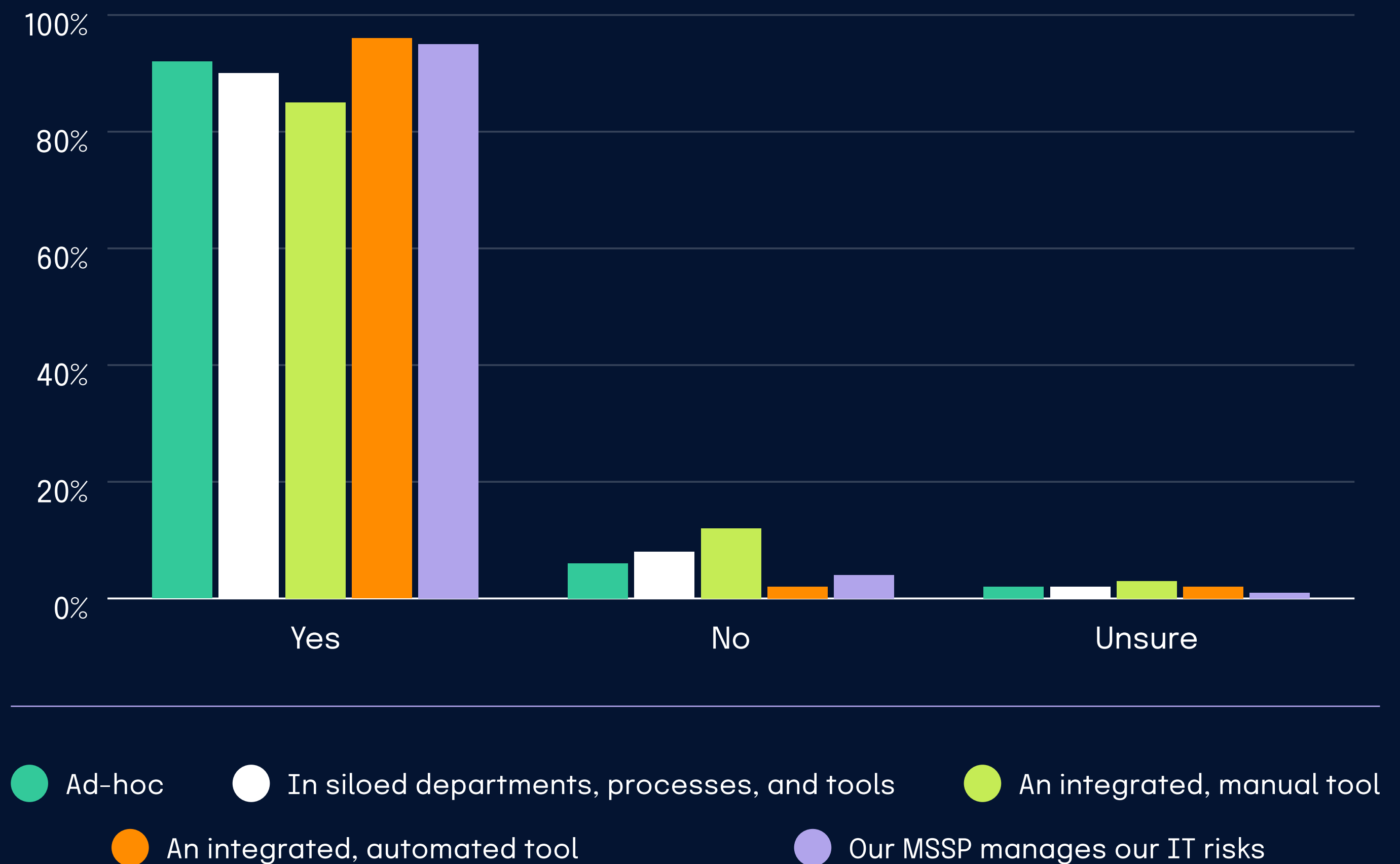


Automation correlates with higher perceived capacity

Perceived capacity also aligns with how automated the operating model is. Respondents using an integrated tool with mostly automated processes were more likely to say they had sufficient budget and resources (96%) than those using an integrated tool with mostly manual processes (85%) or those managing risk in siloed departments, processes, or tools (90%). Automation is not only a productivity lever; it changes how “resourced” a team feels by reducing the coordination load and the manual effort required to maintain readiness.

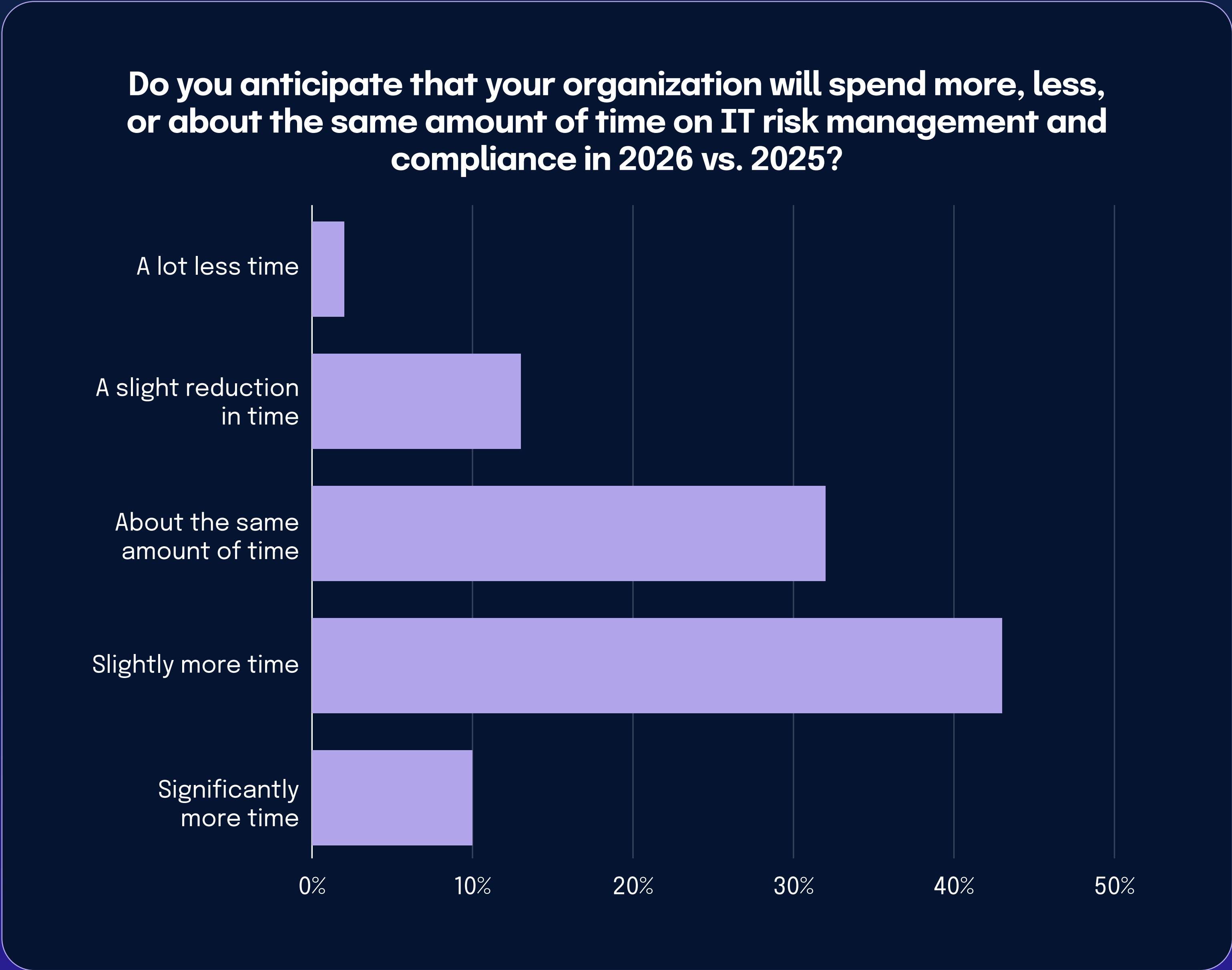
In 2025, did you have the budget and resources to execute your GRC goals/initiatives?

by approach to managing IT risks



Increased budget does not indicate decreasing workloads

However, sufficiency does not imply that workload is shrinking. Respondents anticipate spending even more time on GRC work in 2026. Even with adequate resources, the scope and intensity of risk and compliance work is still expanding.

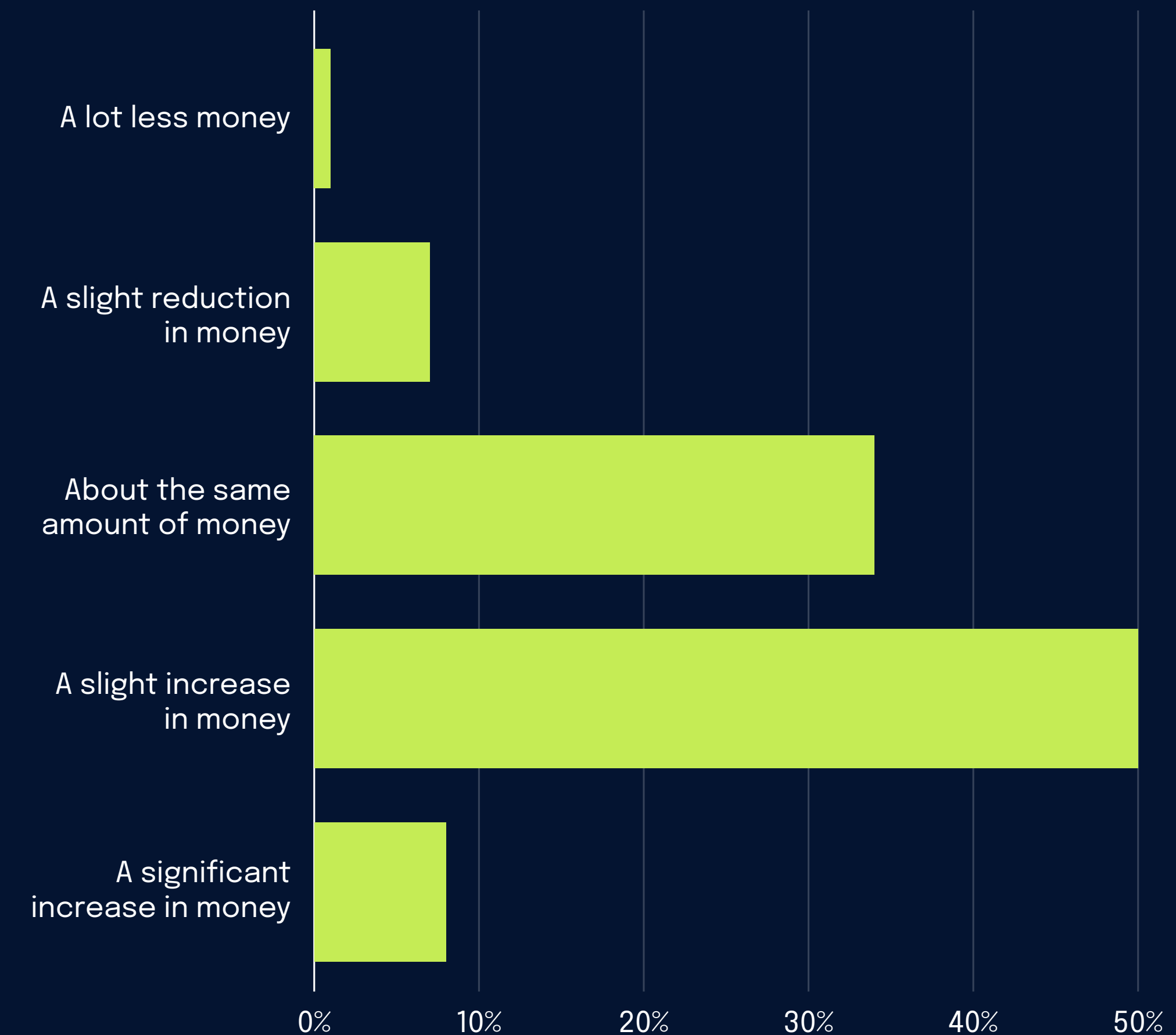


Predicted budgets for 2026

Most organizations expect GRC spending pressure to continue into 2026. A majority anticipate spending more money overall, with 50% expecting a slight increase and 8% expecting a significant increase. At the same time, 34% expect to spend about the same, and only 8% anticipate any reduction (7% slight reduction; 1% a lot less).

This indicates a sustained upward drift. Many organizations appear to be planning incremental increases to keep pace with expanding requirements, ongoing assurance expectations, and the operational cost of maintaining readiness. It also reinforces a theme seen elsewhere in the budget data: even when increases are modest, they compound over time and often come with higher expectations for measurable ROI. For GRC leaders, that means the focus shifts from simply securing more funding to demonstrating impact through reduced manual work, stronger traceability, and faster, more defensible reporting.

Do you anticipate that your organization will spend more, less or about the same amount of money on IT risk management and compliance in 2026 vs. 2025?

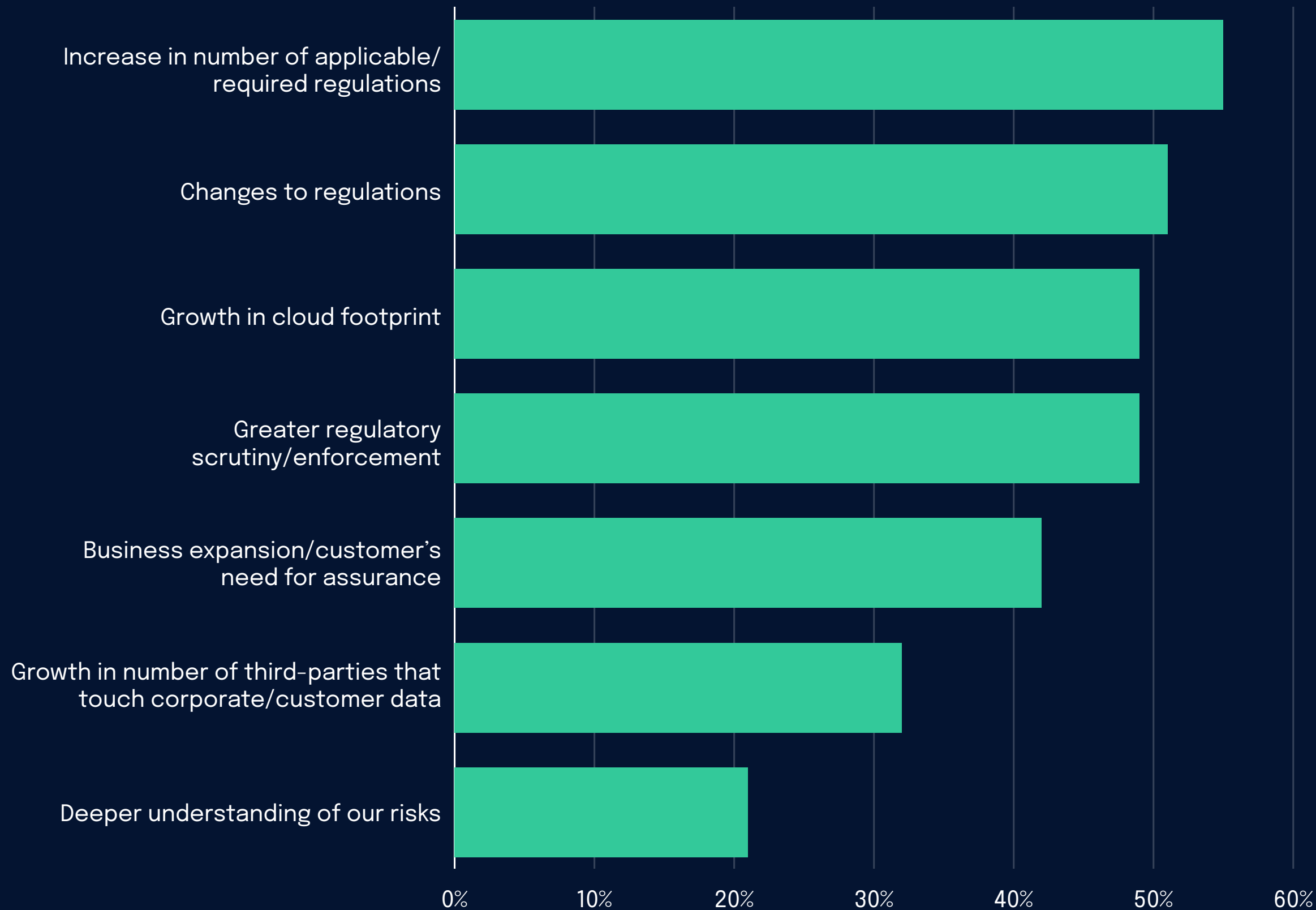


Top drivers of spend increase

Among respondents expecting higher spend, the top drivers are dominated by external volatility and internal complexity. Regulation is not simply increasing; it is changing, being enforced, and expanding in scope. At the same time, cloud growth continues to amplify the control surface area that GRC programs must manage and evidence.

Spend increases are not discretionary upgrades. They are responses to structural conditions that are unlikely to reverse. In that environment, the ROI discussion becomes less about whether to invest and more about how to ensure investments reduce recurring operational inefficiency.

You stated you expect to increase the amount you're spending. What are the top factors driving your IT risk/compliance spend increase?

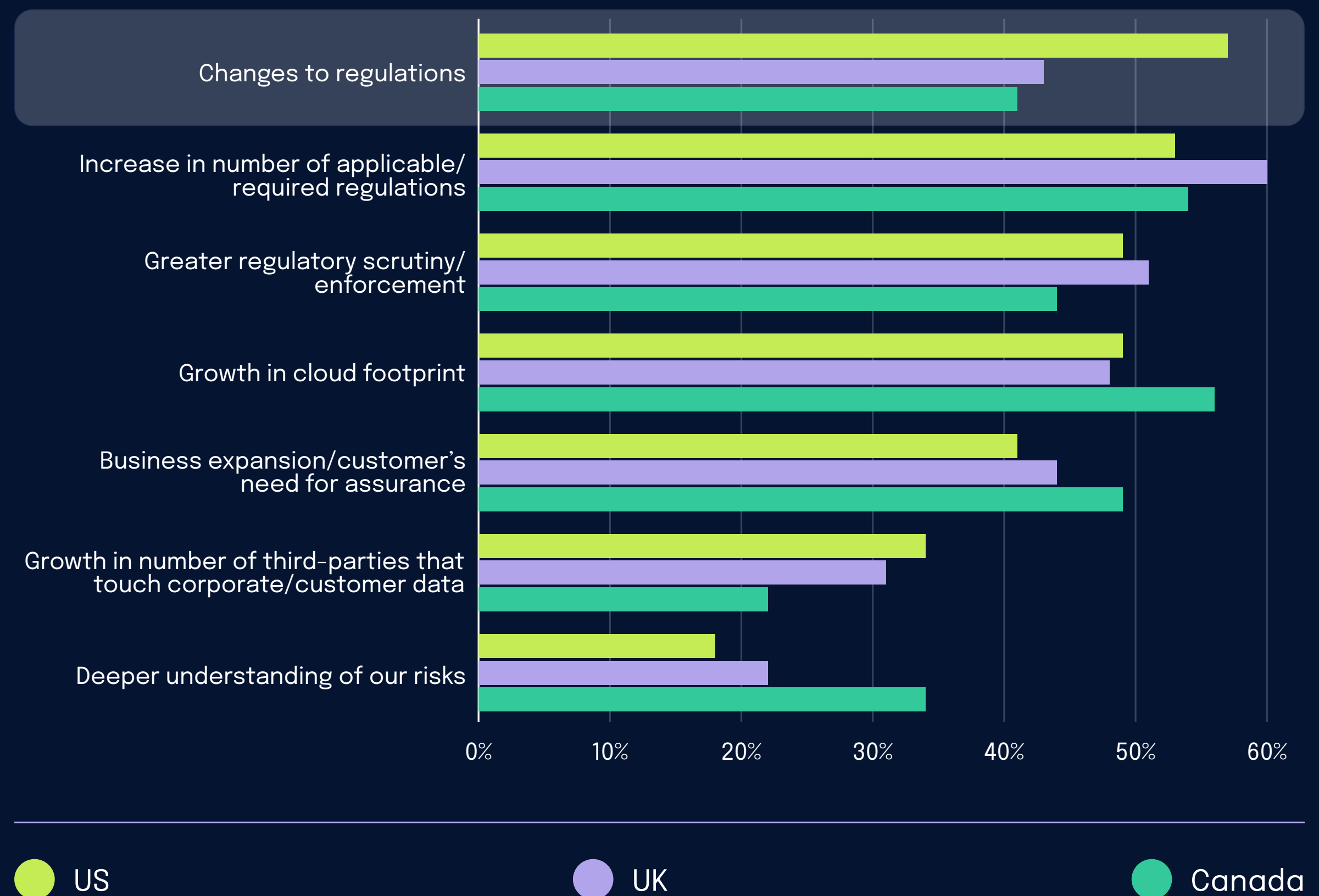


Regulatory volatility is a stronger driver in the US than in the UK/Canada

Respondents headquartered in the US are more likely to cite regulatory volatility as a top driver of increased IT risk and compliance spend (57%) compared to the UK (43%) and Canada (41%). This suggests that regulatory change is being felt as a more immediate planning pressure in the US, where organizations may be balancing a fast-evolving patchwork of requirements with heightened expectations for defensible controls and reporting.

You stated you expect to increase the amount you're spending. What are the top factors driving your IT risk/compliance spend increase?

by company headquarters

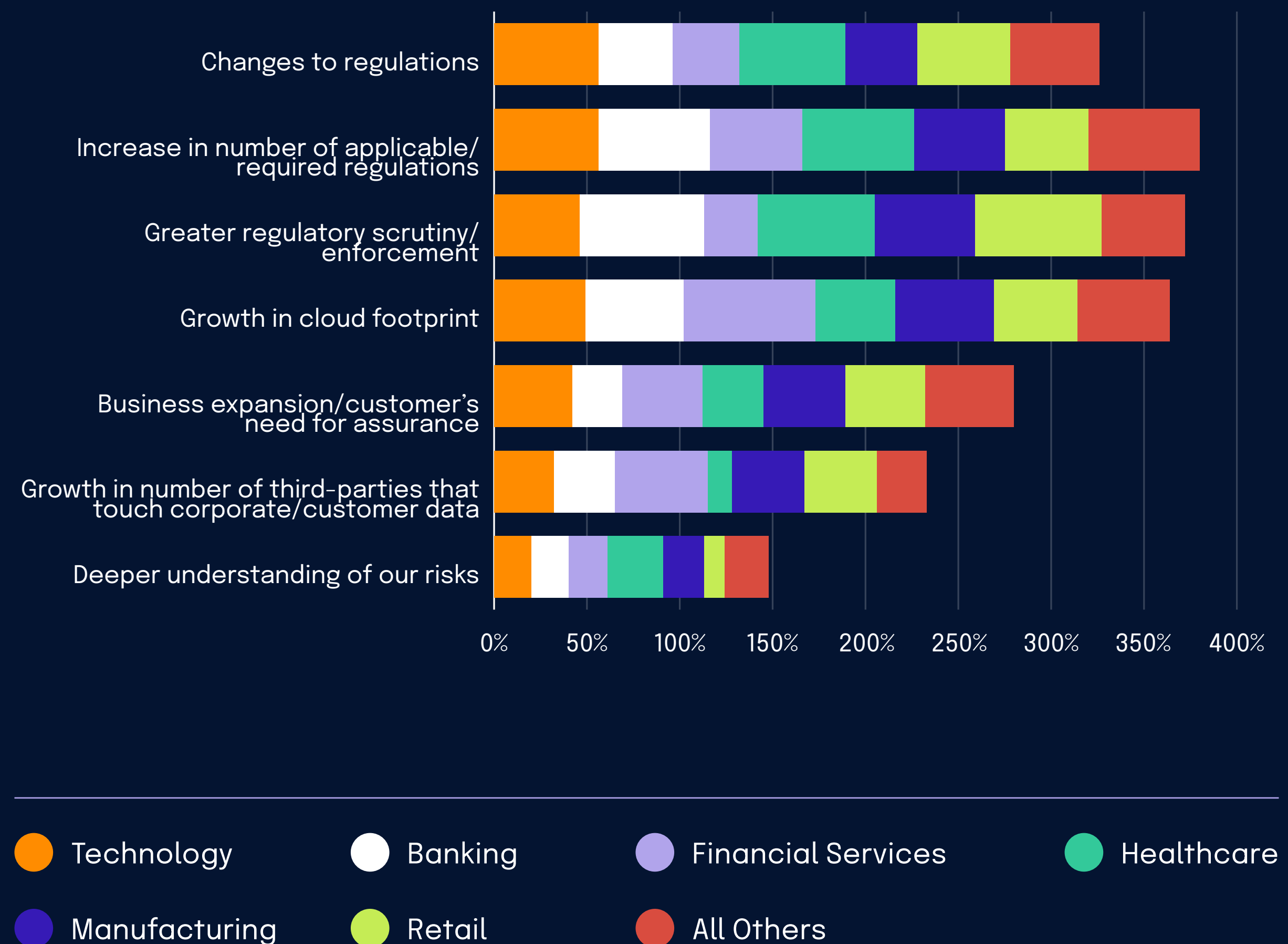


Cloud growth is especially pronounced in Financial Services

Financial Services stands out as the industry feeling elevated pressure from growth in cloud footprint at 71%. Cloud transformation is expanding the technical surface area that teams must govern, while enforcement pressure raises the consequences of gaps in control consistency, evidence readiness, and reporting. For Financial Services leaders, this points to a need for operating models and tooling that can keep compliance continuously current as environments change.

You stated you expect to increase the amount you're spending. What are the top factors driving your IT risk/compliance spend increase?

by industry

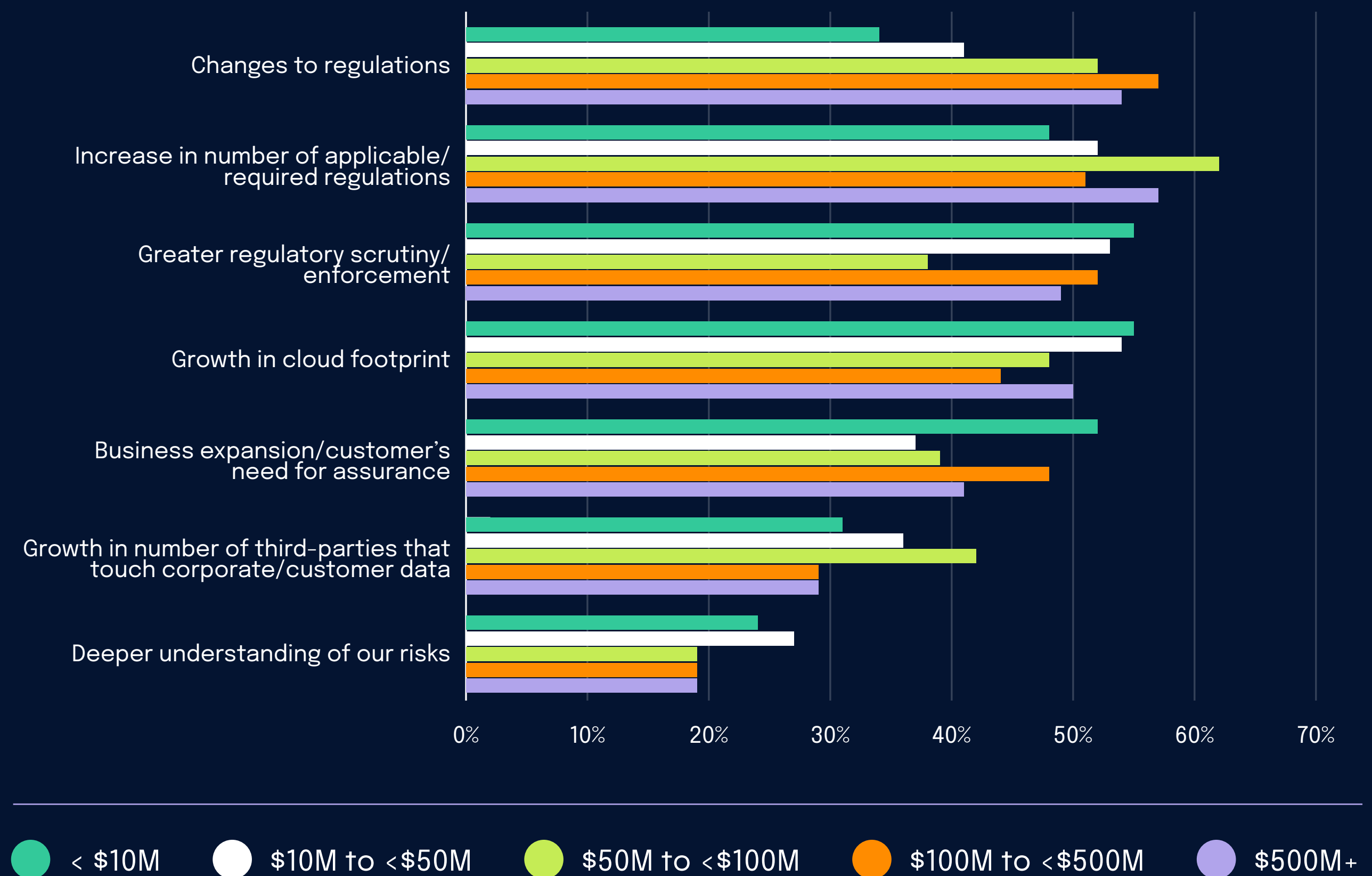


Revenue scale correlates with a stronger “regulatory volatility” driver

Regulatory volatility increases as a spend driver with organizational scale. Respondents in the \$100M to less than \$500M and \$500M+ revenue bands are significantly more likely to cite regulatory volatility (57% and 54%, respectively) than those under \$10M (34%). This aligns with a practical reality: as organizations grow, they typically face a wider mix of contractual obligations, regulatory exposure, and external assurance demands, making regulatory change less of a periodic concern and more of an ongoing operating condition.

You stated you expect to increase the amount you’re spending. What are the top factors driving your IT risk/compliance spend increase?

by revenue

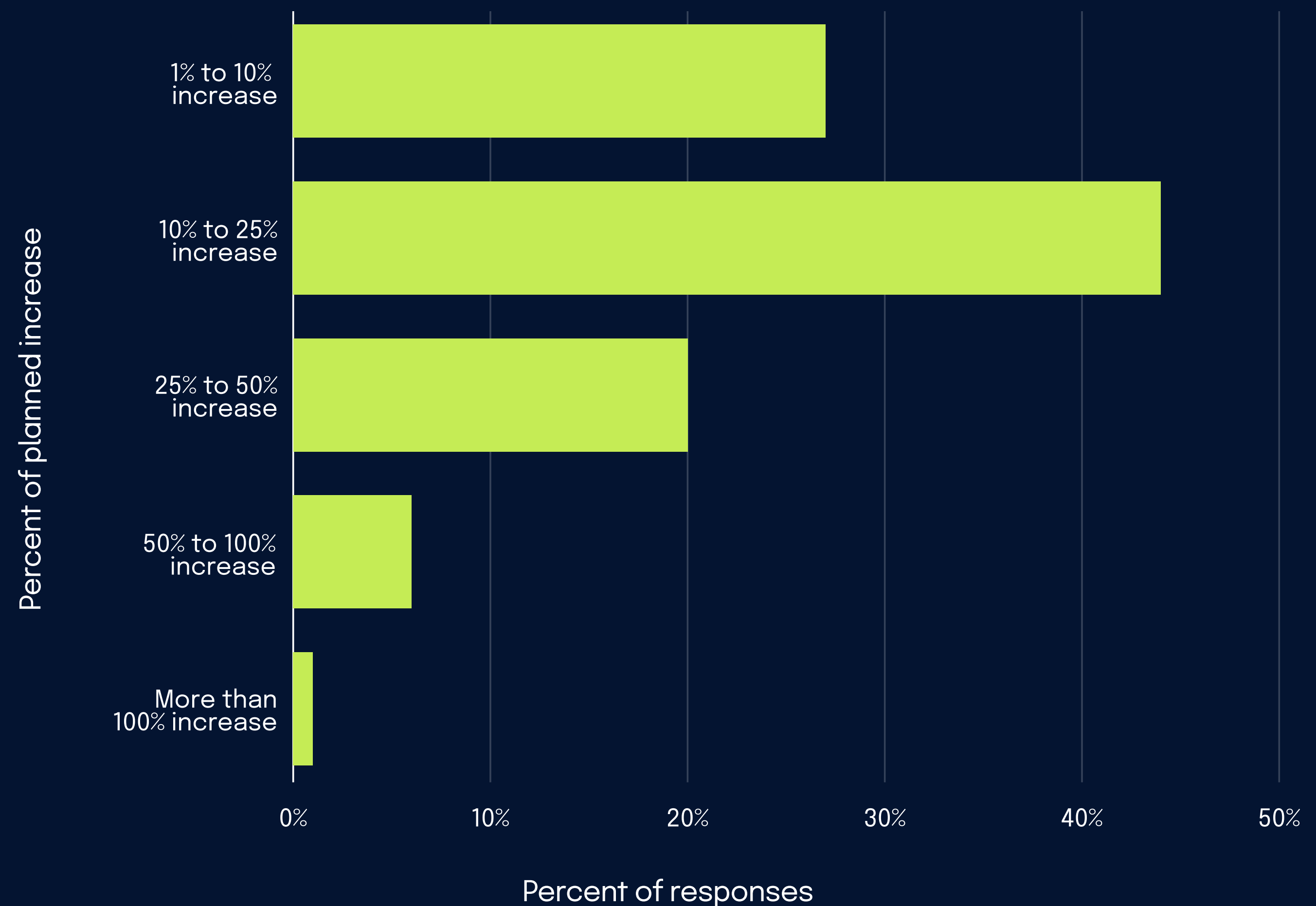


Planned budget increases over the next 12-24 months

The distribution suggests that many are planning moderate increases rather than minimal adjustments. This matters because it implies continued prioritization and continued pressure to deliver measurable outcomes from that investment.

The operational implication is straightforward: when budgets grow, expectations rise. That places a premium on programs that can show defensible progress through reliable metrics, consistent control evidence, and reporting that leadership can trust.

What is the expected or planned increase in your GRC budget in the next 12 to 24 months?

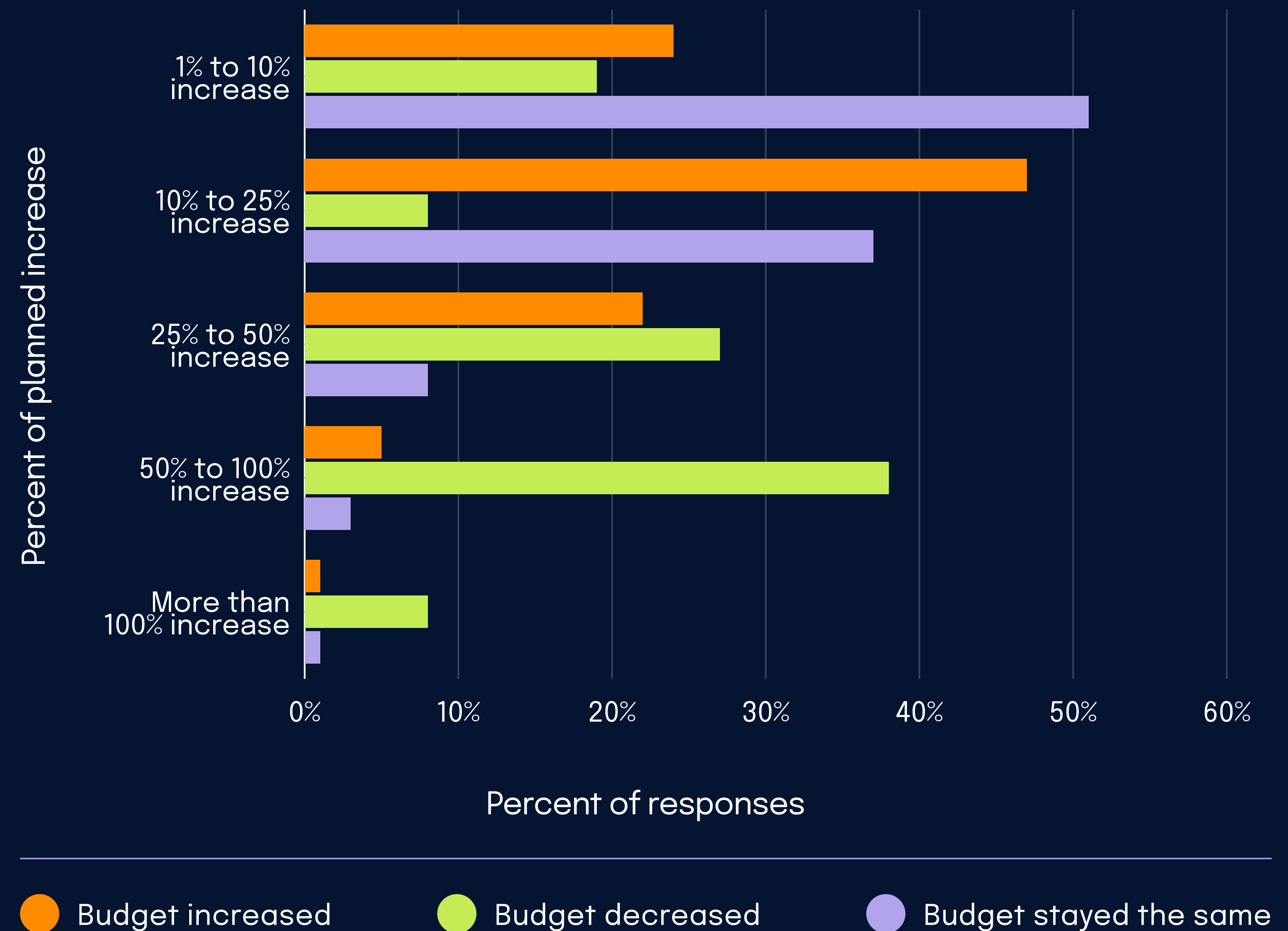


Prior-year budget trajectory strongly shapes the size of planned increases

Planned increases are not uniform; they reflect the momentum of the prior year. Organizations whose GRC budgets stayed the same in 2025 are more likely to plan a modest 1%–10% increase (51%), while organizations whose budgets increased in 2025 are more likely to plan larger jumps, including 25%–50% increases (22%). This suggests that many organizations treat GRC investment as a multi-year scaling effort: when budgets have already been rising, organizations are more likely to continue expanding scope and capacity rather than making only incremental adjustments.

What is the expected or planned increase in your GRC budget in the next 12 to 24 months?

by 2025 GRC budget changes



CHAPTER 4

Third-Party Risk Management at Scale

Third-party risk management (TPRM) has moved from a specialized security practice to a business-wide operating requirement. Vendors and suppliers are now embedded in nearly every critical workflow, from customer data processing and core infrastructure to finance, HR, and AI-enabled services. As a result, third-party risk is no longer something organizations can address only at onboarding or at annual renewal. It requires repeatable decision-making, consistent evidence collection, and the ability to detect changes in vendor risk posture over time.

This year's data reflects that shift in two important ways. First, third-party risk programs are increasingly expected to deliver ongoing assurance, not just point-in-time due diligence. Respondents' priorities emphasize cybersecurity and data protection, and many organizations report maturity models that include continuous monitoring.

Second, the operational inputs powering TPRM remain varied. Organizations continue to rely on a mix of questionnaires, trust centers, and risk rating solutions, along with manual tools and fragmented workflows. In practice, these mixed inputs often create the biggest execution challenges: normalizing information, applying consistent evaluation standards, tracking remediation, and maintaining an audit-ready record as vendors and requirements change.

This chapter also highlights how the scope of third-party risk is expanding in step with technology adoption. AI is now part of the vendor ecosystem, and many organizations have begun incorporating AI-specific assessment criteria into supplier evaluations. However, approaches differ substantially, ranging from dedicated frameworks to lighter-weight criteria within general assessments. This variability signals an important maturity frontier: organizations recognize AI-related third-party risk, but many are still formalizing what “good” looks like in practice, including what evidence to request, how to validate it, and how frequently to reassess.

Across these findings, the underlying theme is consistency at scale. As vendor ecosystems grow, the primary constraint is not intent. It is the ability to run third-party risk management as a standardized, repeatable workflow that integrates evidence, monitoring, and remediation. Programs that can centralize vendor risk records, apply consistent controls and evaluation standards, and reduce manual follow-up are best positioned to keep pace with rising assurance expectations without turning TPRM into a bottleneck for the business.

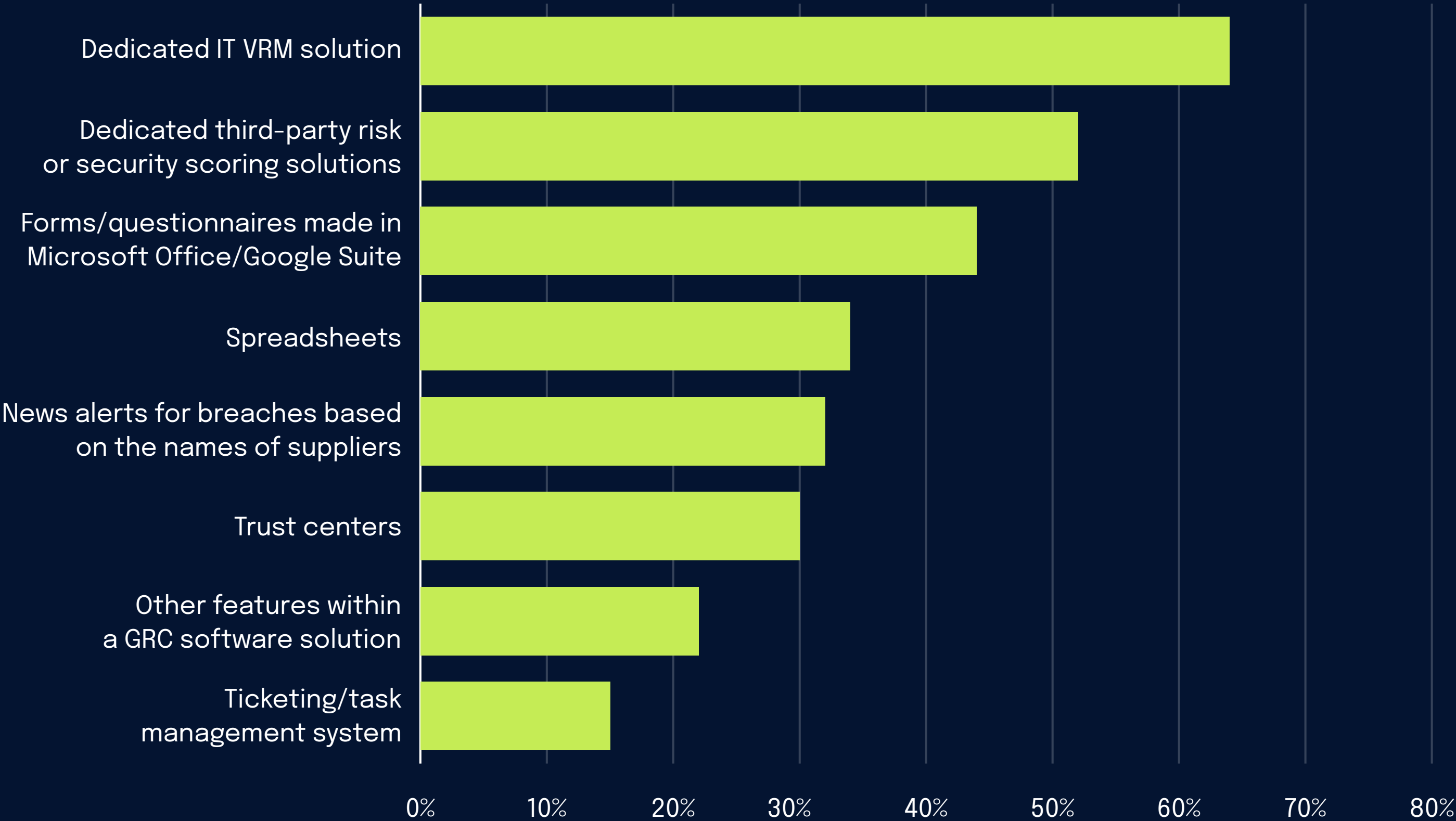
Tooling is improving, but many programs still rely on manual inputs

Even as third-party risk programs mature, the tools and inputs teams rely on remain mixed. Many organizations are combining dedicated solutions and structured processes with manual workflows that slow down reviews and introduce inconsistency.

A key implication is that third-party risk often becomes “multi-system by default.” When vendor evidence, questionnaires, ratings, and remediation tracking are spread across different tools, teams spend more time normalizing information than making informed decisions. This can create friction in vendor onboarding, delay remediation follow-through, and make it harder to demonstrate consistency to auditors and leadership. The organizations best positioned to scale are those that can centralize third-party risk records, standardize evidence requirements, and automate repeatable steps, such as collection, parsing, and status tracking.

A SaaS GRC platform helps by providing a system of record for vendor profiles, control requirements, evidence, and remediation workflows. This does not eliminate the need for ratings, questionnaires, or trust centers. Instead, it makes those inputs easier to operationalize consistently across a growing vendor ecosystem.

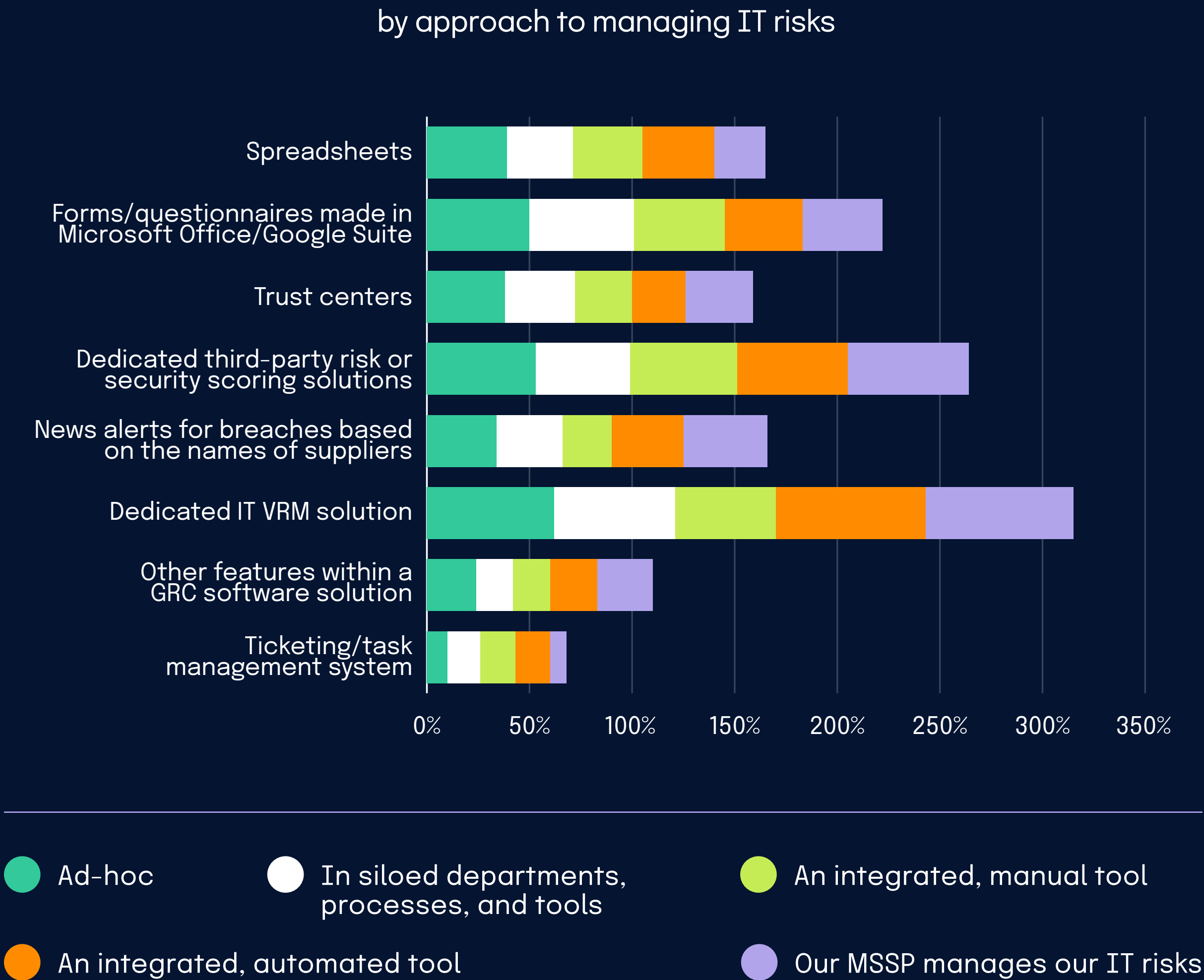
What tools are you using to identify and manage IT risks arising from your third parties? Select all that apply:



Automated programs are more likely to invest in dedicated vendor risk platforms

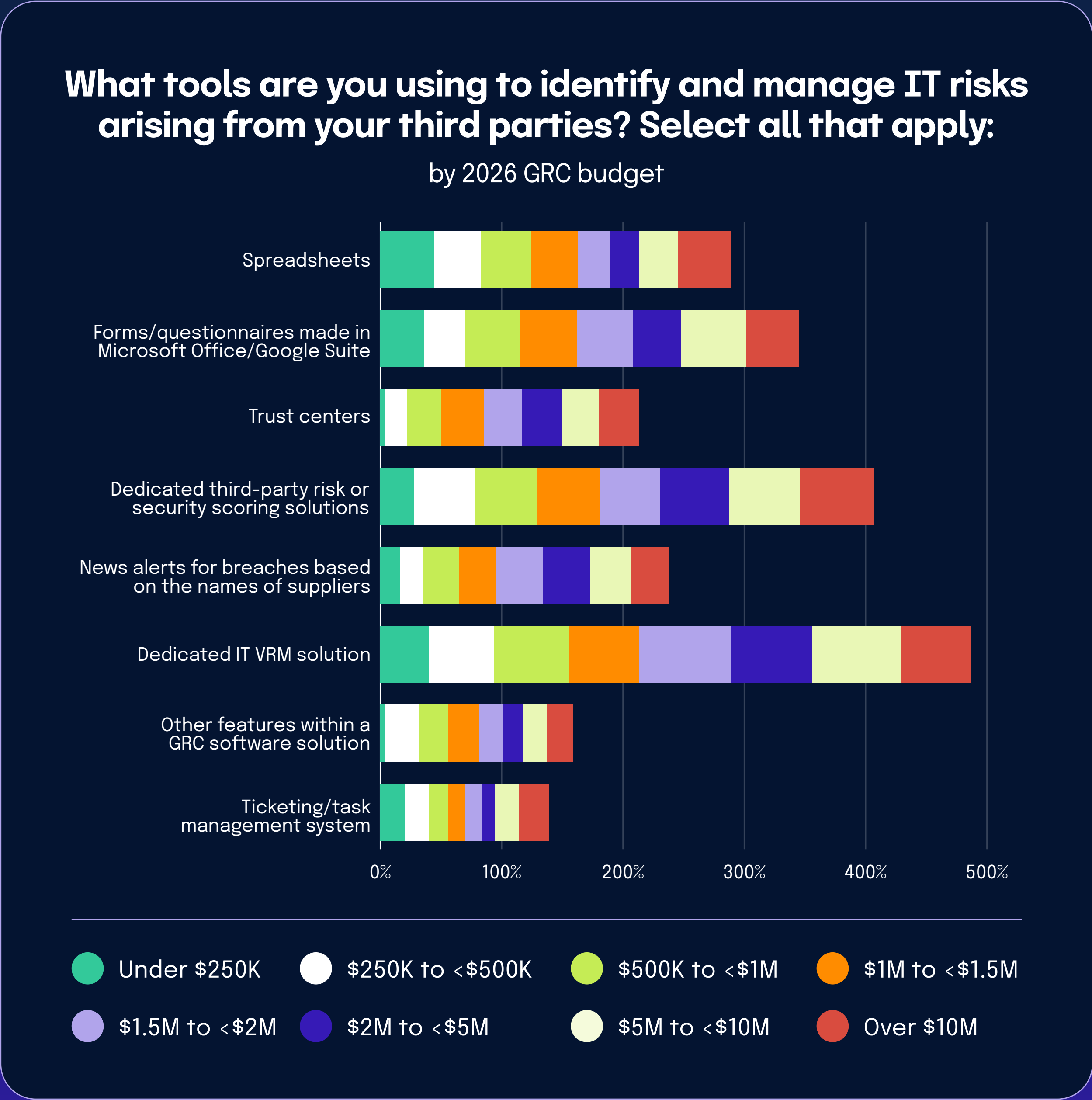
Organizations with a more automated IT risk operating model are significantly more likely to use a dedicated IT VRM solution (73%) than those using an integrated, mostly manual tool (49%). Dedicated VRM tools typically support the operational mechanics of scale: standardized intake, structured assessments, consistent evidence handling, automated reminders, and clearer remediation tracking. In more manual environments, even with an integrated tool, work is often still done in spreadsheets, email follow-ups, and one-off questionnaires, which makes it harder to sustain consistent coverage as vendor counts grow. TPRM maturity is increasingly tied to the ability to run continuous cycles of evaluation and follow-through, which becomes far more feasible when the program invests in purpose-built systems and workflow automation.

What tools are you using to identify and manage IT risks arising from your third parties? Select all that apply:



Even high-budget programs still depend on document-based assessments

Use of forms/questionnaires made in Microsoft Office and/or Google Suite is higher among organizations with \$5M to less than \$10M GRC budgets (53%) than among those with \$250K to less than \$500K budgets (34%). This is an important reminder that higher budgets do not automatically translate into more modern execution. Even well-funded programs may rely on questionnaires because they are familiar, auditable, and easy to deploy quickly across large vendor populations. However, questionnaires can become a scalability constraint when they are not standardized, when evidence is not centrally stored, and when responses are not tied to controls, risk decisions, and remediation workflows. The opportunity for many teams is to treat questionnaires as one input among several, and to reduce friction by centralizing responses, automating follow-ups, and translating vendor-provided artifacts into structured, comparable risk signals.



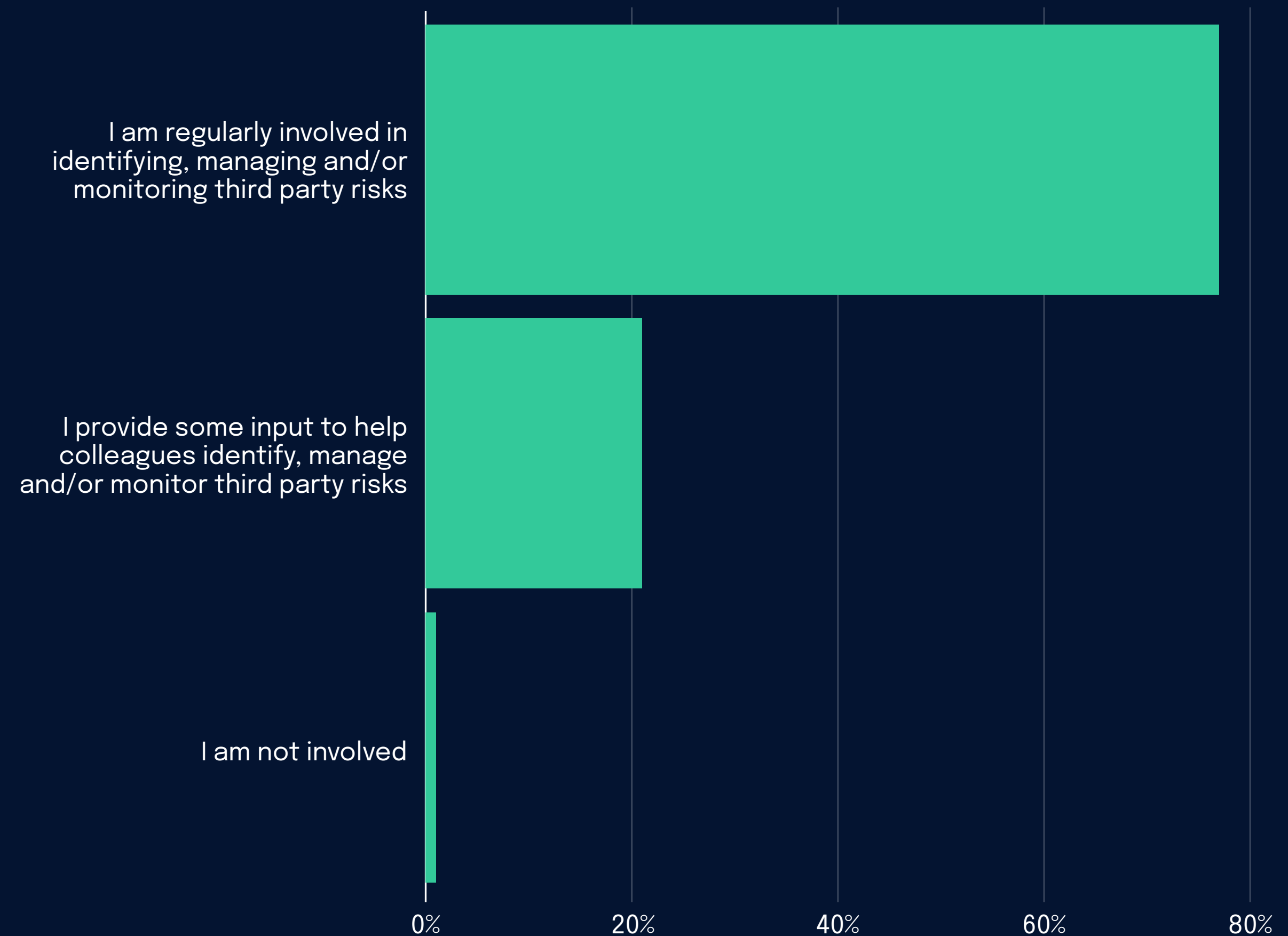
TPRM is a shared responsibility, but ownership varies by operating conditions

Third-party risk is inherently cross-functional, but involvement levels are still meaningful because they reflect whether third-party risk management is treated as a continuous discipline or an occasional checkpoint. The overwhelming majority of respondents report being regularly involved in identifying, managing, and/or monitoring third-party risks, which signals that TPRM is embedded in day-to-day responsibilities for many practitioners.

However, the smaller segments also matter. When respondents describe their involvement as “providing some input” rather than being regularly involved, it often indicates that third-party risk is handled through localized processes or delegated workflows, which can weaken consistency and increase variance in how vendors are evaluated across the organization. Over time, these differences tend to show up as uneven evidence quality, inconsistent remediation tracking, and less predictable audit readiness.

Involvement is a proxy for operational ownership. A program becomes easier to scale when third-party risk management has defined accountability, standardized workflows, and a shared system for tracking vendor risk posture and remediation.

What’s the nature of your involvement with managing third-party/supplier risks within your organization?

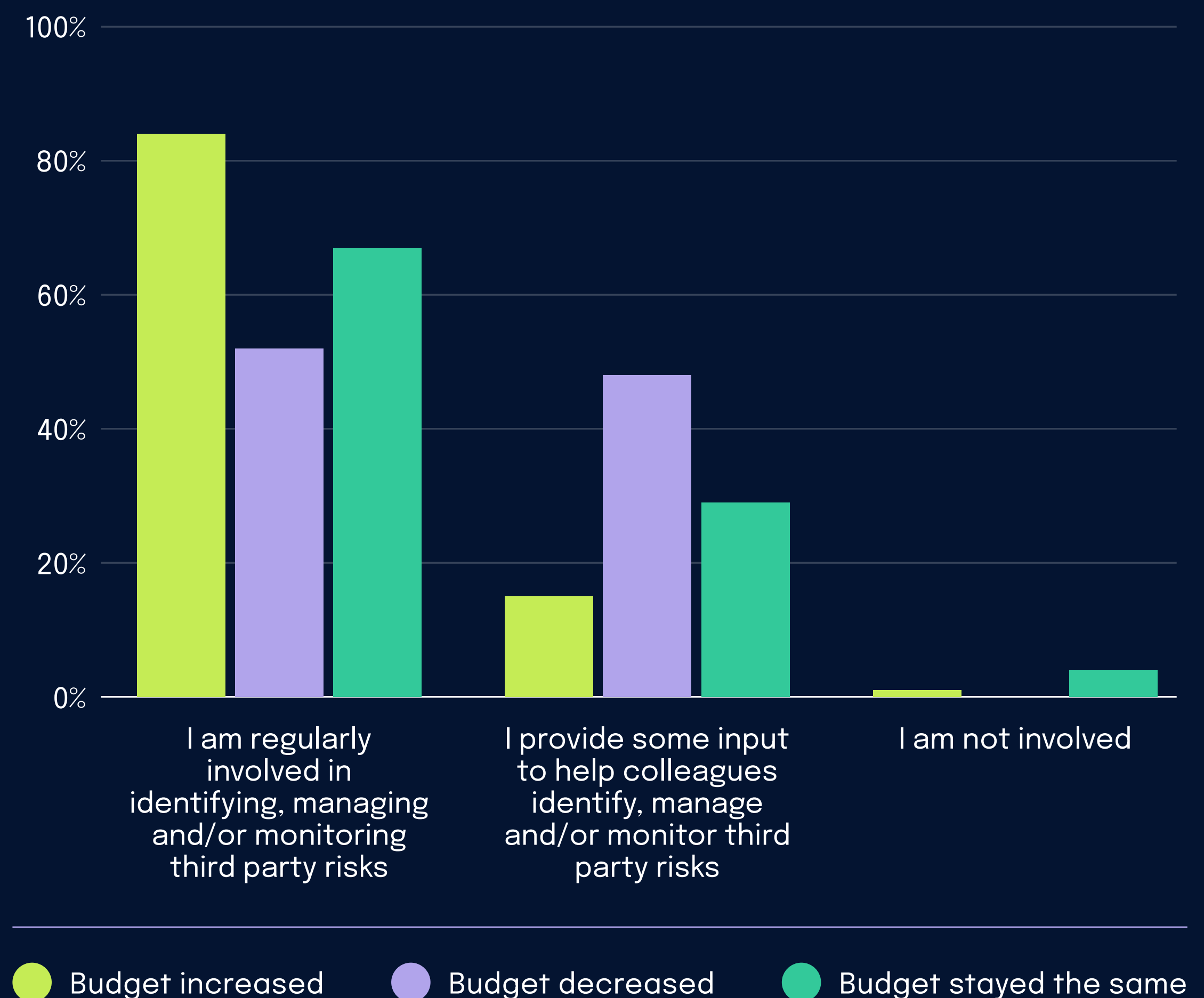


Budget pressure reduces direct ownership of third-party risk work

When budgets decreased, fewer respondents said they are regularly involved in managing third-party risks (52%) compared to when budgets increased (84%), and more respondents reported that they have input but are not directly involved (48% vs 15%). Budget pressure can change the operating model of TPRM, not just the size of the program. When teams are under-resourced, third-party risk work is more likely to be distributed across stakeholders without consistent process ownership, leading to uneven standards and slower remediation follow-through. In practice, it becomes harder to maintain consistent evidence requirements, enforce reassessment cadence, and keep vendor profiles current. The lesson is that even when budgets tighten, organizations still need mechanisms to preserve consistency, often meaning relying more on standardized workflows and automation rather than spreading work across more people in an unstructured way.

What's the nature of your involvement with managing third-party/supplier risks within your organization?

by 2025 GRC budget changes



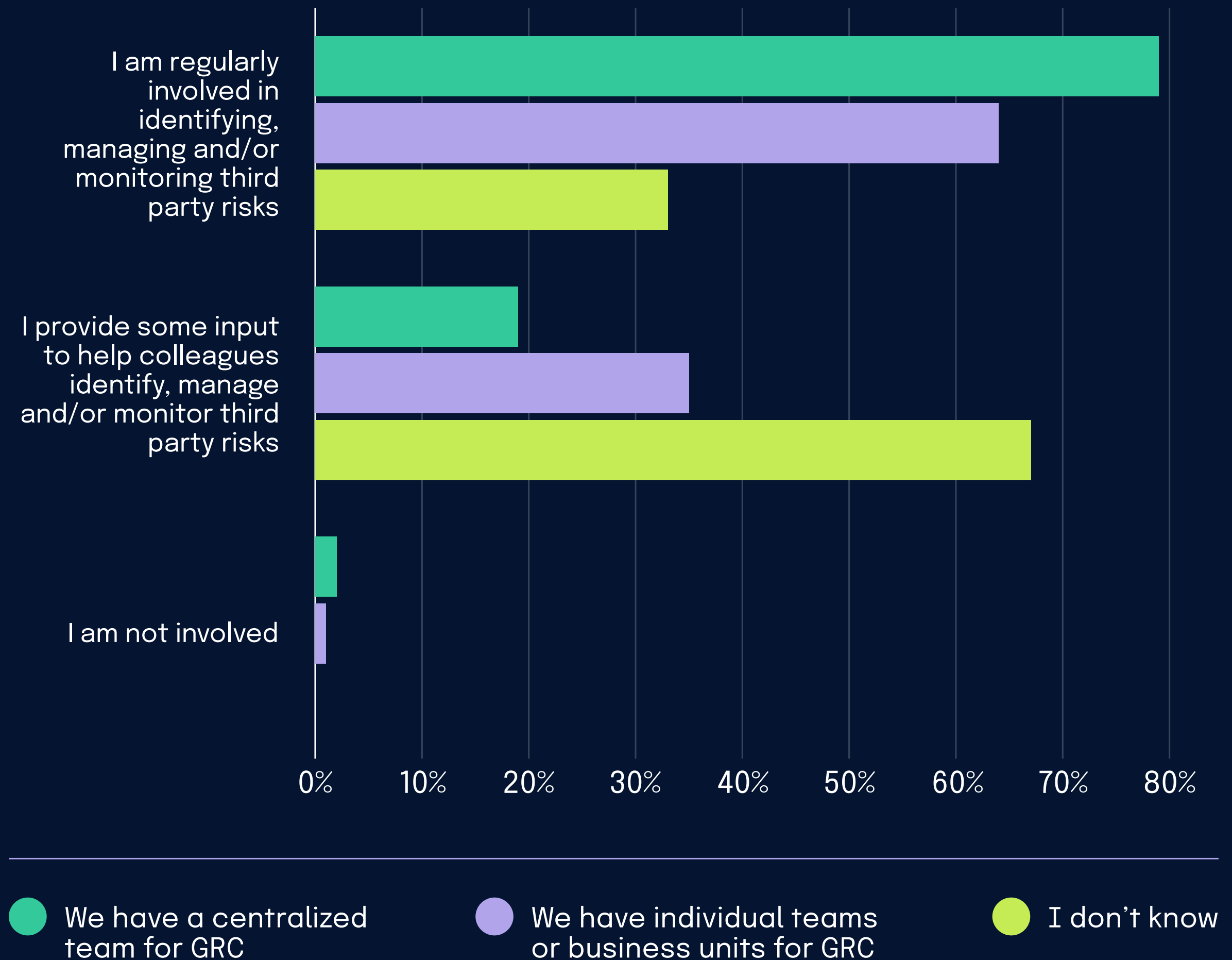
Centralized structures create clearer accountability for vendor risk execution

79% of respondents in centralized programs reported being regularly involved in third-party risk work, compared with only 64% in decentralized structures.

This gap highlights a core advantage of centralization: it makes ownership explicit and makes execution more repeatable. In decentralized structures, third-party risk work often depends on local practices and priorities, which can result in inconsistent assessment depth and documentation quality across business units. Centralized programs tend to define shared standards for evidence, scoring, reassessment cadence, and remediation tracking, which reduces variability and enables clearer reporting. Program structure influences how quickly issues surface, how consistently vendors are evaluated, and how defensible decisions are when auditors or executives ask for proof.

What's the nature of your involvement with managing third-party/supplier risks within your organization?

by GRC program structure



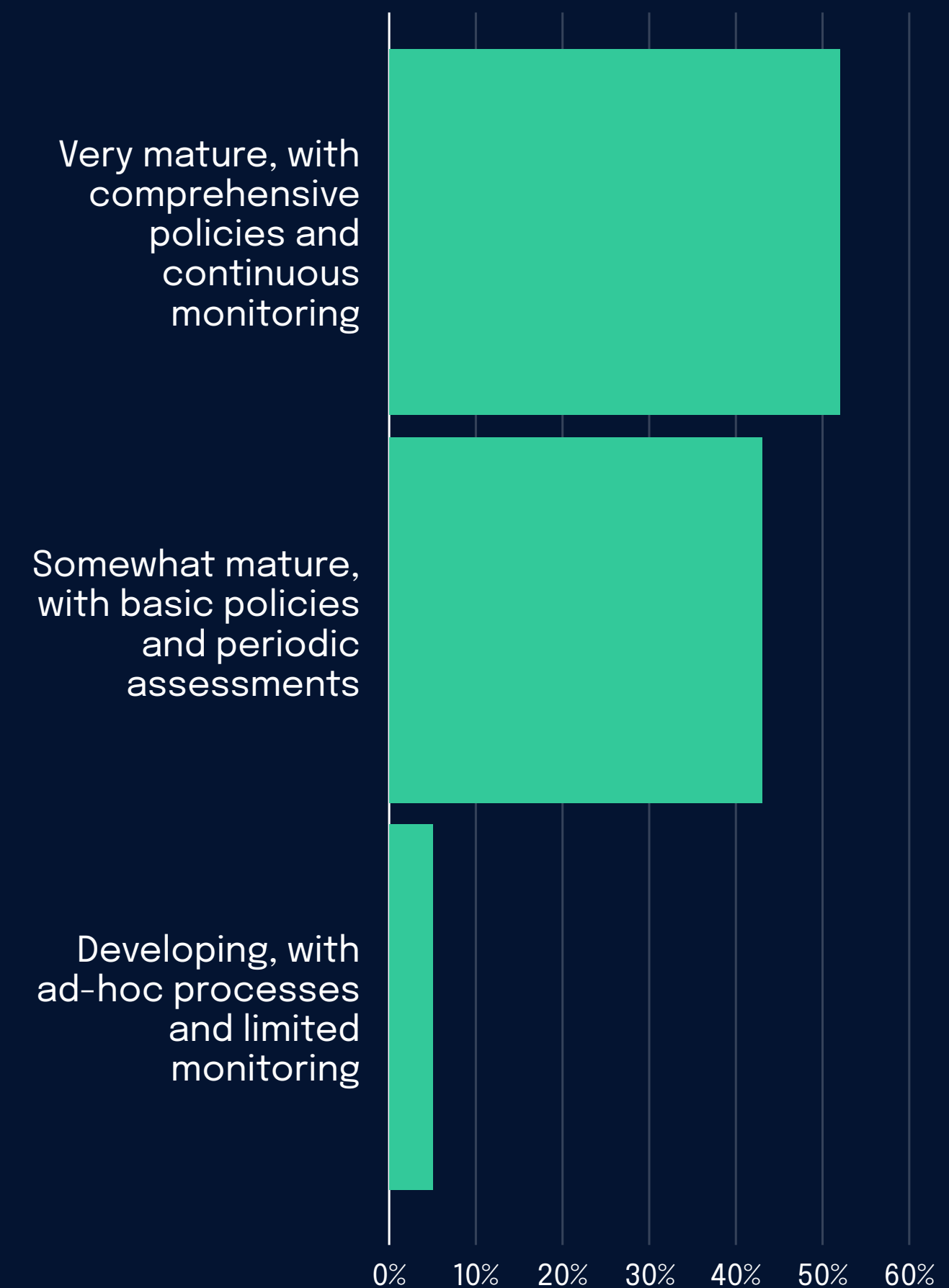
Mature programs are common, but “maturity” depends on monitoring and execution depth

Self-reported maturity is high, with most respondents describing their third-party risk programs as mature. The most important interpretation here is what respondents associate with maturity: not just policies, but monitoring and repeatability. In other words, maturity is increasingly defined by whether organizations can run TPRM as a consistent operating process, not merely whether they have documents and requirements in place.

The hardest parts of TPRM typically appear after onboarding. A vendor's risk profile changes, business usage changes, requirements change, and evidence ages. Programs that only reassess periodically can struggle to keep up with these shifts, especially when the vendor footprint is large. By contrast, programs with continuous monitoring and structured review cycles are more likely to detect drift early and maintain a defensible posture over time.

This is where a SaaS GRC platform can serve as a force multiplier: by connecting vendor risk decisions to control requirements, evidence updates, review cadences, and remediation tracking, teams can reduce repetitive manual follow-up and move from episodic assessments toward continuous readiness.

How would you rate your organization's maturity in managing third-party risks?

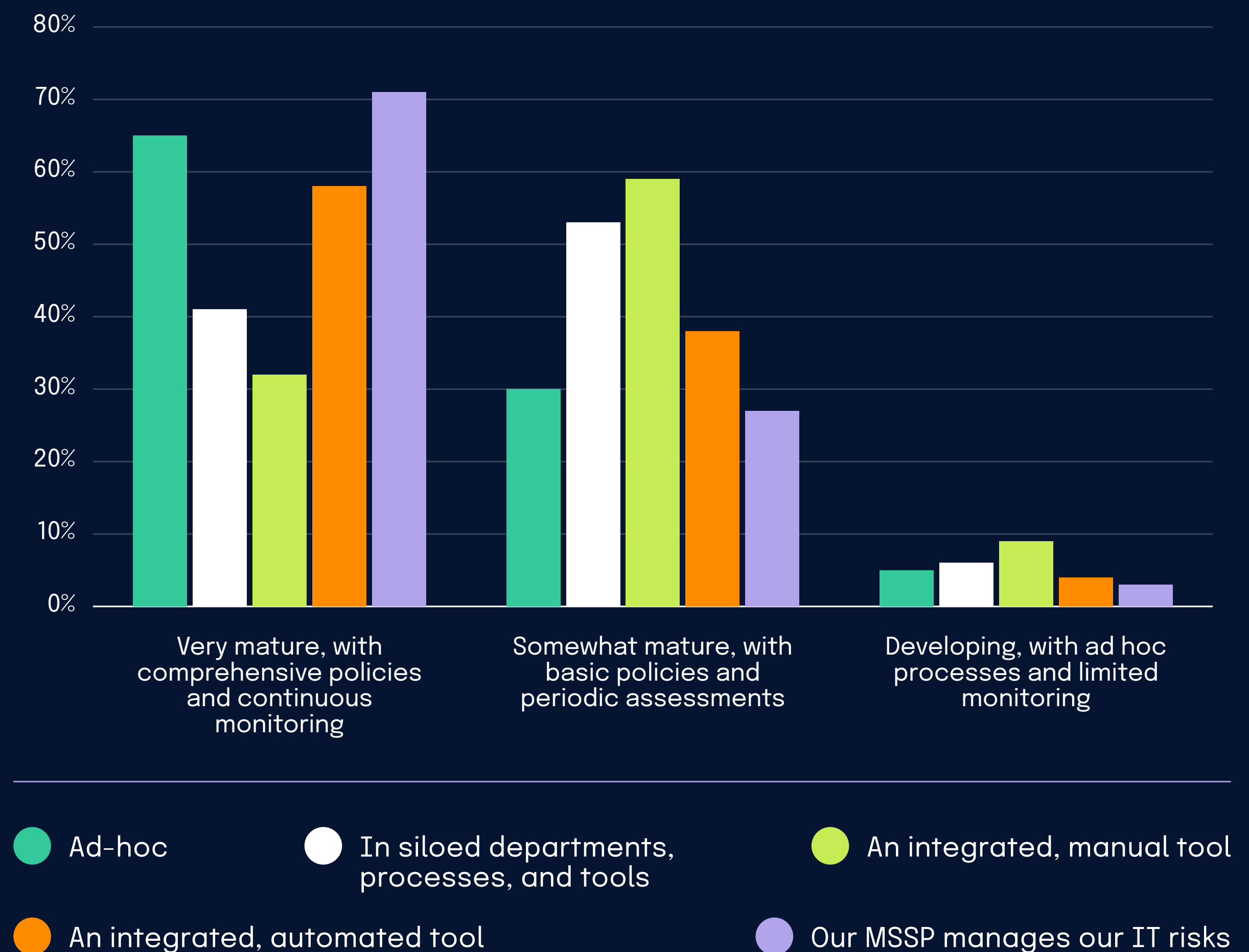


Perceived maturity rises when monitoring and execution are outsourced

Self-reported “very mature” TPRM programs vary widely by operating model. Only 32% of respondents using an integrated, manual tool describe their program as very mature, compared to 71% among those whose IT risks are managed by an MSSP. Maturity is increasingly defined by sustained execution: continuous monitoring, consistent evidence collection, and reliable remediation workflows. A mostly manual model can still be disciplined, but it is harder to keep consistent when vendor populations scale or when vendors’ risk profiles change frequently. MSSP-supported models may also benefit from repeatable playbooks and dedicated capacity for monitoring and response, which can increase confidence in maturity. Ultimately, maturity is not only about policies; it is about whether the program can produce consistent outcomes with predictable effort.

How would you rate your organization’s maturity in managing third-party risks?

by approach to managing IT risks

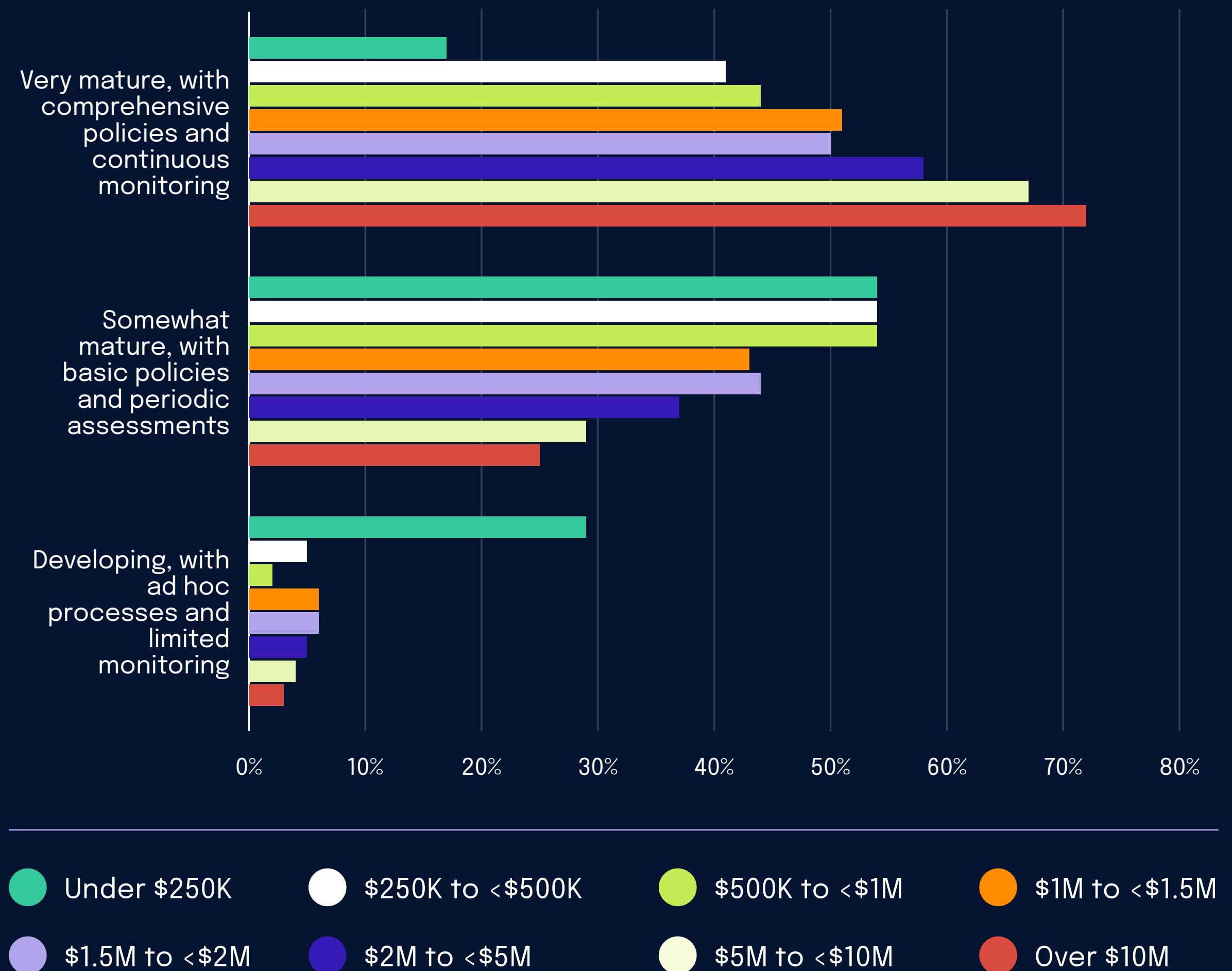


Sustained investment accelerates maturity and continuous monitoring capacity

“Very mature” ratings rise meaningfully with larger 2026 GRC budgets, increasing from 44% among organizations with \$500K to less than \$1M budgets to 72% among those with over \$10M. Deeper maturity often requires sustained investment, particularly when programs move beyond periodic assessments to continuous monitoring and structured reassessment cadence. Larger budgets may support additional personnel, specialized tooling, or external services that improve consistency and coverage. The important nuance is that maturity is not guaranteed by spend; the mechanism is what spend enables: standard operating processes, better evidence capture, stronger reporting, and the capacity to validate and follow up on vendor issues rather than simply collecting documentation.

How would you rate your organization's maturity in managing third-party risks?

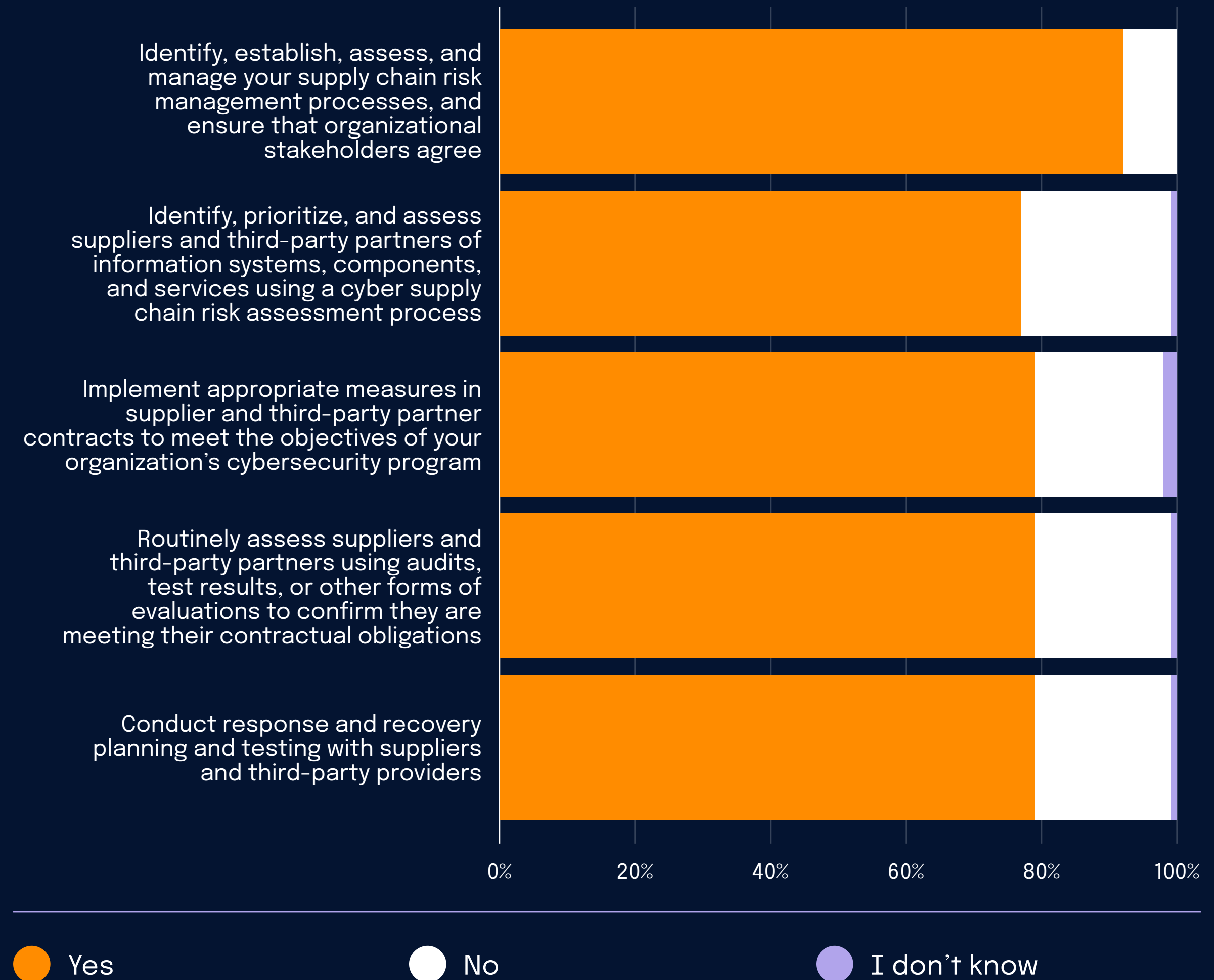
by 2026 GRC budget



Baseline controls are widespread; consistency of execution is the differentiator

The near-universal “yes” response (94%) suggests that baseline third-party cyber risk hygiene is now widely recognized and broadly implemented. The key insight is that best practices have become table stakes; most programs believe they are doing the right foundational activities. The practical question becomes what “engaging in best practices” looks like day to day: whether the practices are consistently applied across all vendors, how often they are refreshed, and whether evidence is maintained in a defensible way. As third-party ecosystems grow, the most common failure mode is not lack of intent but execution drift, where reassessments slip, evidence becomes stale, and remediation is not tracked to completion. The differentiator increasingly becomes operational consistency and the ability to maintain these practices continuously rather than episodically.

Does your organization engage in the following activities to manage cyber risk arising from your suppliers and third-party partners?



When budgets tighten, third-party cyber hygiene becomes harder to sustain

When budgets decreased, the number of respondents answering “No” to following key best practices to reduce third-party risk rises sharply (23%) compared to those whose budgets increased (5%). This suggests that these practices can be vulnerable to resource constraints, particularly because many best practices require recurring effort: reassessments, evidence updates, monitoring, and remediation follow-up.

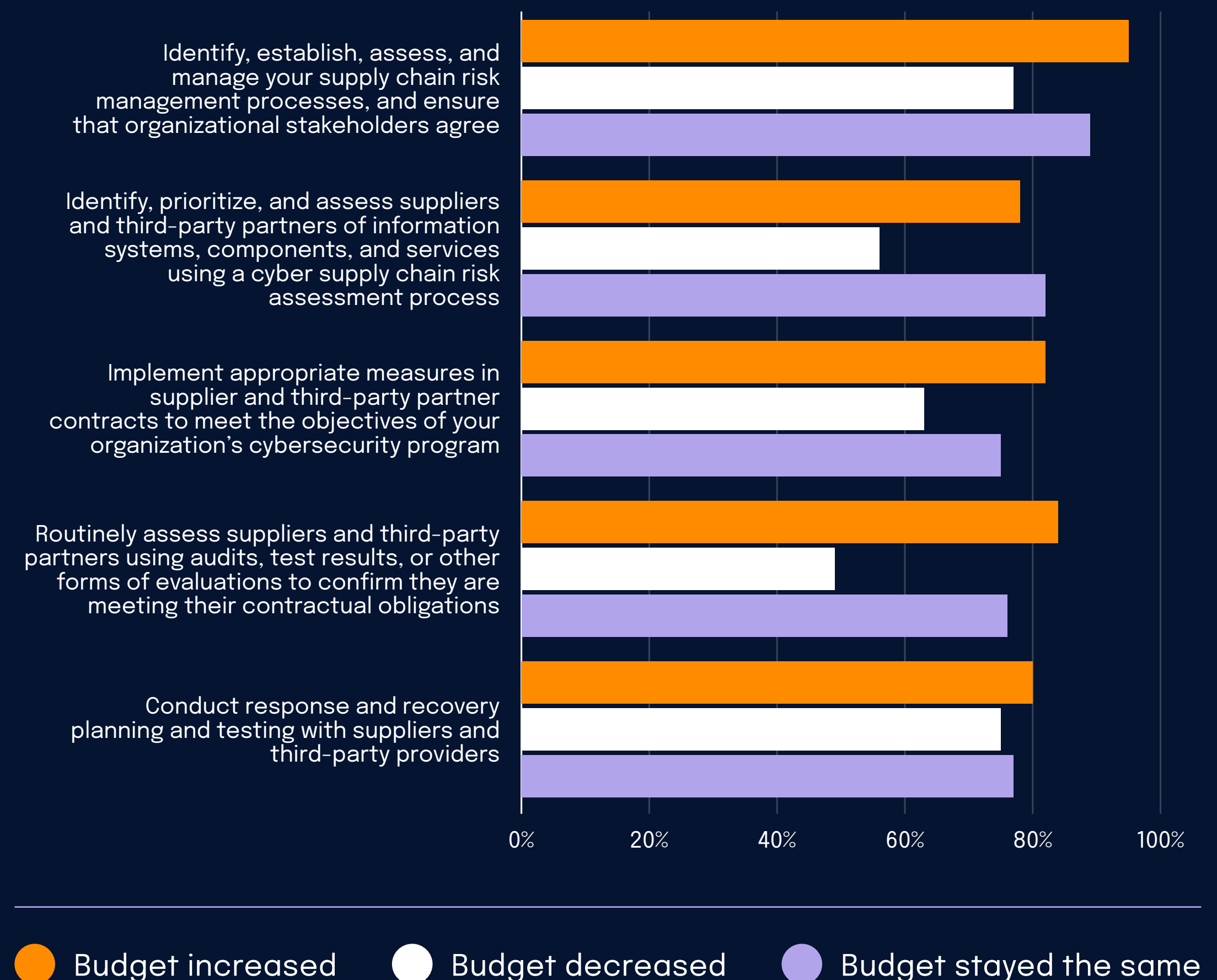
When teams are stretched thin, vendors may receive less frequent attention, fewer requests for updated artifacts, or slower escalation of risk issues. This makes a strong case for

reducing reliance on manual coordination through standardized processes and automation, especially for high-volume vendor ecosystems. In constrained environments, organizations benefit from focusing coverage on the most critical vendors while using tooling to maintain lightweight monitoring across the broader supplier base.

Does your organization engage in the following activities to manage cyber risk arising from your suppliers and third-party partners?

by budget changes in 2025

A: Yes



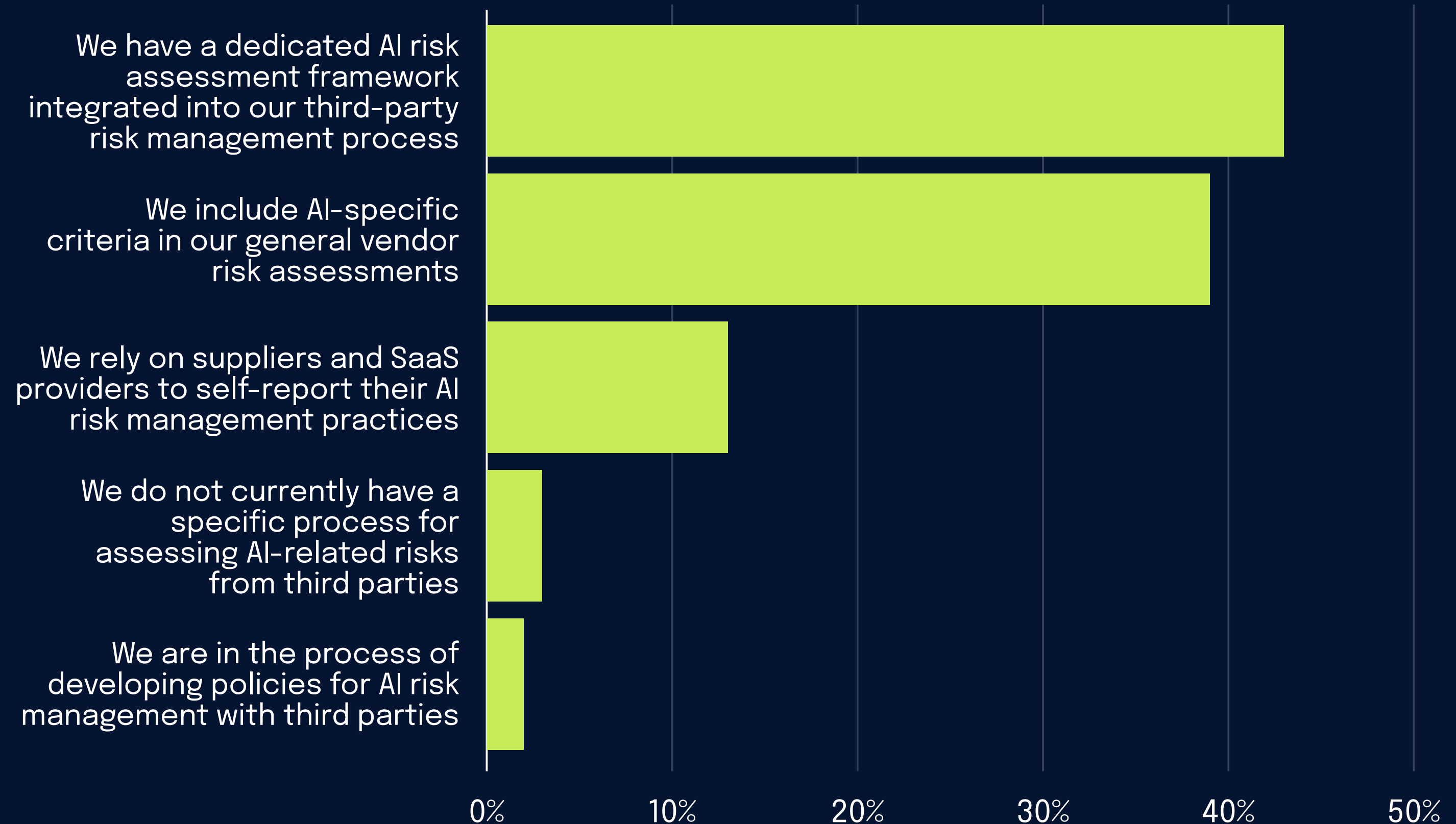
AI risk from suppliers is becoming operationalized, but approaches are still maturing

AI-related third-party risk is no longer theoretical. Many organizations report they have incorporated AI risk into their vendor assessment processes, either through a dedicated framework or by adding AI-specific criteria to general assessments. This is an important signal that third-party risk programs are expanding their scope to reflect real technology changes in the supplier ecosystem.

The nuance is that approaches vary. A dedicated AI risk framework implies deeper operationalization: defined criteria, repeatable evaluation steps, and clearer expectations for evidence and monitoring. Adding AI criteria into general assessments can be a pragmatic step toward consistency, but it can also remain shallow if teams lack standardized artifacts, accountability, or the ability to validate supplier claims over time. Reliance on self-reporting poses an additional challenge: AI risk is difficult to evaluate solely through documentation, especially as models, data practices, and vendor architectures evolve.

For many teams, the near-term opportunity is to standardize AI risk expectations and ensure they are measurable and enforceable. SaaS GRC tooling helps by centralizing vendor AI risk evidence and linking it to policies, control requirements, and review cadences, so AI risk becomes a managed workflow rather than a one-time questionnaire response.

How does your organization assess and manage risks associated with AI technologies provided by suppliers or SaaS providers?

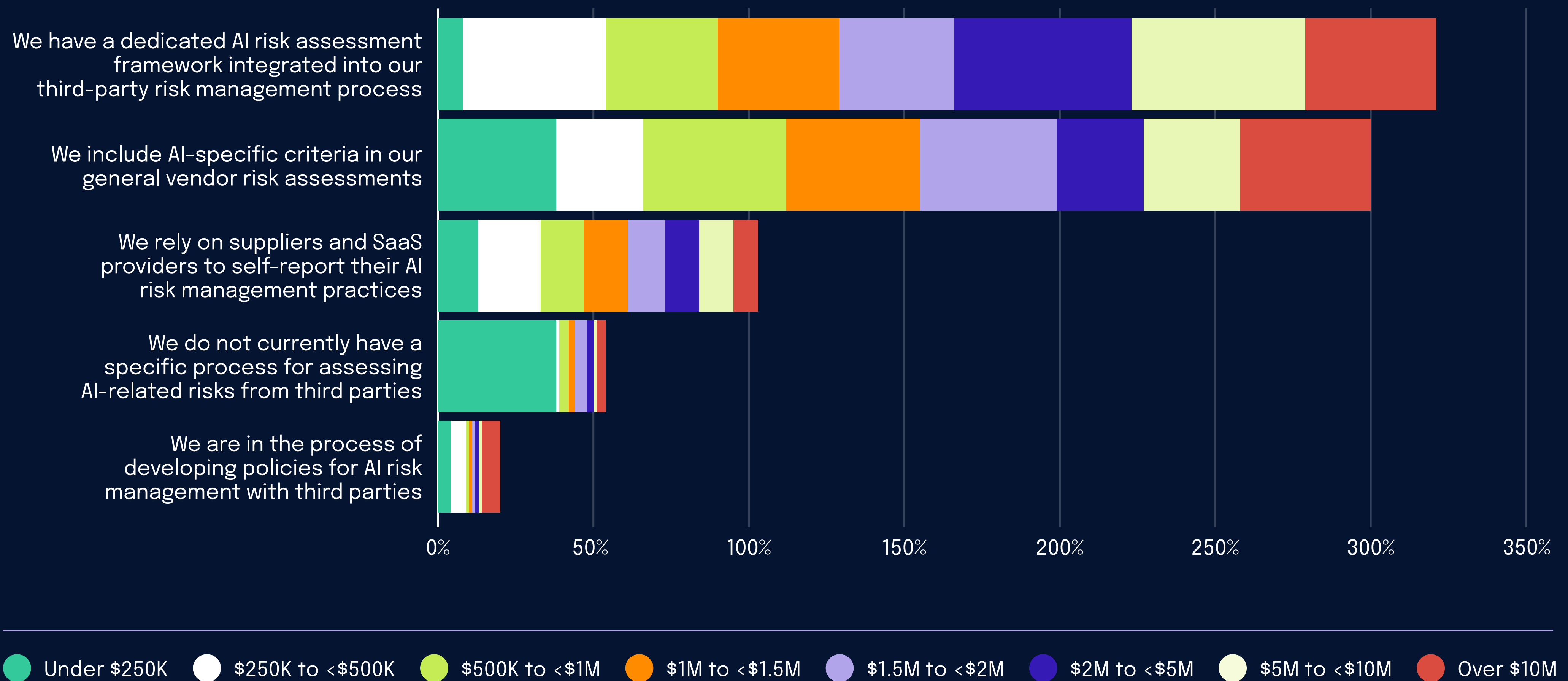


Formal AI risk governance is more common where resourcing supports validation

Dedicated AI risk frameworks increase from 36% in the \$500K to less than \$1M budget band to 57% in the \$2M to less than \$5M band. This suggests that formal AI supplier risk governance requires more than a policy statement; it requires the operational ability to request evidence, perform validation, and maintain ongoing oversight. Higher budget bands may have more flexibility to invest in specialized assessment criteria, AI-related vendor due diligence, and tooling that supports evidence capture and reassessment. For many organizations, the near-term opportunity is to define a practical, enforceable baseline for AI risk that can be embedded into vendor workflows without creating a bottleneck.

How does your organization assess and manage risks associated with AI technologies provided by suppliers or SaaS providers?

by 2026 GRC budget



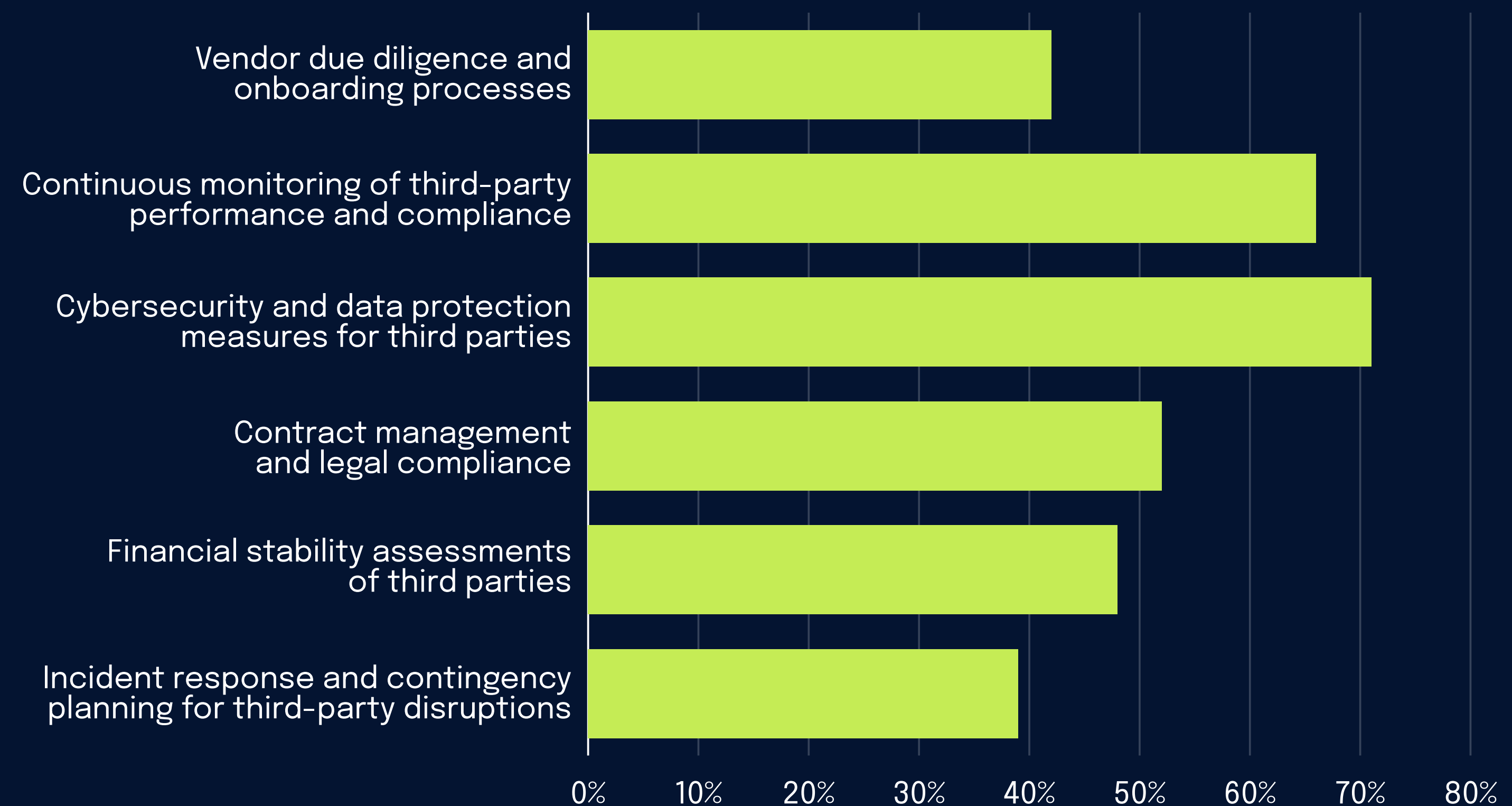
Priorities point to a shift from onboarding checklists to ongoing assurance

When organizations describe what they prioritize in third-party risk management, the emphasis is clearly moving toward ongoing assurance rather than one-time gatekeeping. Cybersecurity, data protection, and continuous monitoring appear as leading priorities, reinforcing that organizations are trying to maintain confidence in vendors over time, not simply approve them at onboarding and hope conditions remain stable.

This shift makes sense as vendor ecosystems expand. More vendors means more evidence, more renewals, and more risk events to evaluate. Programs that prioritize monitoring are effectively acknowledging that TPRM is a lifecycle discipline. The operational question becomes whether teams have the tooling and processes to sustain that lifecycle without creating bottlenecks for procurement, security, and business stakeholders.

A platform-based approach supports this priority shift by making continuous monitoring outputs, periodic reviews, and remediation workflows easier to manage in one place, improving consistency while reducing administrative overhead.

Which areas of third-party risk management does your organization currently prioritize?

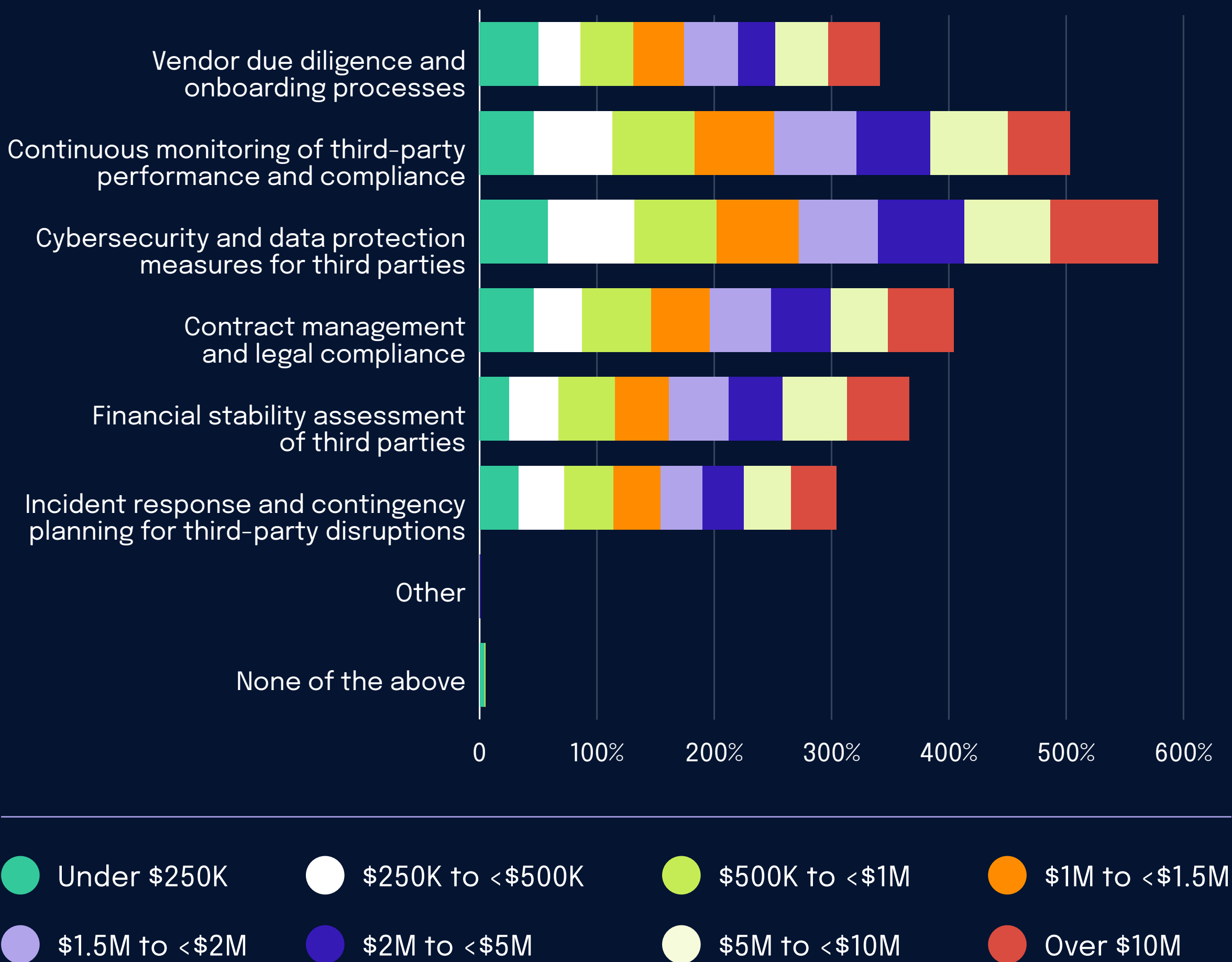


The largest programs prioritize vendor cyber controls as a continuous requirement

Prioritization of cybersecurity and data protection measures for third parties increases with budget scale, rising from 67% in the \$1.5M to less than \$2M band to 92% in the over \$10M band. This indicates that the largest programs are treating vendor cyber controls as a continuous governance focus rather than a periodic compliance exercise. Larger programs often support a wider third-party footprint and higher-risk processing of sensitive data, making vendor cybersecurity posture more central to enterprise risk management. The practical implication is that as budget and scope grow, TPRM shifts from “collect evidence” to “maintain assurance,” which depends on continuous monitoring, structured control expectations, and clear remediation workflows.

Which areas of third-party risk management does your organization currently prioritize?

by 2026 GRC budget



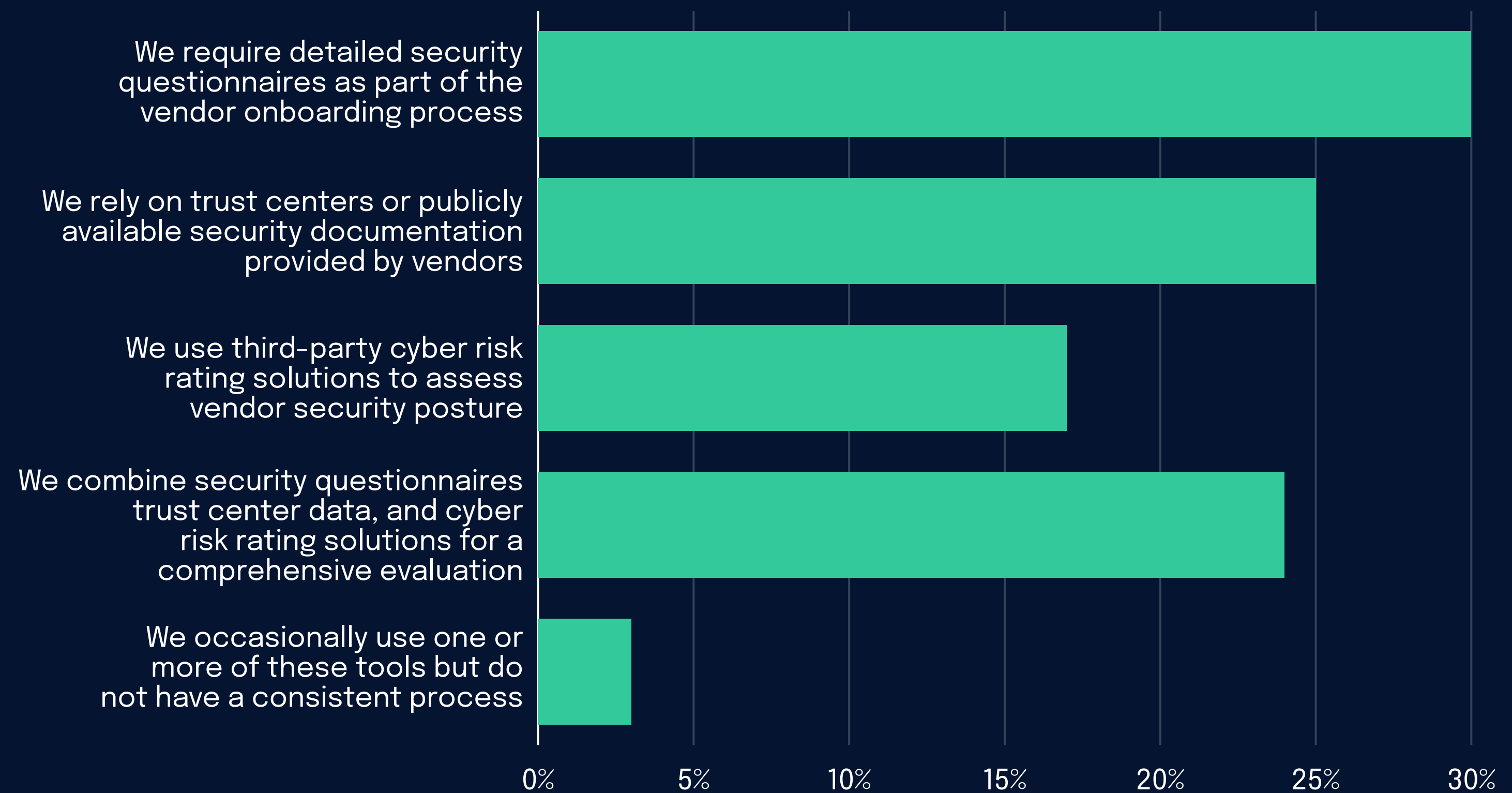
Vendor evaluation is becoming multi-sourced, but consistency remains the differentiator

Organizations increasingly use multiple sources of information to evaluate vendors: security questionnaires, trust centers, and cyber risk ratings each offer different strengths. The most mature evaluation approach is not necessarily choosing one method; it is building a consistent process that blends sources in a structured way and ties them to clear risk decisions and remediation expectations.

Reliance on questionnaires alone can lead to delays and inconsistent quality, especially if reviewers interpret responses differently across vendors. Trust centers can speed the collection of baseline artifacts, but they vary in completeness and update frequency. Cyber risk ratings can add continuous external signals but should be contextualized and validated against how the vendor is actually used inside the organization.

The operational advantage comes from consistency and traceability: a repeatable approach to collecting inputs, mapping them to requirements, recording decisions, tracking remediation, and maintaining audit-ready evidence. This is where SaaS GRC platforms provide leverage, because they support standardization at scale while keeping vendor evaluations connected to the broader compliance and risk program.

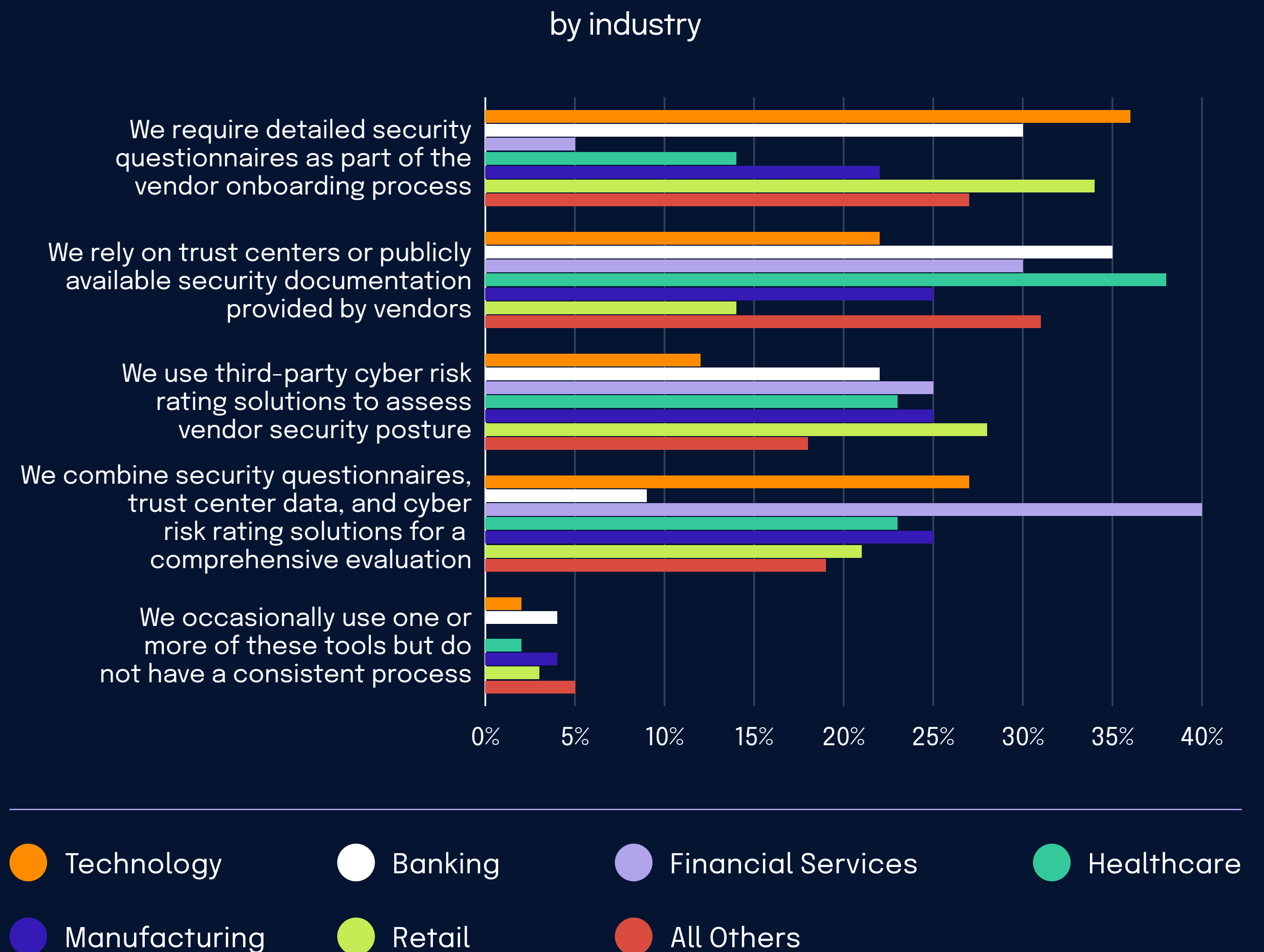
How does your organization utilize security questionnaires, trust centers, or third-party cyber risk rating solutions when evaluating vendors or SaaS providers?



Some industries lean on standardized vendor artifacts to scale evaluations

Healthcare respondents are significantly more likely to rely on trust centers or publicly available vendor security documentation (38%) than Retail (14%). This likely reflects the intensity of assurance expectations in Healthcare, where teams may need to evaluate many vendors quickly and consistently while maintaining evidence for audit and compliance purposes. Trust centers can reduce the time spent requesting baseline artifacts and provide a standardized starting point for evaluation. The operational risk is that trust centers vary in completeness and freshness, so reliance on them works best when paired with defined requirements for updates, supplemental documentation for higher-risk vendors, and clear internal standards for what constitutes sufficient evidence.

How does your organization utilize security questionnaires, trust centers, or third-party cyber risk rating solutions when evaluating vendors or SaaS providers?

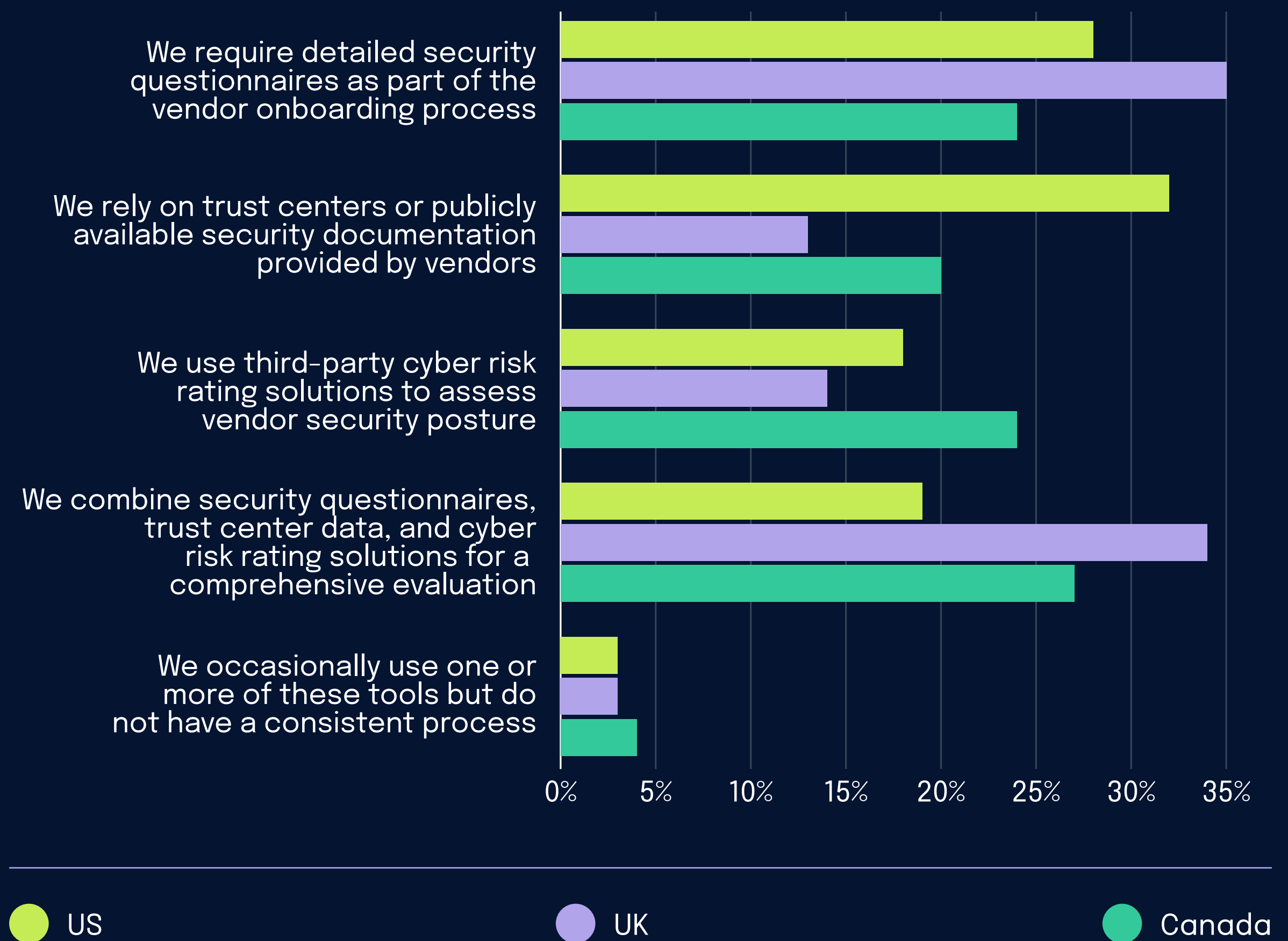


Regional differences influence how vendor assurance evidence is sourced

Reliance on trust centers is higher among US-headquartered organizations (32%) than UK-headquartered organizations (13%). This suggests meaningful differences in how vendor assurance workflows are operationalized across regions, including what evidence sources teams consider acceptable for baseline validation. Evaluation methods tend to reflect both external expectations and internal process maturity. Trust centers can be a strong accelerator when they are integrated into a repeatable workflow that captures evidence, maps it to requirements, and triggers follow-up when documentation is incomplete or outdated. Without that structure, trust centers may reduce friction early but leave gaps in defensibility later when proof is required.

How does your organization utilize security questionnaires, trust centers, or third-party cyber risk rating solutions when evaluating vendors or SaaS providers?

by company headquarters



CHAPTER 5

Decision Power in GRC: Ownership, Oversight, and Organizational Readiness

GRC decision-making has become more consequential – and more visible – than it was even a few years ago. Risk and compliance leaders are no longer making choices solely to satisfy auditors or check regulatory boxes. They are making decisions that directly affect how quickly the business can onboard vendors, enter new markets, meet customer assurance demands, and respond when something goes wrong. In this environment, the structure of decision-making, who holds oversight, and how teams are staffed are not internal details. They shape how effectively an organization can maintain readiness and prove it under scrutiny.

This year's data suggests a clear tension at the center of many programs. Decision authority is often concentrated in a small set of leaders, which can enable speed and accountability. At the same time, GRC execution increasingly depends on distributed participation across IT, security, legal, procurement, and business owners who must provide evidence, perform control activities, and respond to issues on tight timelines. When governance and operating structure are clear, this distribution becomes manageable through standardized workflows and consistent evidence practices. When governance is unclear, distribution becomes fragmentation, leading to inconsistent control application, heavier follow-up burden, and slower reporting.

Organizations are planning for continued growth in compliance capacity, reflecting the expectation that risk and compliance work will require sustained effort in 2026 and beyond. However, growth introduces its own operational challenges. Larger teams and broader programs require stronger process discipline, clearer ownership, and systems that make day-to-day work repeatable. Without that structure, scaling can increase coordination cost rather than increasing throughput and consistency.

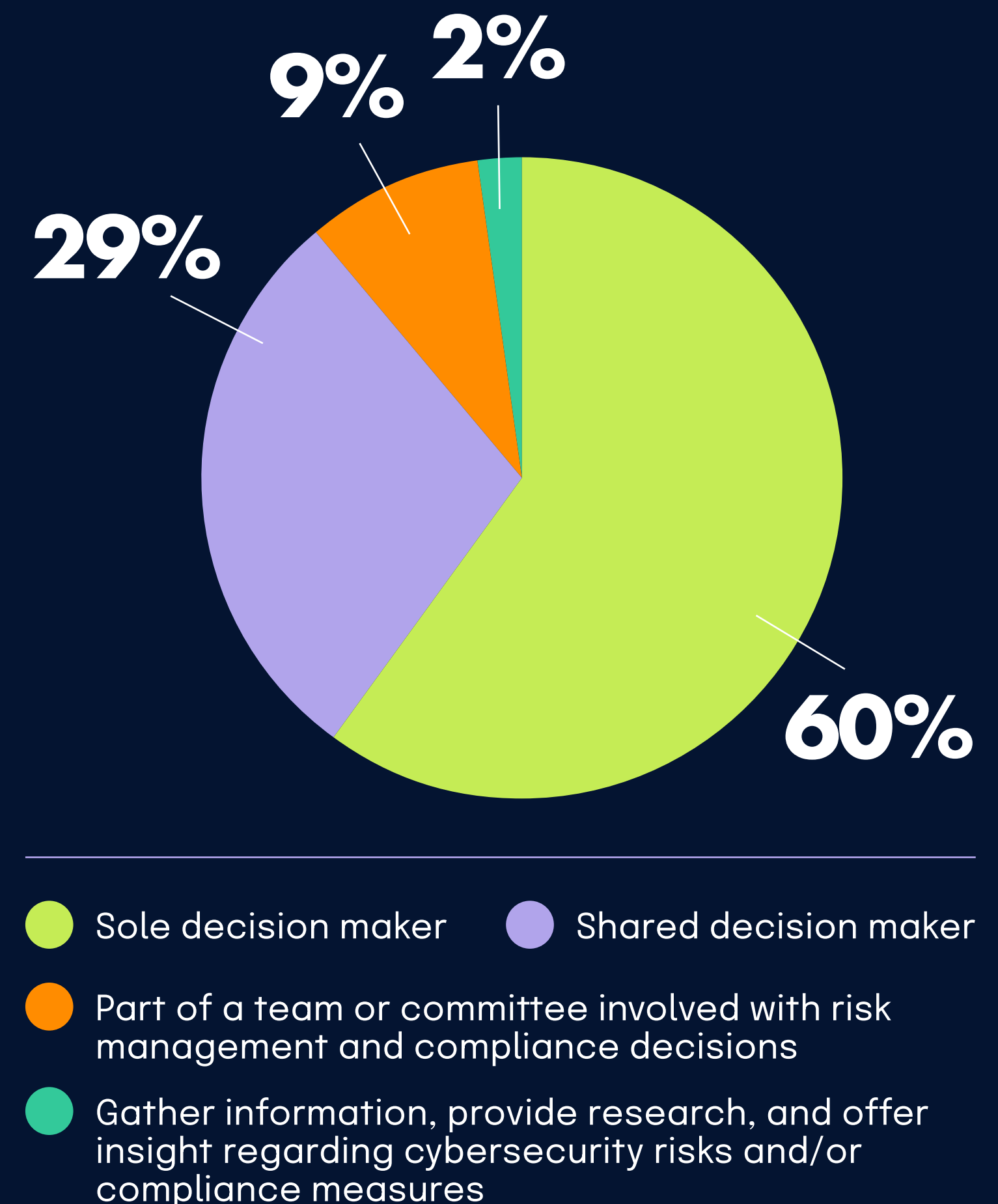
GRC technology decisions are rarely made by one person in isolation. Even where one role holds primary responsibility, buying decisions typically reflect a committee dynamic with distinct champions, influencers, and financial approvers. The most effective organizations treat this as an advantage: they align stakeholders around a shared definition of success, connect investments to measurable outcomes, and choose operating models and tools that support standardization at scale.

Decision ownership is concentrated, but complexity creates buying committees

Many respondents play a primary role in cybersecurity and risk management decisions. In practice, this concentration of decision ownership can be a strength: it enables faster prioritization, clearer accountability, and more consistent direction across the program. It also reflects the reality that risk and compliance decisions often require a single point of authority to balance business needs, regulatory requirements, and security constraints.

However, the presence of shared decision-making and committee-based involvement signals an equally important reality. As programs scale, decisions about risk and compliance tooling tend to involve multiple perspectives because the outcomes affect multiple parts of the organization. A platform decision touches compliance operations, audit readiness, security controls, IT workflows, and procurement processes. This is why the most effective programs align stakeholders early around what success looks like: standardized processes, consistent evidence capture, clear reporting, and measurable improvements in readiness and workload reduction.

Which best describes your involvement in decisions regarding cybersecurity and risk management for your organization?

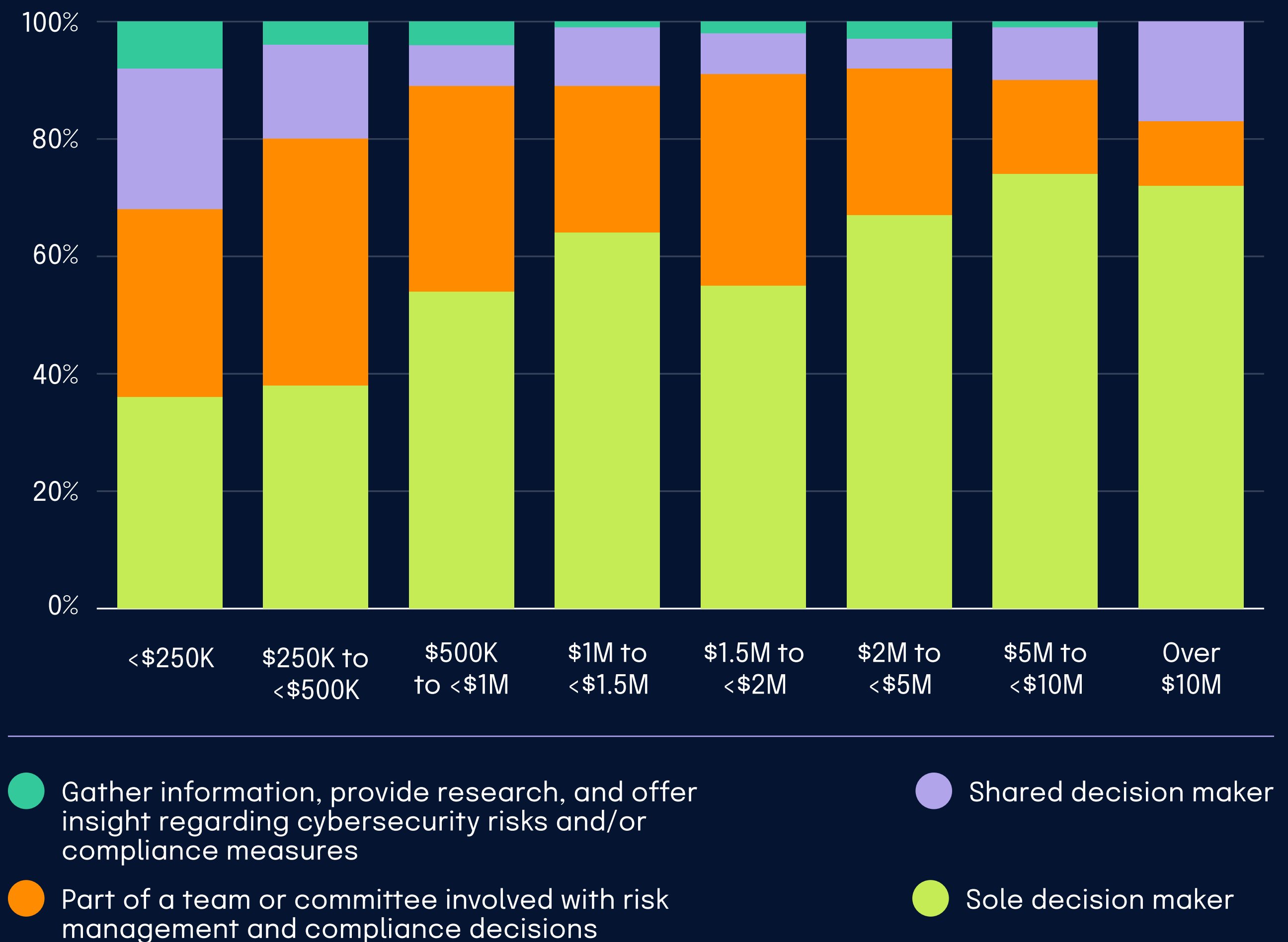


As budgets grow, decision authority becomes more centralized

Decision authority becomes more concentrated as budgets increase. Among respondents with GRC budgets of \$250K or less, only 36% say they are the sole decision-maker, with the rest split between shared decision-making (32%) and team or committee (24%). In the largest budget bands, the pattern flips: respondents reporting being a sole decision maker rise to 74% in the \$5M to less than \$10M segment and remain high at 72% in the \$10M+ segment, while “shared decision maker” drops to 16% and 11%, respectively. Higher-spend programs tend to have clearer centralized decision authority, which can speed technology adoption and standardization, whereas lower-spend programs more often rely on consensus and committee dynamics that can extend decision cycles.

Which best describes your involvement in decisions regarding cybersecurity and risk management for your organization?

by 2026 GRC budget



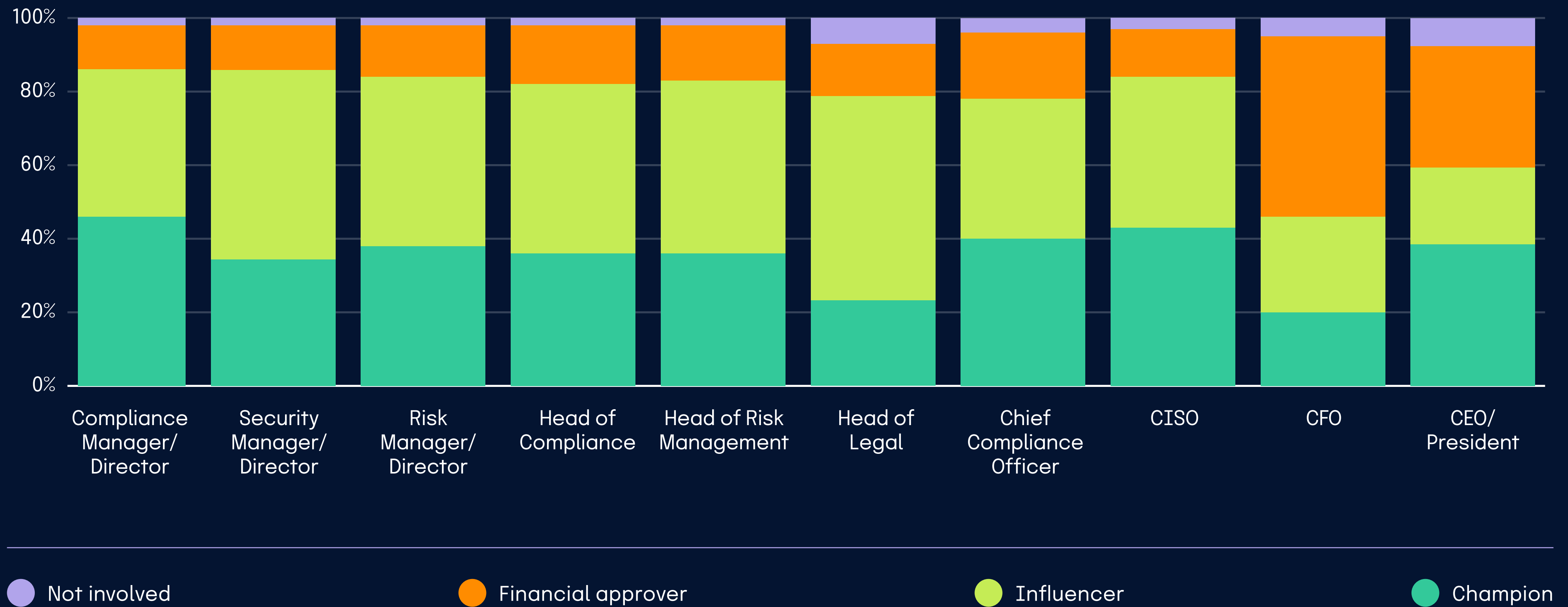
The buying committee is clear, with distinct champions, influencers, and financial approvers

When respondents describe who is involved in buying compliance or risk technology, a consistent pattern emerges: organizations tend to have clear champions, clear influencers, and clear financial approvers. This is important because it highlights that buying decisions are rarely one-dimensional. Even when a single leader owns the decision, the purchase is typically shaped by operational users, security leadership, and finance.

For practitioners, the key implication is that successful technology decisions require alignment on both outcomes and adoption. Champions often focus on solving operational pain, influencers often evaluate fit and risk reduction, and financial approvers assess ROI and consolidation opportunities. The strongest buying cases connect these priorities. They tie day-to-day execution improvements, such as reduced manual work and faster evidence collection, to defensible outcomes leadership cares about: readiness, consistency, and reduced exposure.

Organizations that treat these as separate conversations often struggle with adoption later. Programs that align on a shared operating model and common requirements before purchase are better positioned to implement efficiently and demonstrate measurable gains after the platform is in place.

Who are the decision-makers involved when buying compliance or risk technology?



Roles the C-Suite plays in decision-making

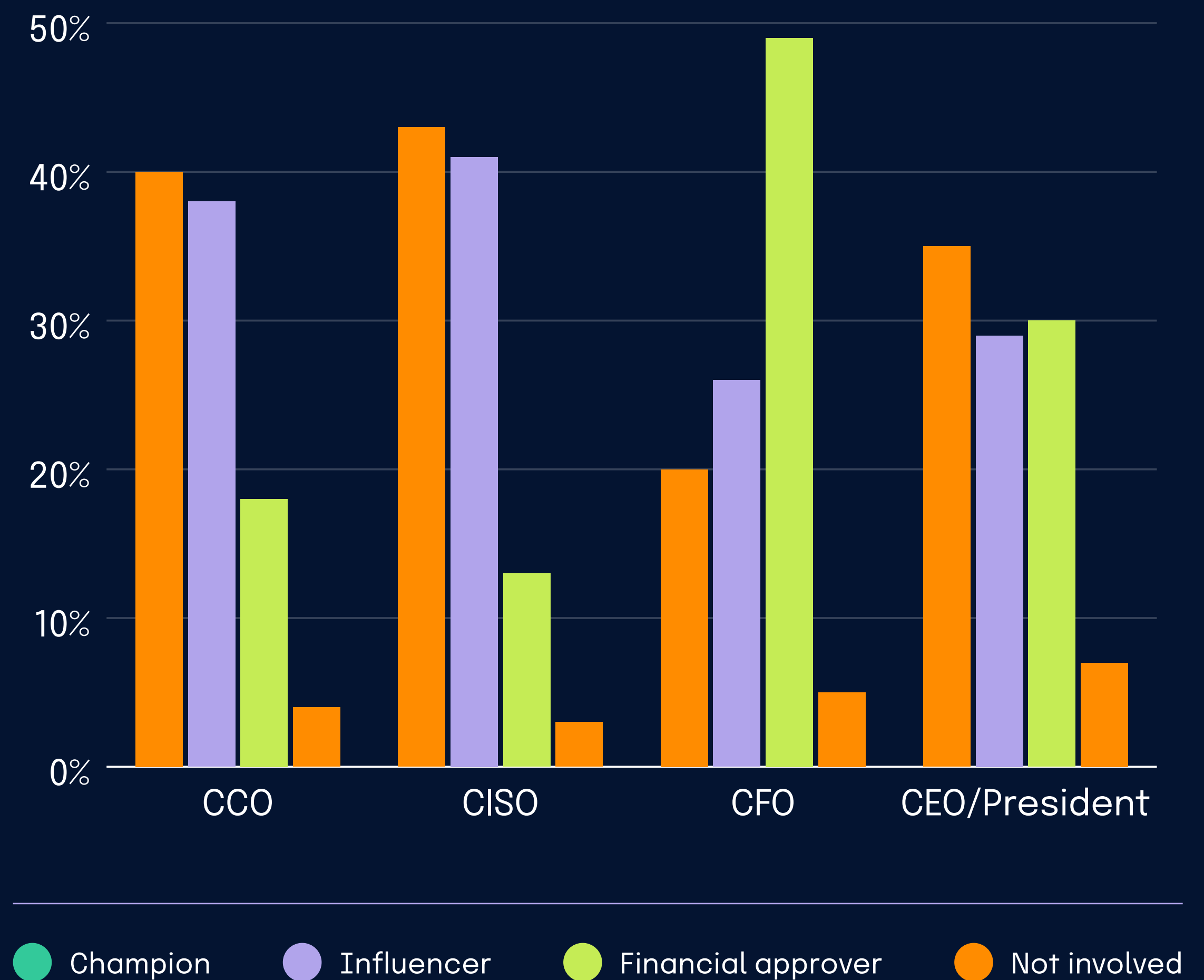
The Chief Information Security Officer (CISO) is most frequently positioned as a driver of change, serving as either a champion (43%) or an influencer (41%), with relatively fewer cases where they are the financial approver (13%). This reinforces a consistent buying reality: security leadership often defines requirements and validates risk outcomes, but budget approval usually sits elsewhere. In practice, this means the strongest business cases link security outcomes to measurable operational impact, so the CISO's priorities translate cleanly into an approver-ready justification.

The Chief Financial Officer (CFO) is the clearest financial gatekeeper in the buying committee: financial approver (49%), versus influencer (26%) and champion (20%). ROI, consolidation, and cost defensibility are central to closing a purchase, even when the functional need is clear. It also means that programs that can articulate reduced manual effort, faster audit readiness, and fewer last-minute escalations tend to have an easier path to approval.

CEO/President involvement is more evenly distributed across being a champion (35%), an Influencer (29%), and a financial approver (30%). Executive leadership is often directly engaged in governance decisions, especially when risk and compliance tooling is tied to broader priorities like customer assurance, market expansion, or resilience. In other words, when these purchases are framed as business enablers rather than internal tooling, executive sponsorship becomes more common.

The Chief Compliance Officer (CCO) is primarily an execution leader and requirements setter, most commonly serving as a champion (40%) or influencer (40%), and less often as a financial approver (15%). This aligns with the operational role many compliance leaders play: owning day-to-day program performance and accountability, while working with finance or executive leadership for final approval. For adoption success, the CCO's influence is critical because they often define the process standards that determine whether a tool becomes a true system of record.

Who are the decision-makers involved when buying compliance or risk technology? (C-suite only)

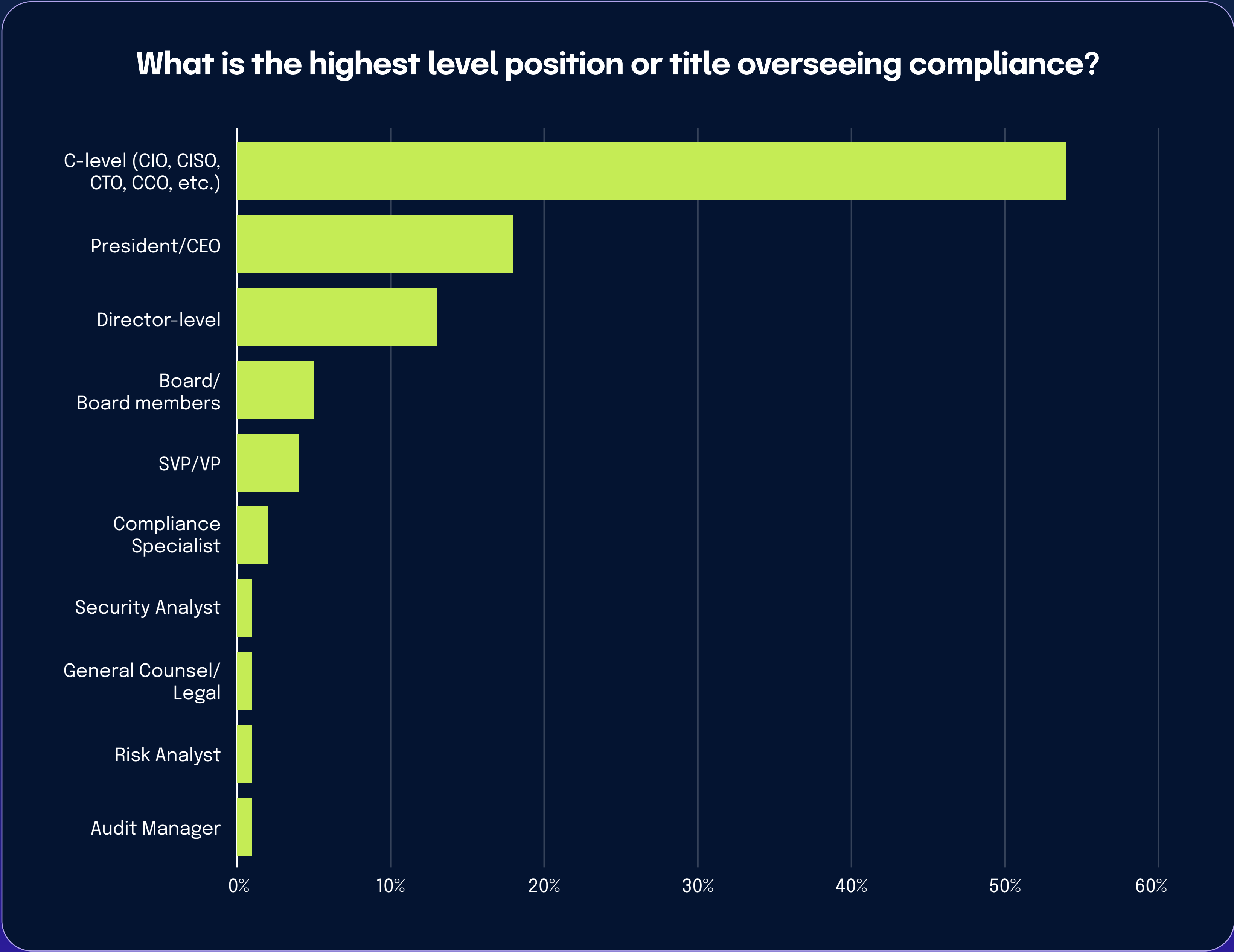


Oversight sits high, but the “highest level owner” varies by organization profile

Oversight of compliance and risk management often sits at senior levels, which reflects the strategic importance of trust and defensibility. Senior oversight can help prioritize investments, break cross-functional bottlenecks, and ensure that compliance and risk work receive the organizational attention they require. It also signals that compliance is increasingly treated as a business risk issue, not simply a technical requirement.

At the same time, where oversight is placed influences how programs operate. When oversight is clearly assigned and connected to a centralized operating model, programs are more likely to set standard expectations for controls, evidence, and reporting. Where oversight is less defined or varies across business units, it is more common to see fragmented processes and inconsistent documentation standards, which creates variability in readiness and greater manual effort for teams trying to consolidate information for leadership.

Governance is not just an org chart decision. It shapes how accountability works, how standards are enforced, and how consistently the organization can demonstrate readiness across business units and regions.

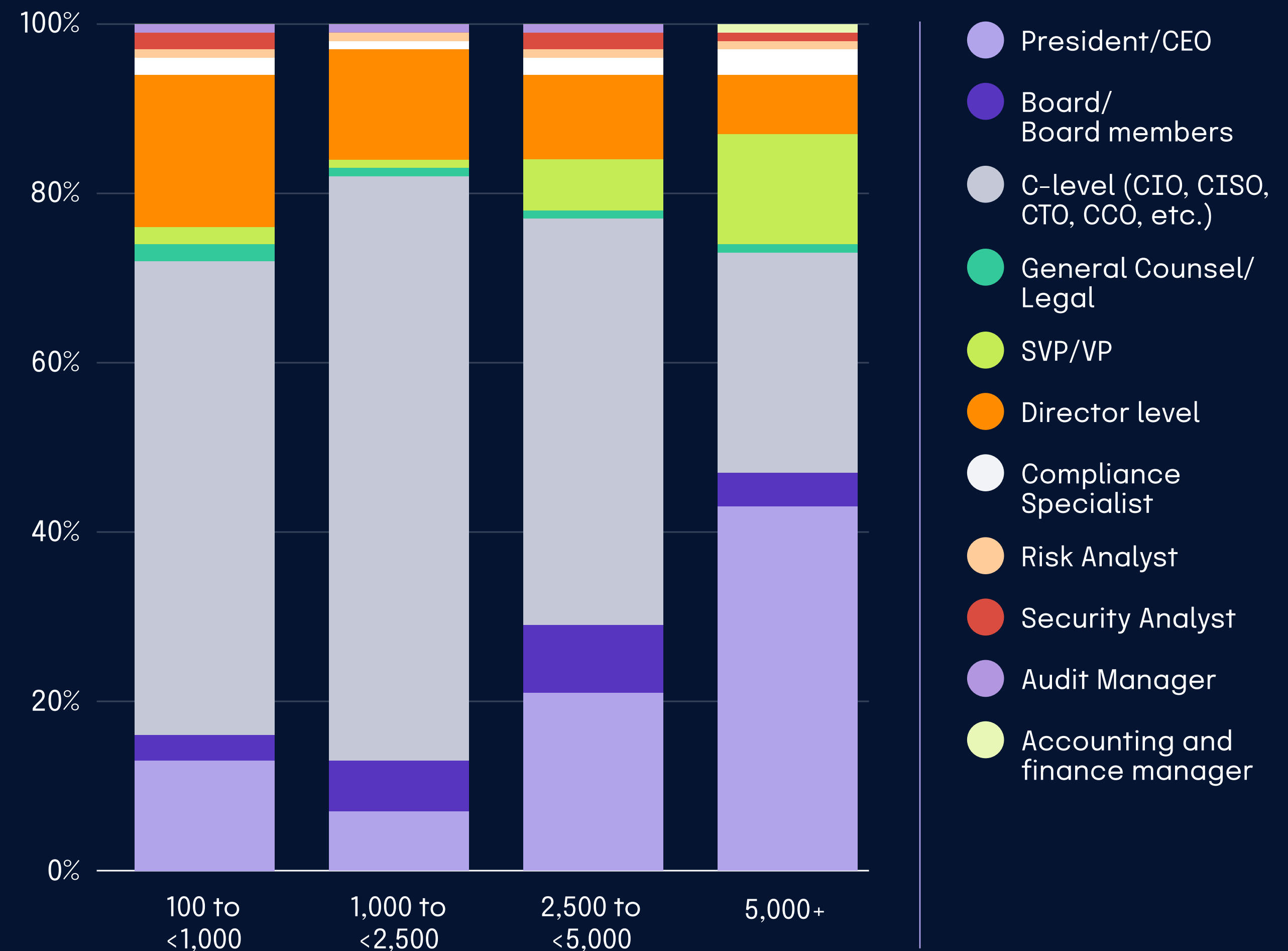


Oversight remains senior, but the “owner” shifts as organizations scale

Oversight moves in different directions as organizations scale. Midsized organizations are most likely to report C-level oversight (69%), suggesting compliance is firmly positioned as an executive-owned function at that size band. In the largest organizations, C-level oversight drops to 26%, while President/CEO oversight rises to 43% and SVP/VP oversight rises to 13%. One interpretation is that as organizations become very large, compliance oversight becomes more distributed across senior layers or owned at the very top, depending on how governance is structured, which can change how consistently priorities translate into day-to-day execution. Senior oversight is common, but the exact seat of oversight can materially influence how policy decisions, control standards, and reporting expectations are reinforced across the business.

What is the highest level position or title overseeing compliance?

by company size



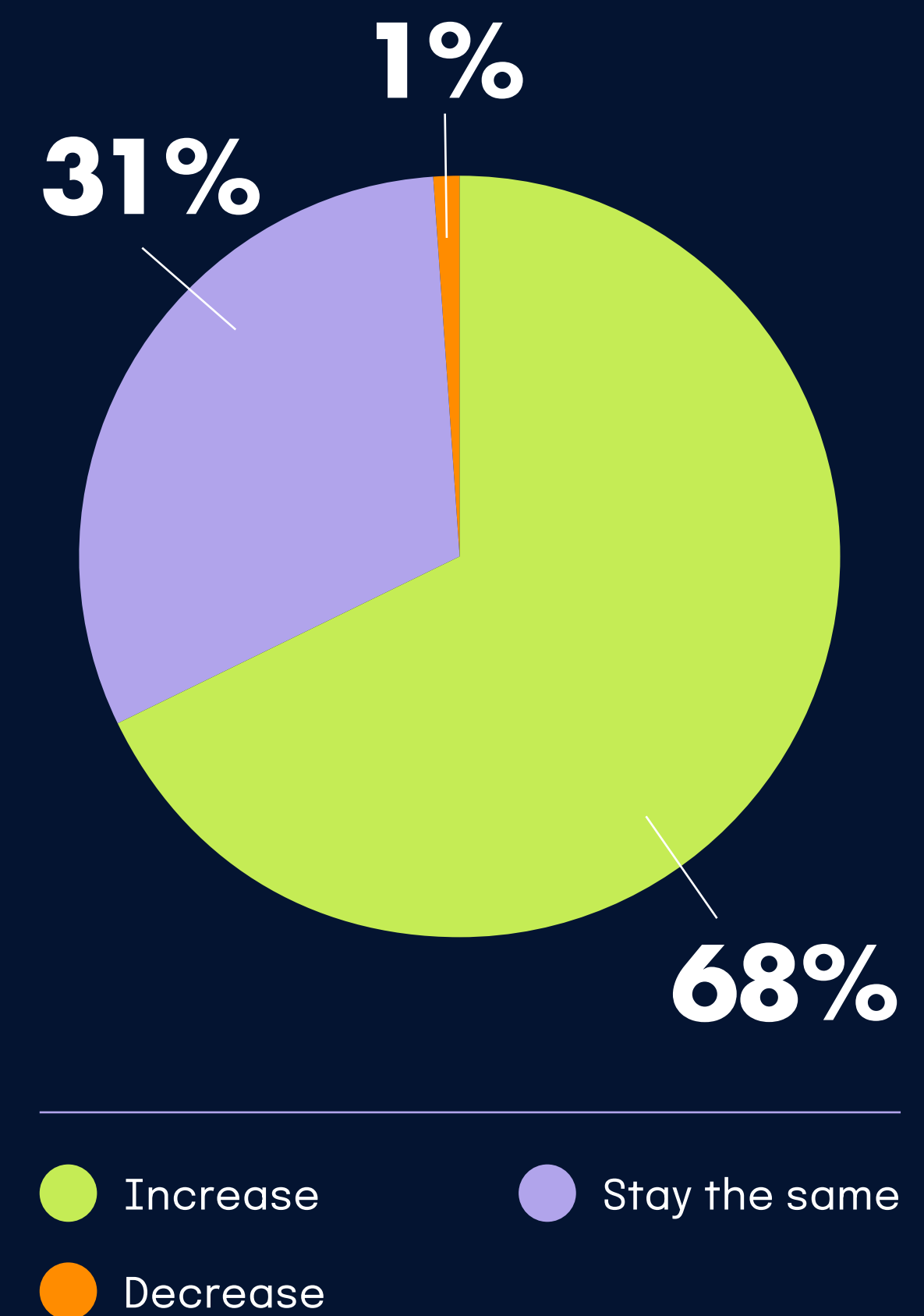
Growth expectations are strong, especially where investment and automation are higher

Respondents express strong expectations for team growth over the next two years, indicating that many organizations anticipate increased workloads and plan to expand capacity accordingly. This optimism aligns with broader signals that risk and compliance work is becoming more continuous and central to business operations. It also suggests that organizations expect rising requirements and are preparing for an environment where maintaining readiness demands sustained effort.

However, headcount growth alone rarely solves the core scaling challenge. As teams expand, they often inherit a larger scope, more stakeholders, and more evidence requirements. Without standardization, growth can simply increase the number of people coordinating manual work rather than increasing throughput and consistency. The most effective teams pair growth with investments in repeatable processes and systems that reduce administrative overhead, maintain traceability, and make reporting defensible at scale.

This is where the operating model matters as much as the org chart. Teams that scale successfully typically define clear ownership for key workflows, standardize control and evidence expectations, and reduce reliance on ad hoc follow-up by embedding workflows into a shared system.

In the next two years, which best describes the growth of your company's compliance team in terms of personnel?

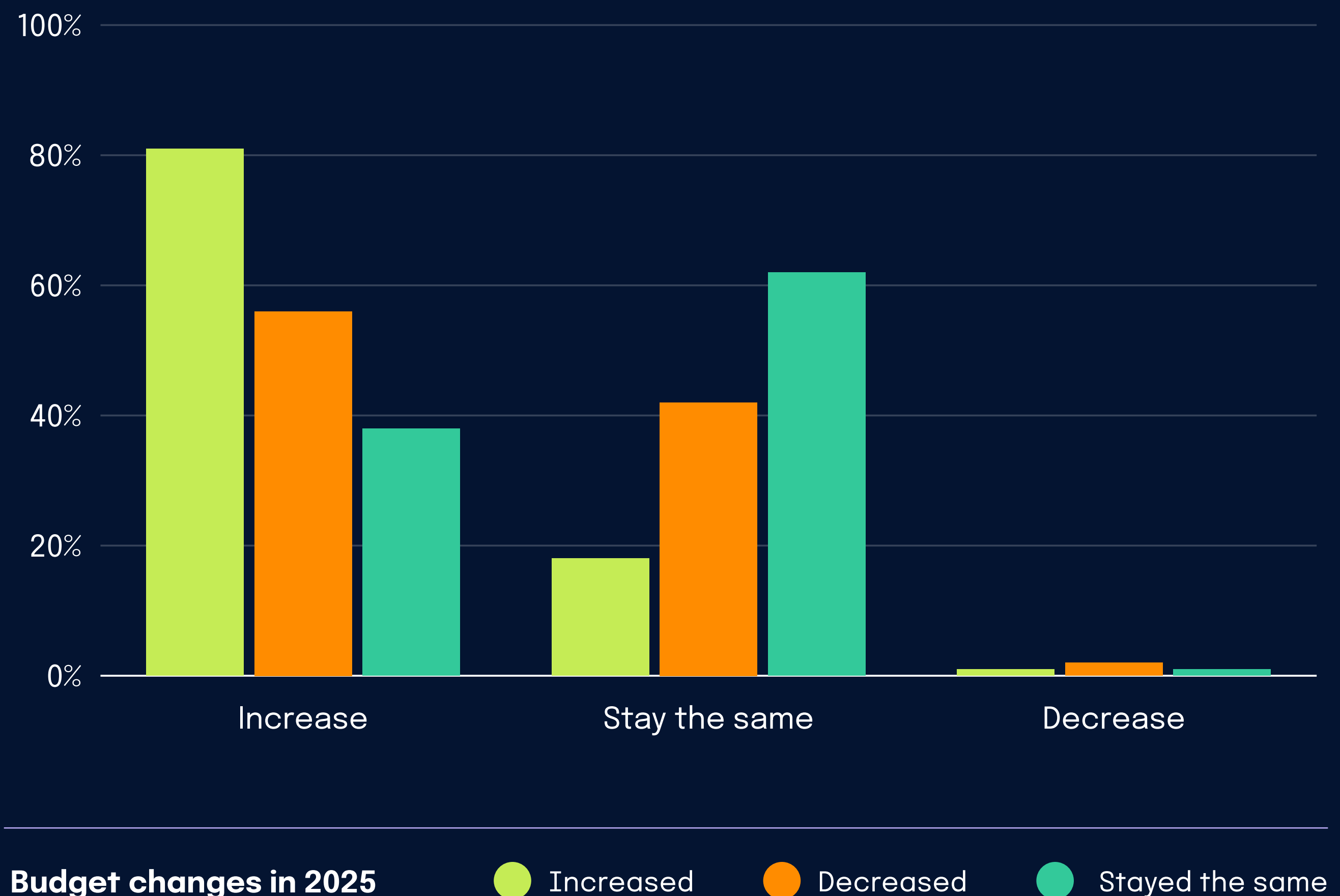


Budget momentum strongly shapes expectations for headcount growth

Hiring expectations track strongly with recent budget momentum. When budgets increased, 81% expect headcount to increase, indicating that many organizations view compliance capacity as something they need to expand alongside program scope. When budgets stayed the same, the dominant expectation becomes stability: only 38% expect growth, while 62% expect the team to stay the same. Even when budgets decreased, a majority still anticipate growth (56%), which suggests either optimism about recovery or recognition that demand is rising regardless of financial pressure. For readers, the takeaway is that teams are forecasting growth, but the likelihood of growth is much higher when there is already a budget tailwind behind it.

In the next two years, which best describes the growth of your company's compliance team in terms of personnel?

by 2025 GRC budget changes

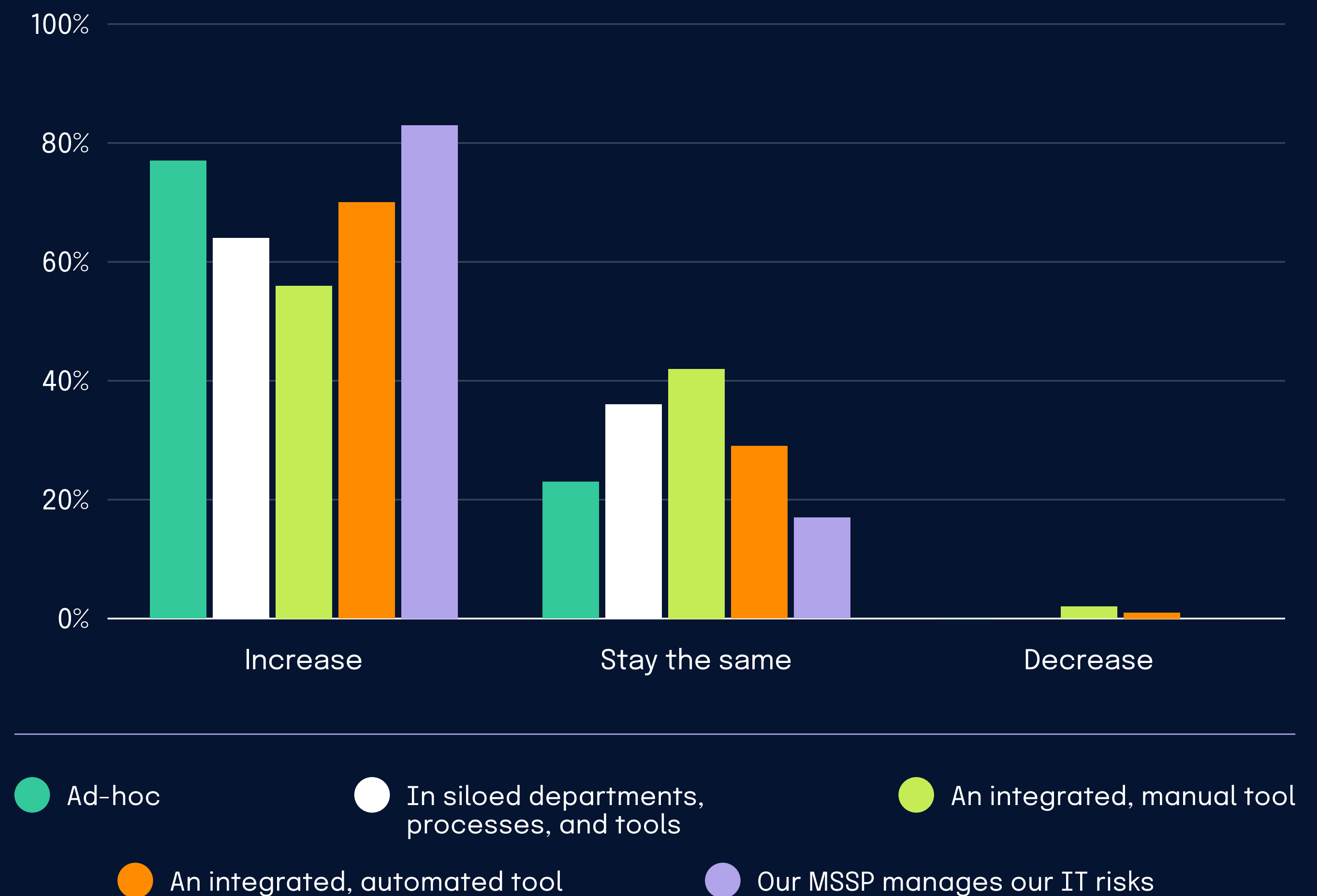


Operating model maturity influences how teams plan to scale

Team growth expectations align with operating model maturity. Respondents whose IT risks are managed by an MSSP are most likely to expect growth (83%), followed by those who manage risk ad-hoc (77%) and those using an integrated tool that's mostly automated (70%). The lowest growth expectation appears among respondents using an integrated tool that's mostly manual (56%), where 42% expect staffing to remain the same. One interpretation is that manual, integrated environments may already feel stretched and constrained by execution overhead, making staffing expansion harder to secure, while more mature or externally supported operating models may have clearer justification for scaling capacity and scope.

In the next two years, which best describes the growth of your company's compliance team in terms of personnel?

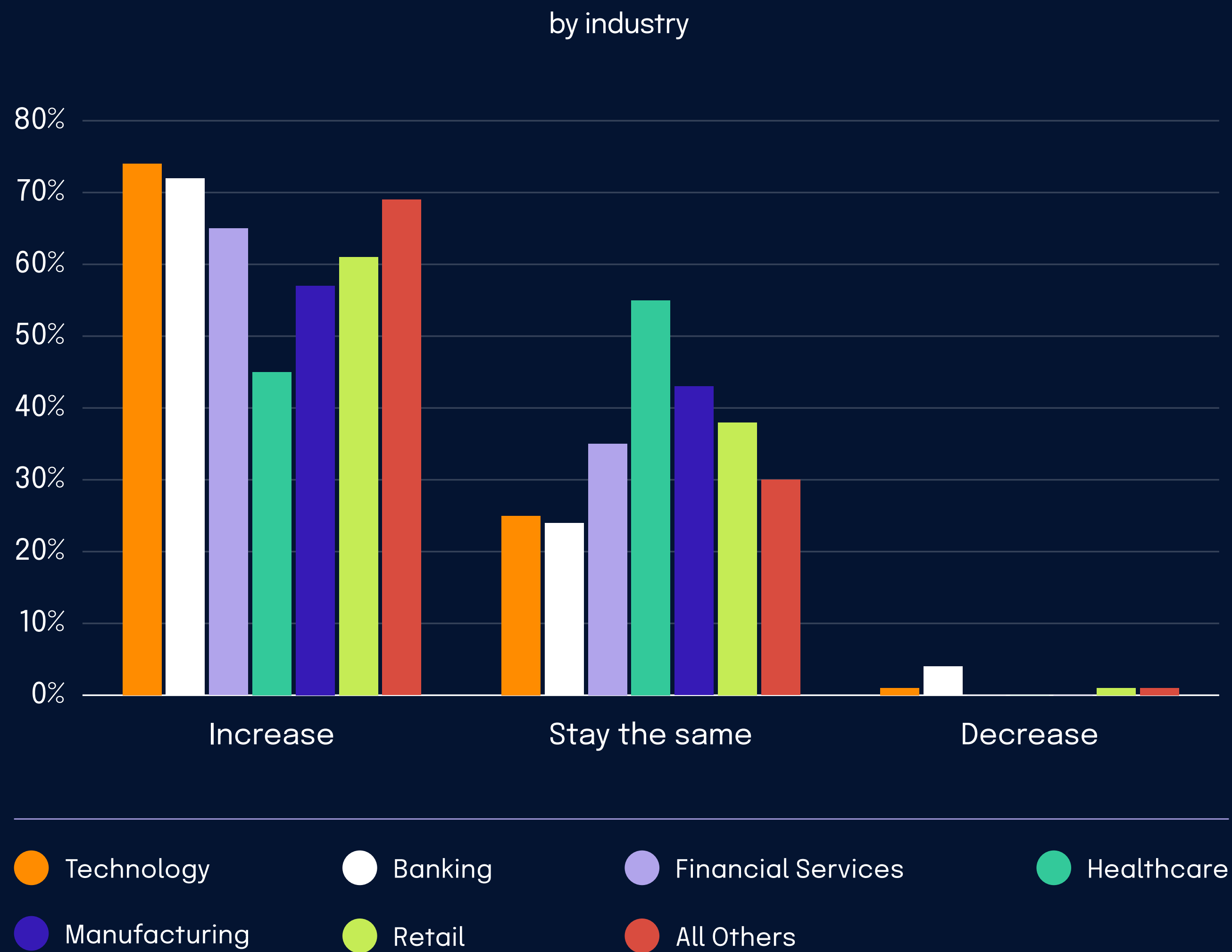
by approach to managing IT risks



Staffing growth expectations vary meaningfully by industry

Industries differ meaningfully in how aggressively they expect to scale compliance staffing. Technology (74%) and Banking (72%) show the strongest growth expectations, signaling continued investment in assurance and compliance execution. Healthcare is the clear outlier, with only 45% expecting growth and 55% expecting team size to stay the same, suggesting a more stability-oriented staffing posture in this sample. Manufacturing is also more conservative than Technology, with 57% expecting growth. The practical implication is that staffing expectations reflect both perceived regulatory and customer pressure and the extent to which organizations believe they can meet rising requirements through operating model improvements rather than headcount.

In the next two years, which best describes the growth of your company's compliance team in terms of personnel?

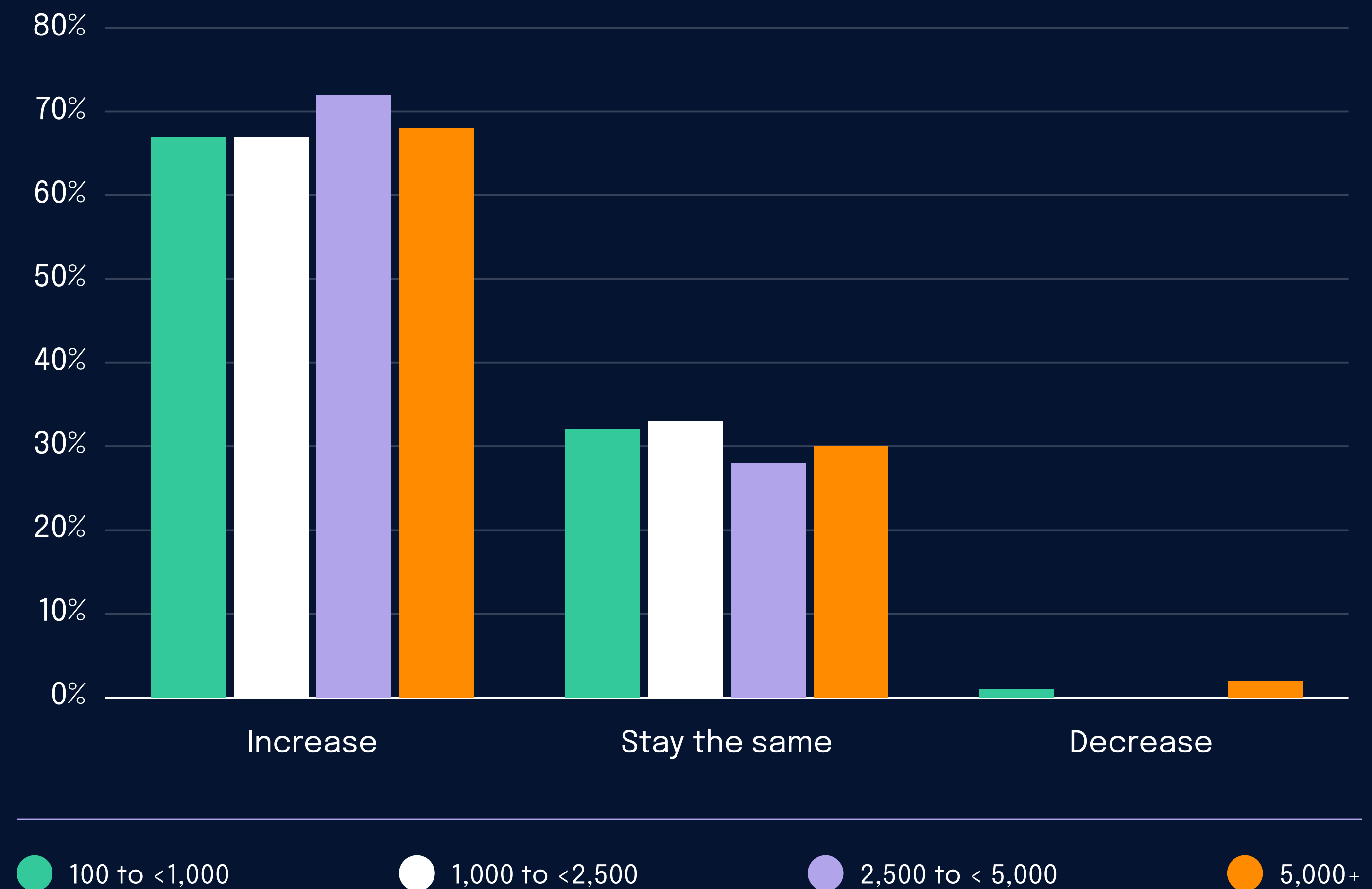


Growth intent is widespread across sizes, even where headcount stays flat

Growth expectations are consistently high across size bands, with less dramatic variation than in other cuts. Organizations with 2,500 to less than 5,000 employees are most likely to expect growth (72%), while the smallest and mid-size bands sit at 67%, and 5,000+ sits at 68%. The more important nuance is that even in the largest enterprises, a meaningful minority expects staffing to stay flat (30%), reinforcing that many large organizations are still trying to scale readiness through standardization and tooling rather than relying solely on headcount.

In the next two years, which best describes the growth of your company's compliance team in terms of personnel?

by company size



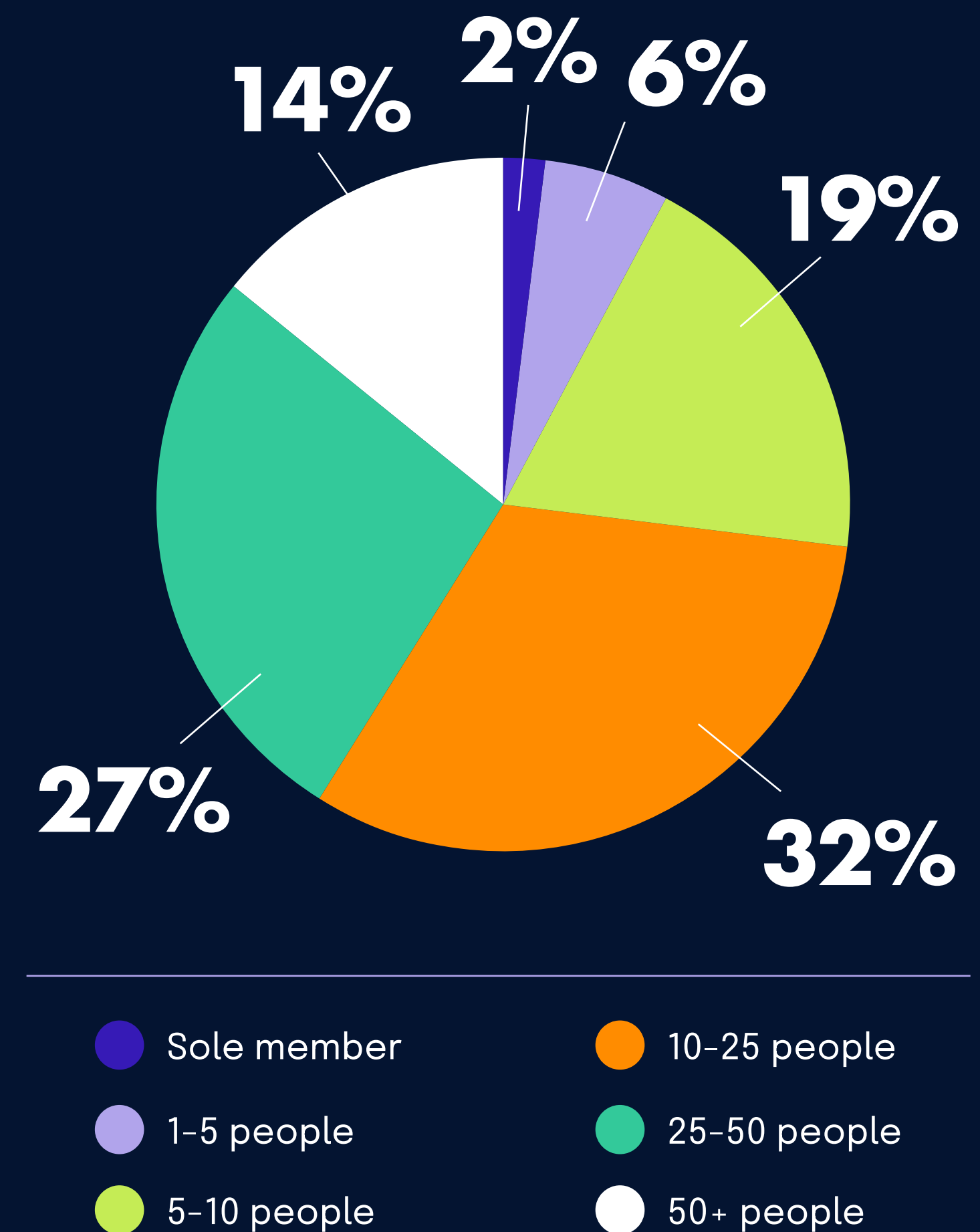
Many programs are substantial, and expectations for impact will follow

Team size provides a baseline lens for understanding decision-making and growth expectations. Many respondents report working in established compliance and risk teams rather than being the only individual responsible. That matters because as teams become more substantial, the demand for consistency increases. Larger teams typically require clearer workflow definitions, stronger governance, and shared systems that prevent knowledge from being siloed in individuals or departments.

It also reinforces why technology decisions become more consequential as programs scale. A tool that works for a small team may not support standardized execution across a larger, distributed set of stakeholders. As team size grows, the need for shared evidence practices, standardized control mapping, and consistent reporting becomes more central to program effectiveness.

For leaders, the implication is that scale should drive intentional design. Mature teams are not simply larger; they are more consistent. They operate with repeatable processes, clear roles, and systems that make readiness and reporting sustainable.

What is the size of your compliance management and/or risk management team?

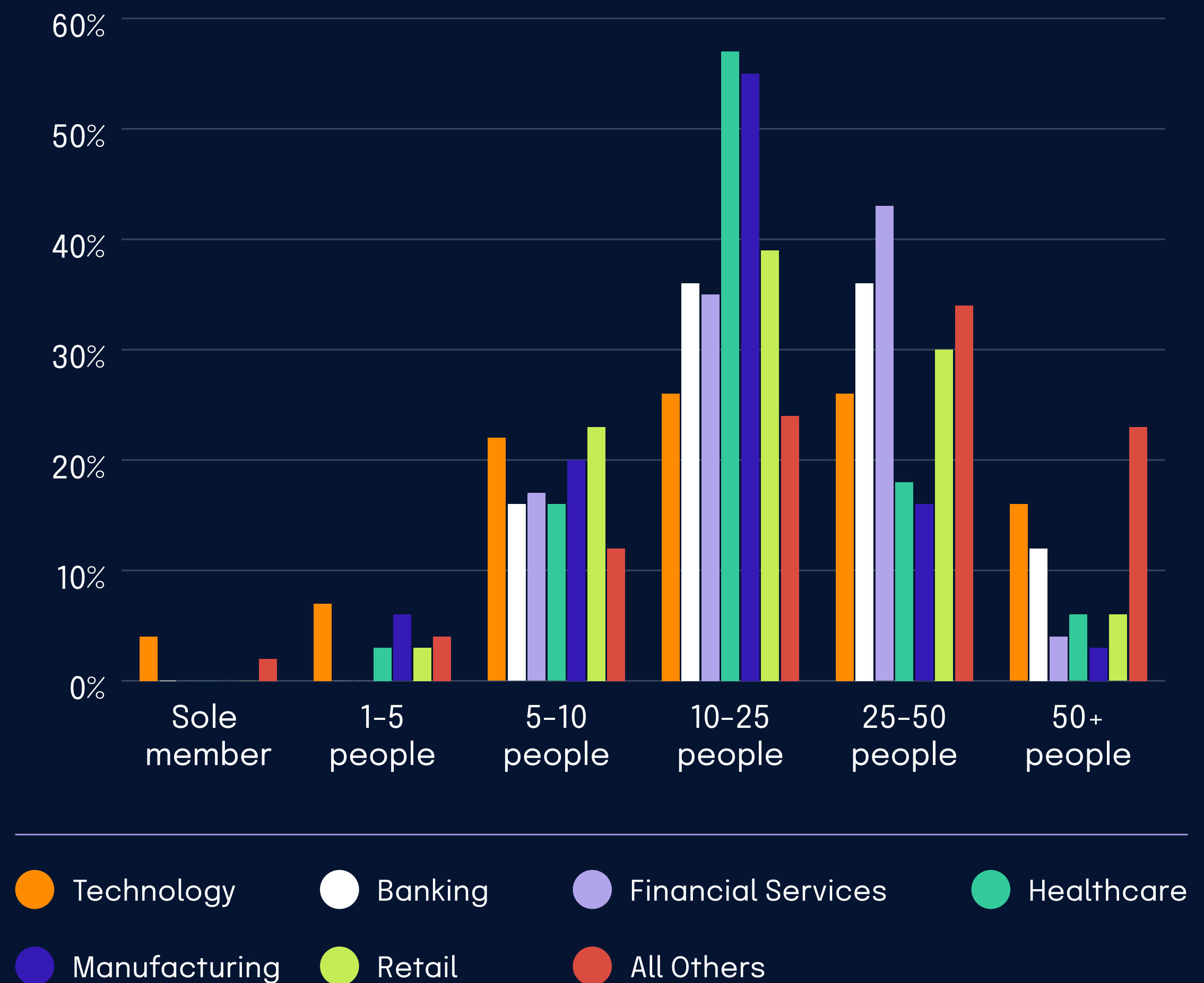


Team size reflects industry complexity and assurance expectations

Team size distribution varies substantially by industry, revealing very different operating realities. Healthcare is heavily concentrated in the 10–25 people band (57%), suggesting structured teams with defined responsibilities but not necessarily very large scale. Manufacturing shows a similar concentration in 10–25 people (55%), indicating many programs operate at a mid-sized team level. Financial Services stands out with a stronger tilt toward larger teams, peaking in 25–50 people (43%), which aligns with the complexity and breadth of third-party and regulatory exposure typical of that sector. “All Others” has the highest share of very large teams (50+ people: 23%), suggesting that this category likely includes organizations with broader program scope or more centralized enterprise risk/compliance functions. The key takeaway is that “typical” team size is highly industry-dependent, which affects what “good” operational scale looks like.

What is the size of your compliance management and/or risk management team?

by industry

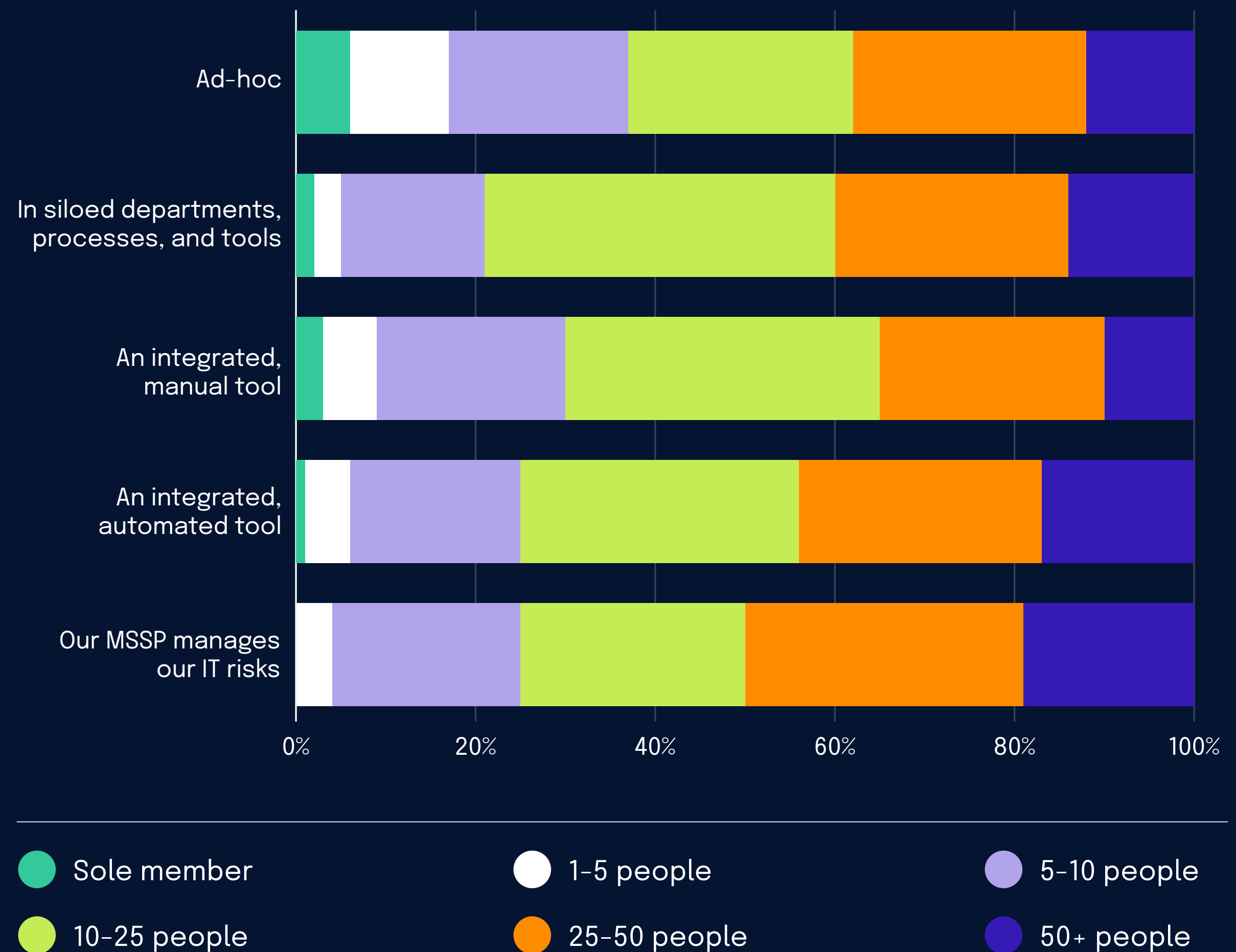


Team scale and operating model do not always move in lockstep

Team size also shifts with how organizations manage IT risk. Ad-hoc approaches skew smaller, with a higher share of respondents in 1–5 people (11%) and a higher presence of “sole member” teams (6%), which can make consistent execution difficult as scope grows. Siloed approaches concentrate in the mid-range, with 39% in the 10–25 people band, suggesting that larger teams do not automatically imply integrated execution. The largest-team signals show up most clearly in MSSP-managed models, which have the highest shares in 25–50 people (31%) and 50+ people (19%). The broader implication is that operating model maturity and team scale move together in some cases, but not always; organizations can have sizable teams and still operate in ways that create fragmentation, which makes process standardization and shared systems more important than headcount alone.

What is the size of your compliance management and/or risk management team?

By approach to managing IT risks

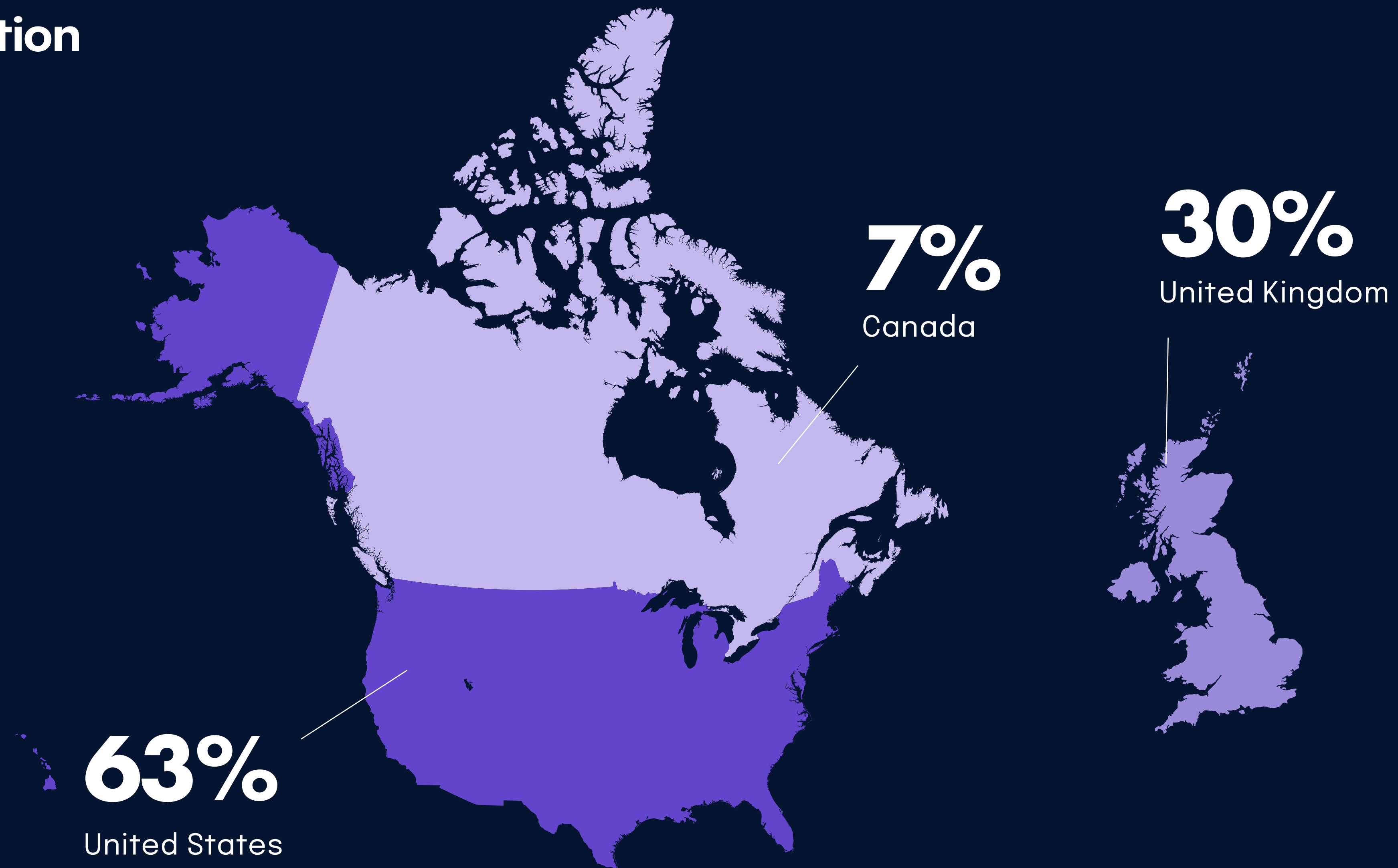


2026

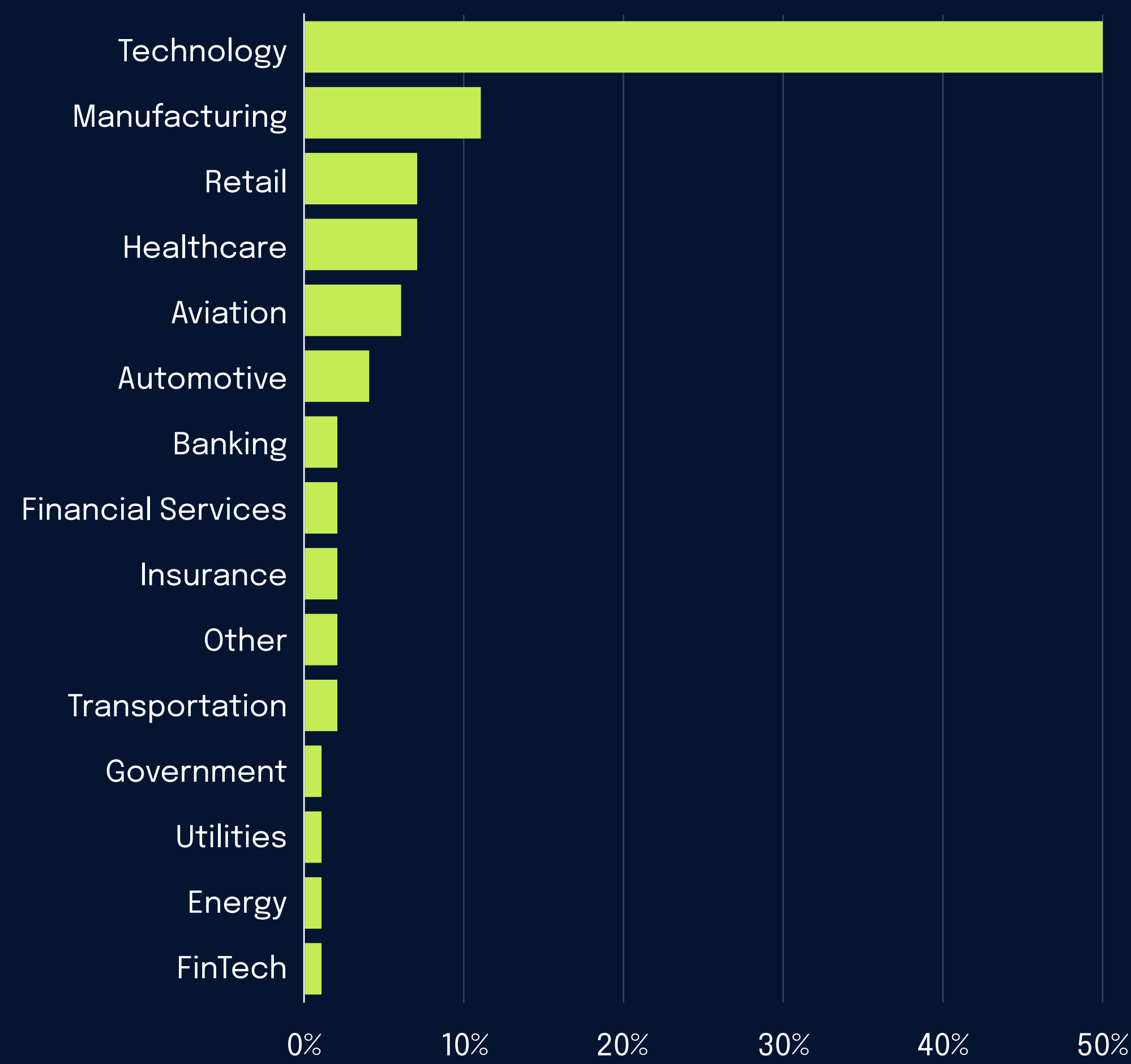
Survey Methodology

The 2026 IT Risk and Compliance Benchmark Survey gathered **1,002 responses during November and December of 2025.**

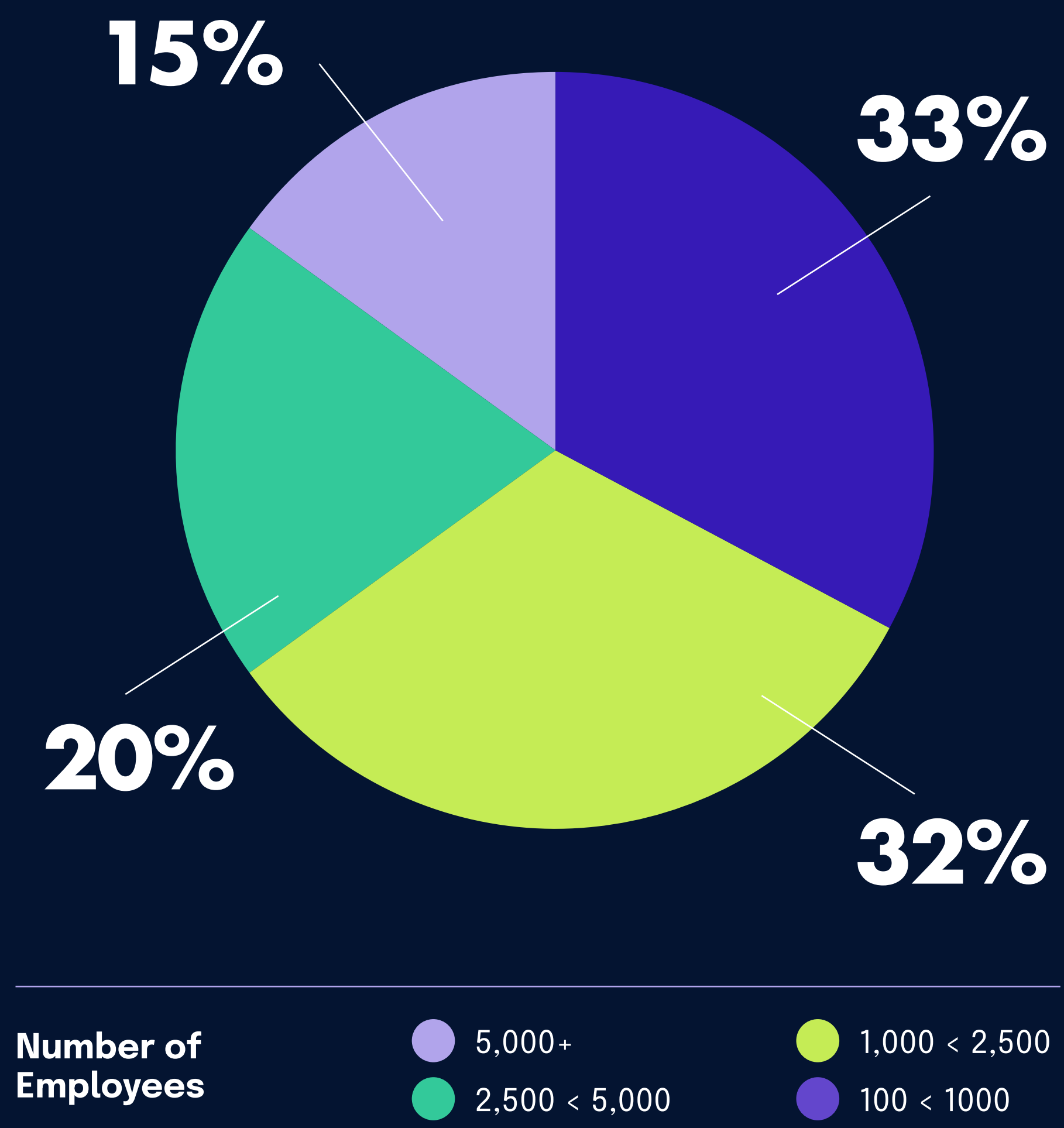
Location



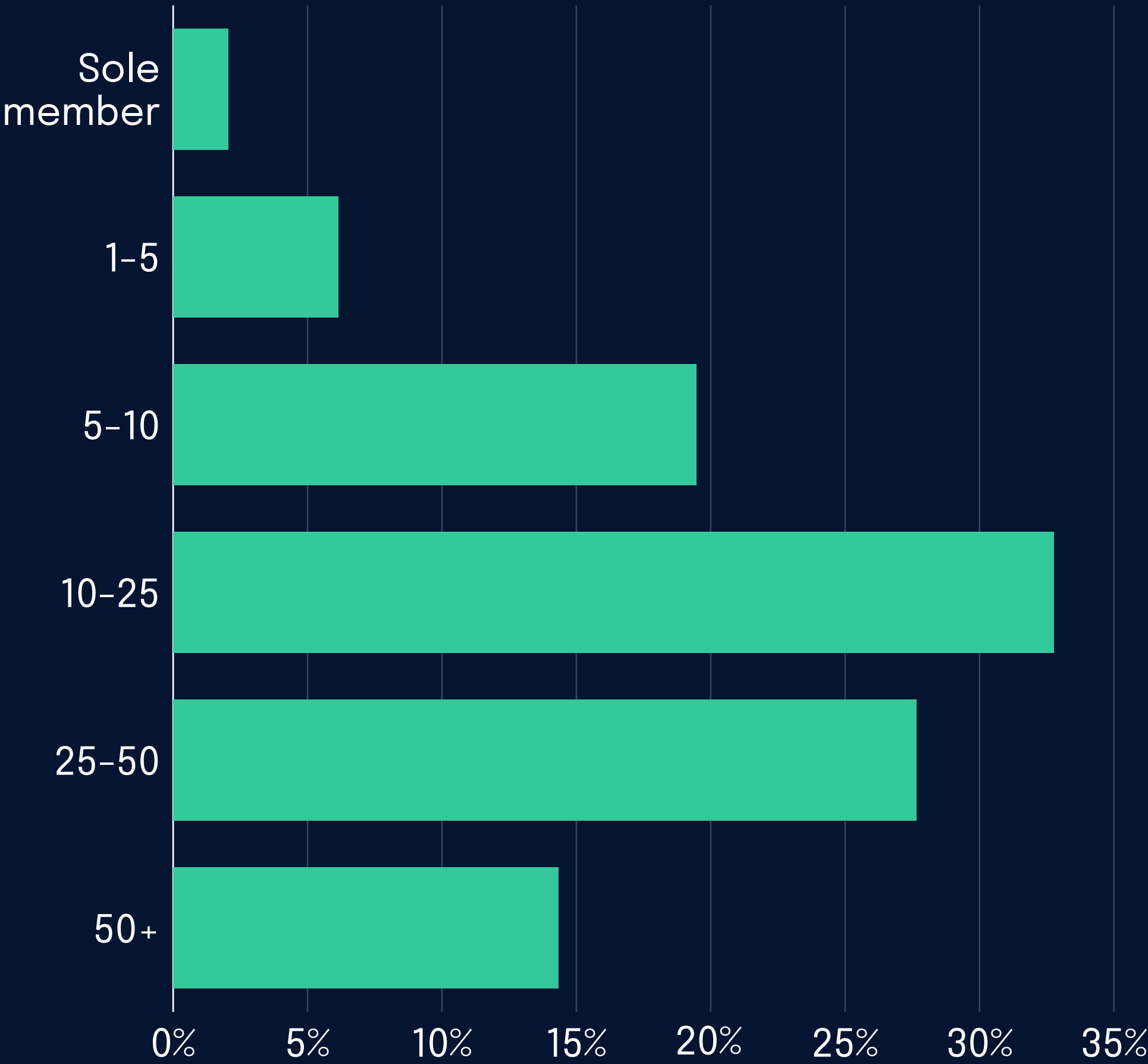
Industries surveyed



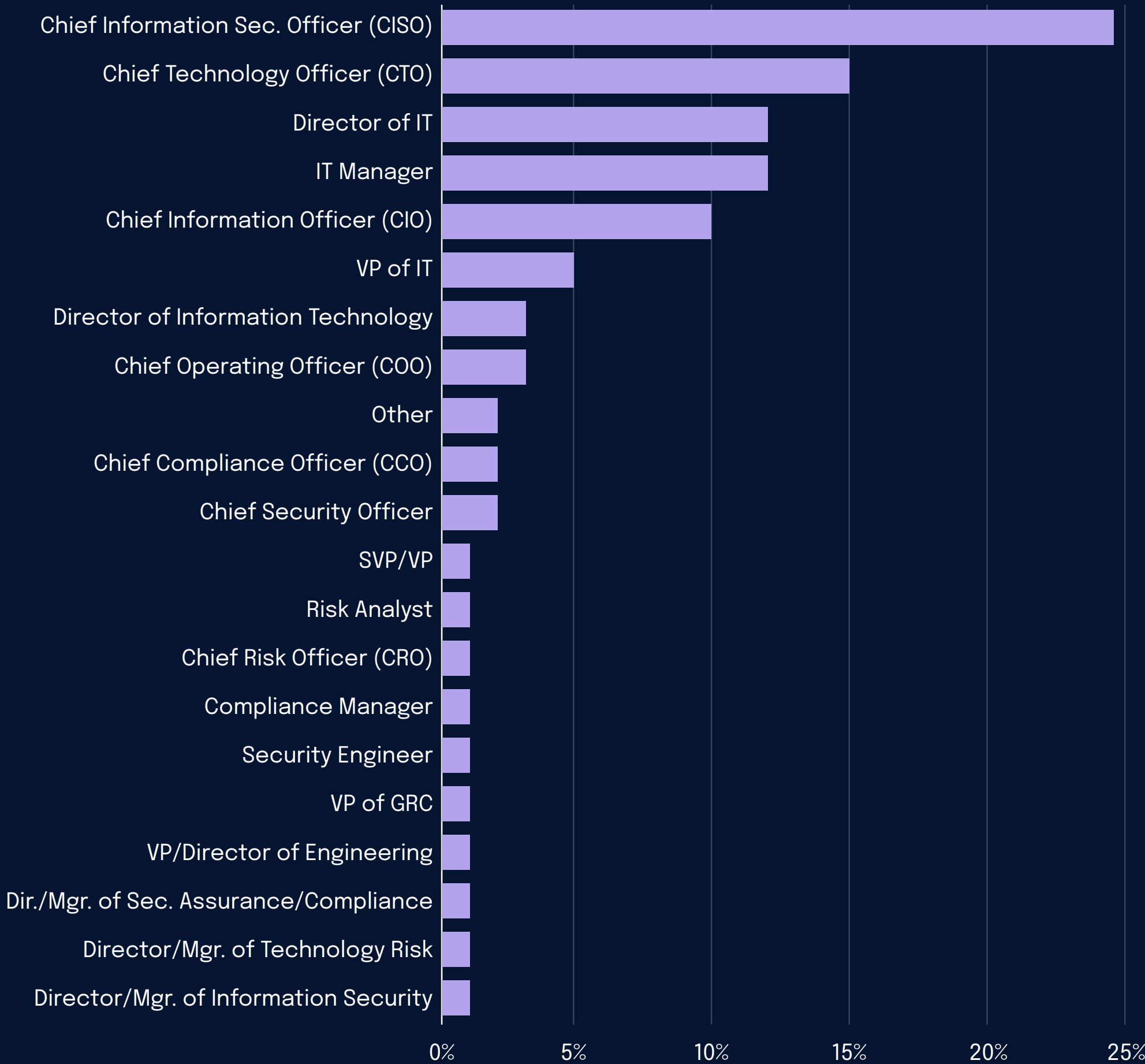
Organization size



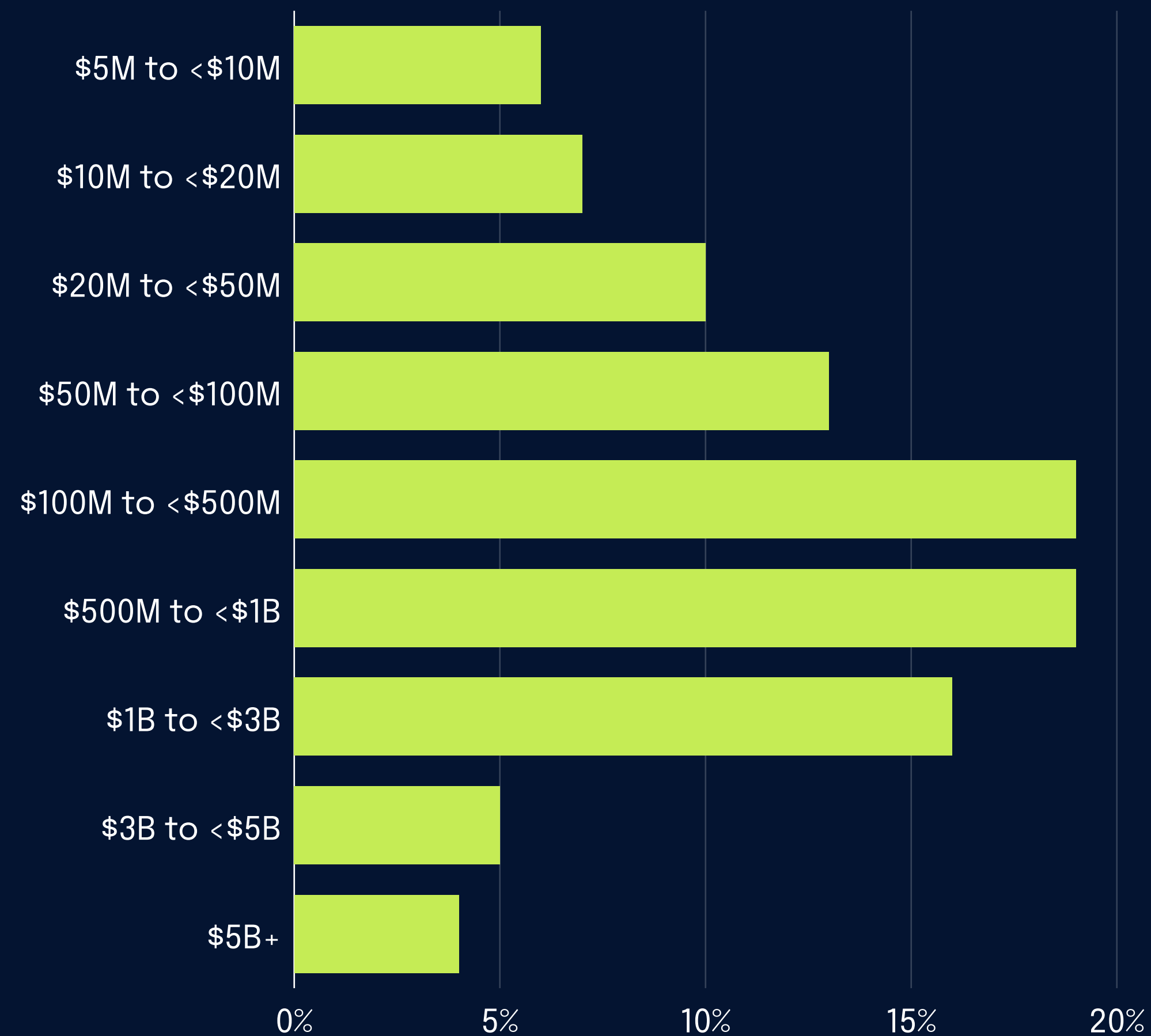
Team size



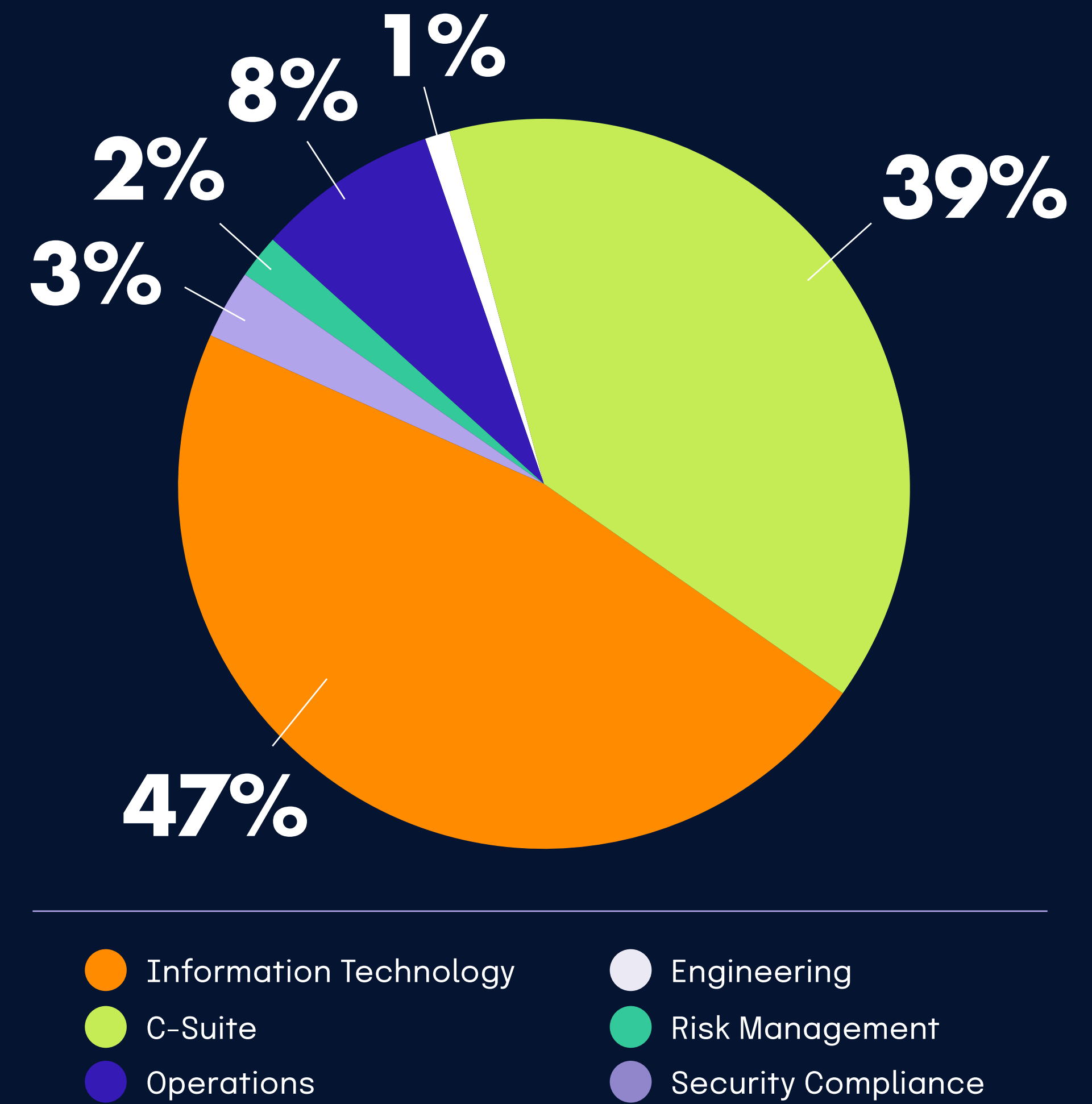
Job titles



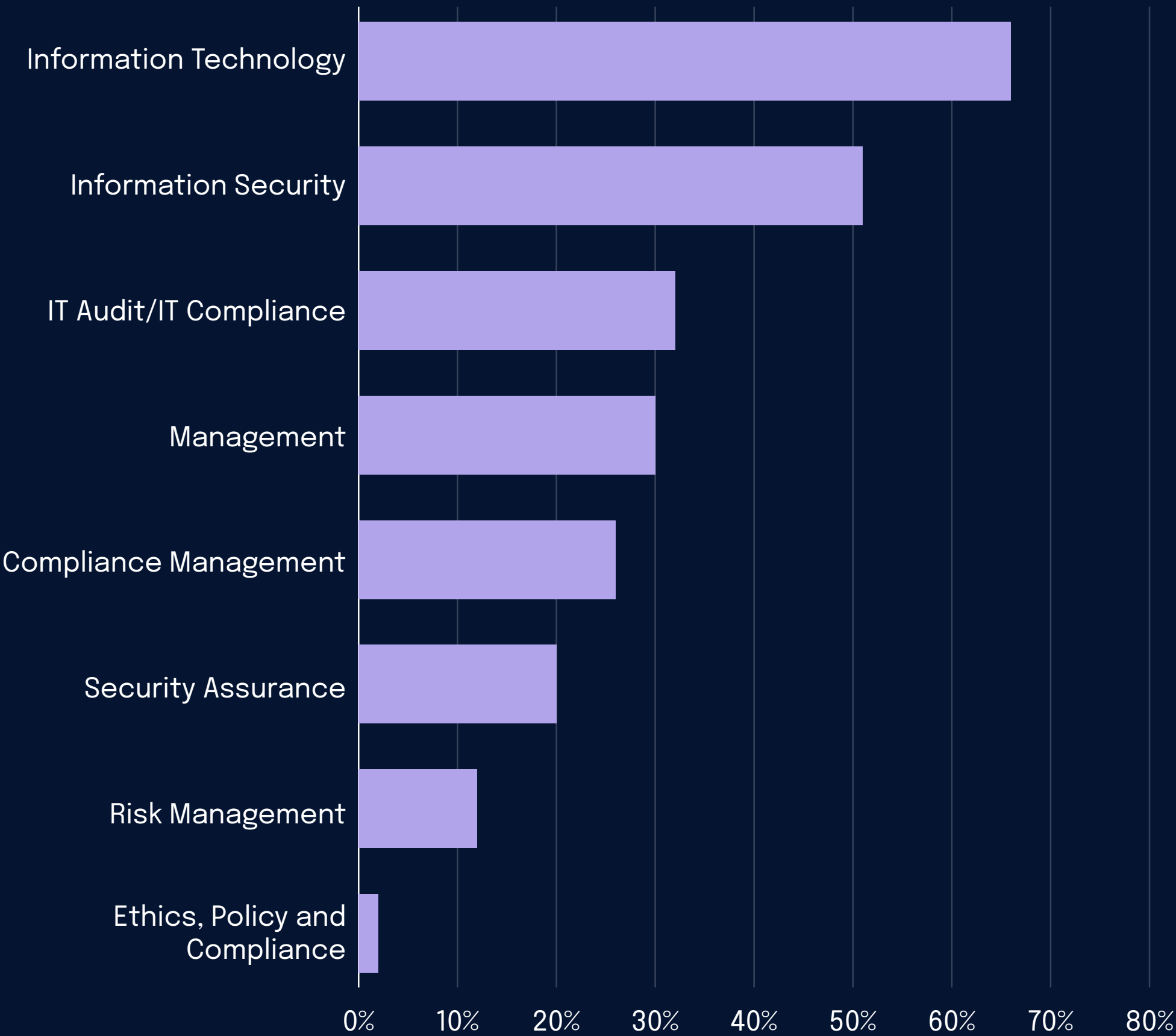
Revenue



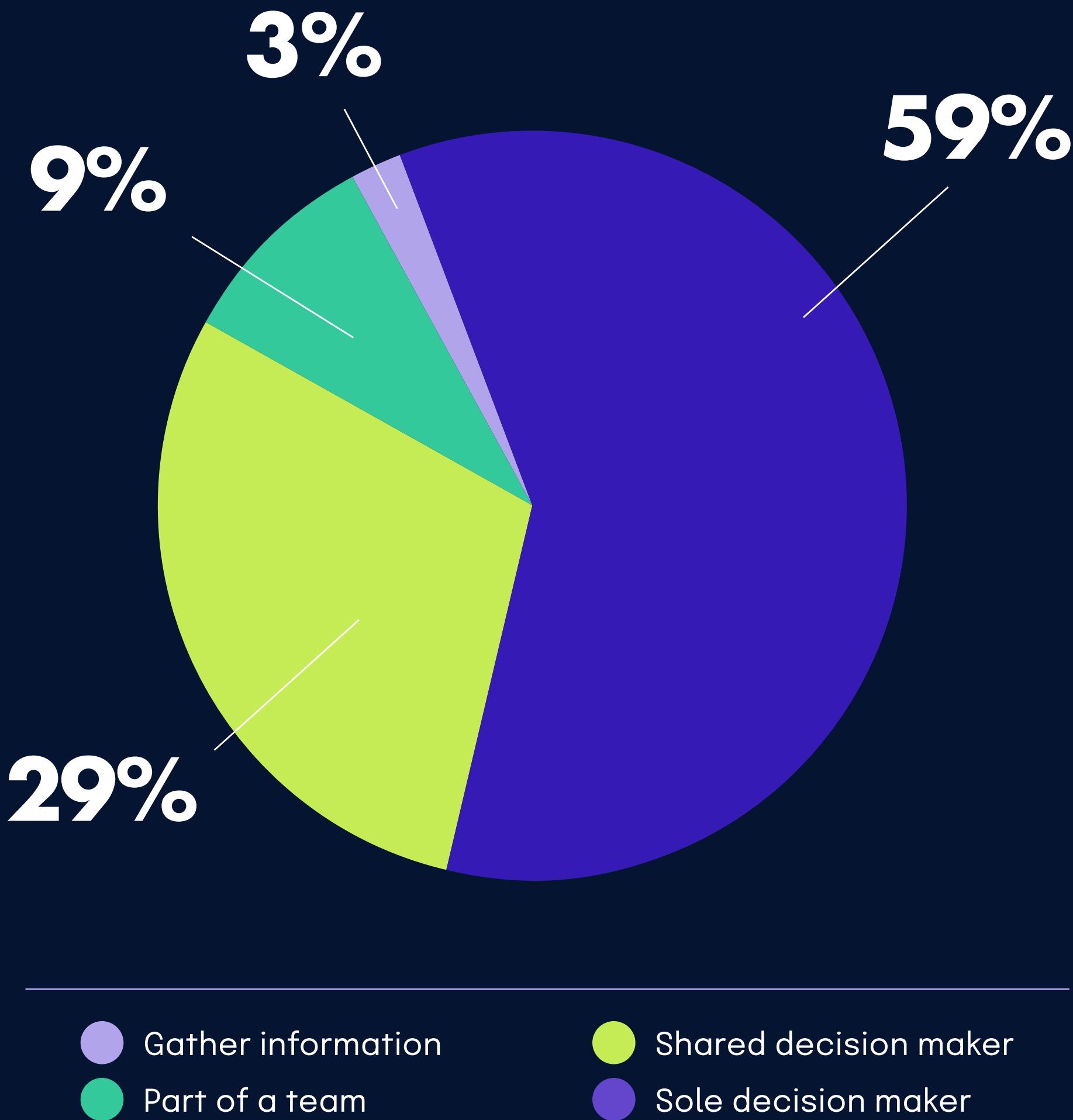
Department



Job function



Decision-making capabilities





About Hyperproof

Hyperproof is a modern, AI-powered GRC platform that empowers IT, security, and compliance teams to manage controls at scale, integrate their risk operations, and build trust with customers. With Hyperproof, you can scale compliance across your business, automate many controls and orchestrate the rest, connect controls to risks to protect your business, and unlock new business by automating security questionnaires and trust management. Leading organizations like Reddit, Fortinet, Appian, Outreach, and Thales trust Hyperproof.

To learn more about Hyperproof, visit hyperproof.io